

False Positive Documentation

Kindly provide the answers for the following queries regarding the vulnerability.

1. Name of the Application

Pledgivo

2. Package ID/Version ID/Listing ID

Package ID: 0Hof600000000iHCAU · Version ID: 04tf6000000RdB1AAK (Pledgivo 1.2.4-1 (Managed - Released)) · Listing ID: not yet listed

3. Partner Name

CloudAlgo

4. Document Filing Date (YYYY-MM-DD)

2026-10-09

5. Target URL (Optional)

6. Review Date (In Case if app already undergone security review)

Repeat Step 7 to 10 in case of multiple Vulnerability — 91 vulnerabilities follow, one per flagged code location (273 scanner paths; a location flagged by several paths or queries is answered once, and Appendix A maps every path to its entry)

7. Vulnerability Name

Apex CRUD Violation — classes/payment/service/PaymentSetupGuideService.cls:1918 (R-001; Apex CRUD Violation paths 1, 9, 14)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

8. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

9. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `if (m.find()) {`

WHY THE CLAIM IS FALSE

The claim is false because the flagged line is a regular-expression match on a string already in memory, not a query or DML statement, so no CRUD operation exists to check; the string was read with `WITH USER_MODE`, so the running administrator's permissions were already enforced.

SUPPORTING DETAIL

The flagged line is a regular-expression match on a string already in memory; it is not a query or DML statement. The data it examines was read with `WITH USER_MODE`, so the running administrator's object and field permissions were already enforced, and only credential and parameter names are retained for a setup checklist. The path is reachable only by the administrator permission set; the fake-Id generator source is test-only and the other is the SOQL builder.

LOCATION IN THE SUBMITTED SOURCE

`classes/payment/service/PaymentSetupGuideService.cls:1918`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (system mode ignores the running user's FLS and object permissions; record sharing is governed by the class sharing keyword. Verified via search excerpt only; page body not fetchable)

10. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PaymentSetupGuideService.cls:1918
if (m.find()) {
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 1 (ONE OF 1, 9, 14)

```
classes/fflib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)
classes/fflib_IDGenerator.cls:39 String keyPrefix = objectType.getDescribe().getKeyPrefix();
classes/fflib_IDGenerator.cls:44 return Id.valueOf(keyPrefix + fakeIdPrefix + fakeIdCount);
classes/PaymentSetupGuideService_Test.cls:2070 new Set<Id>{
fflib_IDGenerator.generate(NamedCredential.SObjectType) });
classes/PaymentSetupGuideService.cls:1608 protected virtual Map<Id, List<CustomHttpHeader>>
queryCustomHeaders(Set<Id> namedCredentialIds) {
classes/PaymentSetupGuideService.cls:1613 WHERE ParentId IN :namedCredentialIds
classes/PaymentSetupGuideService.cls:1610 for (CustomHttpHeader header : [
classes/PaymentSetupGuideService.cls:1618 byParent.put(header.ParentId, new List<CustomHttpHeader>
());
classes/PaymentSetupGuideService.cls:1620 byParent.get(header.ParentId).add(header);
classes/PaymentSetupGuideService.cls:1622 return byParent;
classes/PaymentSetupGuideService.cls:1397 source.headersByParent = queryCustomHeaders(ids);
classes/PaymentSetupGuideService.cls:1403 return source;
classes/PaymentSetupGuideService.cls:184 CredentialSource source = readCredentials(new Set<String>
{ publicName, adminName });
classes/PaymentSetupGuideService.cls:188 Reading reading = source.reading(publicName, shape);
classes/PaymentSetupGuideService.cls:1895 collectHeader(r, headersByParent.get(nc.Id), shape);
classes/PaymentSetupGuideService.cls:1909 private static void collectHeader(Reading r,
List<CustomHttpHeader> headers,
classes/PaymentSetupGuideService.cls:1913 for (CustomHttpHeader header : headers) {
classes/PaymentSetupGuideService.cls:1917 Matcher m =
MERGE_FORMULA.matcher(nullToBlank(header.HeaderFieldValue));
classes/PaymentSetupGuideService.cls:1832 private static String nullToBlank(String value) {
classes/PaymentSetupGuideService.cls:1833 return (value == null) ? '' : value;
classes/PaymentSetupGuideService.cls:1917 Matcher m =
MERGE_FORMULA.matcher(nullToBlank(header.HeaderFieldValue));
classes/PaymentSetupGuideService.cls:1918 if (m.find()) {
```

EVIDENCE CHECKED

- base/main/default/classes/payment/service/PaymentSetupGuideService.cls:1917 Matcher m = MERGE_FORMULA.matcher(...); if (m.find())
- queryNamedCredentials (:1583) and queryCustomHeaders (:1607) WITH USER_MODE
- base/main/default/classes/setup/controller/SetupController.cls:479; SetupController granted only in Fundraising_Admin
- fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

11. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:518` (R-002; Apex CRUD Violation paths 2, 18)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

12. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

13. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }`

WHY THE CLAIM IS FALSE

The claim is false because this is an internal alert from a scheduled job using explicit addresses, no target record and `setSaveAsActivity(false)`; it performs no DML and no user- or guest-reachable path leads to it.

SUPPORTING DETAIL

This is an internal alert sent by a scheduled reconciliation job to the owner of a disputed gift and the configured reply-to address; it uses explicit addresses, no target record, and `setSaveAsActivity(false)`, so it performs no DML. No user- or guest-reachable code path reaches it; the reported sources are a test-only fake-Id generator and the SOQL builder's parameter methods. The send was reviewed for a code change on 2026-10-01 and none applies:

`Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:518`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

14. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:518
if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 2 (ONE OF 2, 18)

```

classes/fplib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)
classes/fplib_IDGenerator.cls:39 String keyPrefix = objectType.getDescribe().getKeyPrefix();
classes/fplib_IDGenerator.cls:44 return Id.valueOf(keyPrefix + fakeIdPrefix + fakeIdCount);
classes/ReceiptService_Test.cls:449 Id oppId =
fplib_IDGenerator.generate(Opportunity.SObjectType);
classes/ReceiptService_Test.cls:476 Messaging.SingleEmailMessage msg = new
ReceiptService().buildDisputeAlert(oppId);
classes/ReceiptService.cls:534 private Messaging.SingleEmailMessage buildDisputeAlert(Id
opportunityId) {
classes/ReceiptService.cls:537 List<Opportunity> opps = oppSel.selectOwnerEmailById(new Set<Id>{
opportunityId });
classes/OpportunitiesSelector.cls:940 public List<Opportunity> selectOwnerEmailById(Set<Id> idSet)
{
classes/OpportunitiesSelector.cls:947 soql, new Map<String, Object>{ 'idSet' => idSet },
AccessLevel.SYSTEM_MODE
classes/OpportunitiesSelector.cls:946 return (List<Opportunity>) Database.queryWithBinds(
classes/ReceiptService.cls:537 List<Opportunity> opps = oppSel.selectOwnerEmailById(new Set<Id>{
opportunityId });
classes/ReceiptService.cls:538 return opps.isEmpty() ? null : buildDisputeAlert(opps[0]);
classes/ReceiptService.cls:544 private Messaging.SingleEmailMessage buildDisputeAlert(Opportunity
o) {
classes/ReceiptService.cls:548 if (o.Owner != null && String.isNotBlank(o.Owner.Email)) {
recipients.add(o.Owner.Email); }
classes/ReceiptService.cls:551 if (recipients.isEmpty()) {
classes/ReceiptService.cls:575 msg.setToAddresses(new List<String>(recipients));
classes/ReceiptService.cls:576 msg.setSubject((String.isNotBlank(orgName) ? orgName + ' - ' : ''))
+
classes/ReceiptService.cls:578 msg.setPlainTextBody(body);
classes/ReceiptService.cls:579 msg.setSaveAsActivity(false);
classes/ReceiptService.cls:581 return msg;
classes/ReceiptService.cls:515 Messaging.SingleEmailMessage msg = buildDisputeAlert(o);
classes/ReceiptService.cls:516 if (msg != null) { msgs.add(msg); }
classes/ReceiptService.cls:518 if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }

```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:575-579 setToAddresses + setSaveAsActivity(false)
- base/main/default/classes/donation/async/RefundReconciliationBatch.cls:726 sole caller
- base/main/default/classes/donation/selector/OpportunitiesSelector.cls:940 selectOwnerEmailById SYSTEM_MODE
- fplib_ApexMocks.mock/verify and fplib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.
- fplib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

15. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:103` (R-003; Apex CRUD Violation paths 3, 10, 22)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

16. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

17. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

WHY THE CLAIM IS FALSE

The claim that a CRUD check is missing before a create/update/delete is false because `Messaging.sendEmail` is not a DML statement: with `setSaveAsActivity(false)` it writes no record at all, so there is nothing for `isCreateable()` to guard. The recipient and merge-field source are the just-finalized gift's own donor Contact, not a request parameter.

SUPPORTING DETAIL

This sink sends a template receipt to the donor Contact of the gift that was just finalized; `setTargetObjectId` and `setWhatId` select the recipient and the merge-field sources, and `setSaveAsActivity(false)` is set, so the send writes no Task/activity record and performs no DML the user could be denied. The recipient is derived from the Opportunity, never from caller input. The only interactive reach is a staff retry of a stuck donation (a permission-set-granted console action), which re-runs the same scheduled finalization and sends the receipt only on first creation of the gift. The QueryFactory 'source' is the SOQL builder, not an entry point. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:103`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (system mode ignores the running user's FLS and object permissions; record sharing is governed by the class sharing keyword. Verified via search excerpt only; page body not fetchable)

18. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:103  
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 3 (ONE OF 3, 10, 22)

```
classes/fflib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)  
classes/ReceiptService.cls:100 msg.setWhatId(opportunityId); // {!Opportunity.*} merge  
source  
classes/ReceiptService.cls:101 msg.setSaveAsActivity(false);  
classes/ReceiptService.cls:103 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:94-103 — setTemplateId, setTargetObjectId(targetContactId), setWhatId(opportunityId), setSaveAsActivity(false), applySender, sendEmail
- base/main/default/classes/donation/service/DonationService.cls:399 — sendDonationReceipt called on first creation only
- base/main/default/classes/donation/controller/DonationMonitorController.cls:57 retryDonationStagingNow -> StagingReconciliationBatch.reconcileOne (without sharing)
- base/main/default/classes/donation/selector/OpportunitiesSelector.cls:333 selectDonorContactById SYSTEM_MODE with reason comment
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

19. Vulnerability Name

Apex CRUD Violation — `classes/donor/service/DonorPortalService.cls:548` (R-004; Apex CRUD Violation paths 4, 20, 24)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

20. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

21. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ code.message });`

WHY THE CLAIM IS FALSE

The claim is false because the send itself performs no DML (`setSaveAsActivity(false)`); the staff actions that reach it re-read the donor Contact in user mode, so the running user's CRUD, FLS and sharing have already been enforced on the only record involved.

SUPPORTING DETAIL

The CRUD finding on the send itself is a false positive: `setSaveAsActivity(false)` is set and no record is written by `Messaging.sendEmail`. The staff 'send portal link' and 'show portal code' actions accept a Contact Id, so both staff twins re-read the donor in the staff user's own mode (`resolveStaffDonorEmail`, `USER_MODE` selectors for Contact and Person Account) and refuse a donor that user cannot see, before any code is minted, any email is sent or any address is returned. The guest path, which is authorized by possession of the code it produces, is unchanged. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donor/service/DonorPortalService.cls:548`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (system mode ignores the running user's FLS and object permissions; record sharing is governed by the class sharing keyword. Verified via search excerpt only; page body not fetchable)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm (sharing mode of the class where a method is DEFINED applies, not the caller's; inherited sharing takes the caller's. Page body not fetchable; the

'defined, not called' rule confirmed only via secondary sources, e.g. <https://salesforcegeek.in/with-sharing-and-without-sharing-in-apex/> — treat as partially verified)

22. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/DonorPortalService.cls:548
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ code.message });
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 4 (ONE OF 4, 20, 24)

```
classes/fplib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)
classes/fplib_IDGenerator.cls:39 String keyPrefix = objectType.getDescribe().getKeyPrefix();
classes/fplib_IDGenerator.cls:44 return Id.valueOf(keyPrefix + fakeIdPrefix + fakeIdCount);
classes/DonorPortalAdminController_Test.cls:317 Id accountId =
fplib_IDGenerator.generate(Account.SObjectType);
classes/DonorPortalAdminController_Test.cls:320 mocks.when(mockSvc.createAccessCodeForDonor(null,
accountId)).thenReturn(stub);
classes/DonorPortalService.cls:572 public AccessCode createAccessCodeForDonor(Id contactId, Id
accountId) {
classes/DonorPortalService.cls:576 AccessCode code = buildDonorAccessCode(contactId, accountId,
false);
classes/DonorPortalService.cls:596 private AccessCode buildDonorAccessCode(Id contactId, Id
accountId, Boolean forEmail) {
classes/DonorPortalService.cls:600 String email = resolveStaffDonorEmail(contactId, accountId);
classes/DonorPortalService.cls:634 private String resolveStaffDonorEmail(Id contactId, Id
accountId) {
classes/DonorPortalService.cls:650 rows =
AccountsSelector.newInstance().selectPersonDonorById(accountId);
classes/AccountsSelector.cls:199 public List<Account> selectPersonDonorById(Id accountId) {
classes/AccountsSelector.cls:203 sql, new Map<String, Object>{ 'accountId' => accountId },
AccessLevel.USER_MODE
classes/AccountsSelector.cls:202 return (List<Account>) Database.queryWithBinds(
classes/DonorPortalService.cls:650 rows =
AccountsSelector.newInstance().selectPersonDonorById(accountId);
classes/DonorPortalService.cls:654 if (rows.isEmpty()) { throw new
AppException(NO_PORTAL_FOR_ORG_ACCOUNT); }
classes/DonorPortalService.cls:655 return (String) rows[0].get('PersonEmail');
classes/DonorPortalService.cls:600 String email = resolveStaffDonorEmail(contactId, accountId);
classes/DonorPortalService.cls:618 code.message = buildCodeEmail(email, rawCode, ttlMinutes);
classes/DonorPortalService.cls:503 private Messaging.SingleEmailMessage buildCodeEmail(String
email, String rawCode, Integer ttlMinutes) {
classes/DonorPortalService.cls:510 msg.setToAddresses(new List<String>{ email });
classes/DonorPortalService.cls:511 msg.setSubject('Your sign-in code for ' + orgName);
classes/DonorPortalService.cls:512 msg.setHtmlBody(buildCodeEmailBody(formatCode(rawCode),
ttlMinutes, orgName, footer));
classes/DonorPortalService.cls:513 msg.setSaveAsActivity(false);
classes/DonorPortalService.cls:515 return msg;
classes/DonorPortalService.cls:618 code.message = buildCodeEmail(email, rawCode, ttlMinutes);
classes/DonorPortalService.cls:620 return code;
classes/DonorPortalService.cls:546 AccessCode code = buildDonorAccessCode(contactId, accountId,
true);
classes/DonorPortalService.cls:548 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{
code.message });
```

EVIDENCE CHECKED

- base/main/default/classes/donor/service/DonorPortalService.cls:30-47 - class header: the staff twins re-read the donor in the STAFF user's mode (resolveStaffDonorEmail) and refuse a donor that user cannot see
- base/main/default/classes/donor/controller/DonorPortalAdminController.cls:72 SendPortalLinkAction, :93 CreatePortalLinkAction, :156 ContactsSelector.selectById (USER_MODE), :175 AccountsSelector.selectPersonDonorById (USER_MODE)
- DonorPortalService_Test / DonorPortalAdminController_Test: a Fundraising_User who cannot see the Contact gets 'not found' and no Portal_Access_Token__c row is created
- The staff path re-reads the donor under the staff user's own sharing and field permissions (DonorPortalAdminController.cls:156 and :175, USER_MODE) before this service acts, so a staff user who cannot see the donor record cannot obtain a portal code for it (hardened 2026-09-25).

23. Vulnerability Name

Apex CRUD Violation — `classes/donor/service/DonorPortalService.cls:483` (R-005; Apex CRUD Violation paths 5, 21, 25)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

24. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

25. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{`

WHY THE CLAIM IS FALSE

The claim is false because `Messaging.sendEmail` with explicit addresses and `setSaveAsActivity(false)` writes no record, so there is no DML to guard; the address must already belong to an existing donor, the request is rate-limited, and the response is identical whether or not it matched.

SUPPORTING DETAIL

This sends a one-time sign-in code to a donor's own address after a guest asks for it; the address must match an existing donor, the request is rate-limited, and the response is the same whether or not it matched. The message uses explicit addresses with no target record and `setSaveAsActivity(false)`, so no record is created. The staff controller methods listed as sources reach a different send site (the staff twin) and share only the message-building helper; the fake-Id generator source is test-only. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donor/service/DonorPortalService.cls:483`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

26. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

`classes/DonorPortalService.cls:483`

```
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 5 (ONE OF 5, 21, 25)

```
classes/fflib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)
classes/fflib_IDGenerator.cls:39 String keyPrefix = objectType.getDescribe().getKeyPrefix();
classes/fflib_IDGenerator.cls:44 return Id.valueOf(keyPrefix + fakeIdPrefix + fakeIdCount);
classes/DonorPortalAdminController_Test.cls:317 Id accountId =
fflib_IDGenerator.generate(Account.SObjectType);
classes/DonorPortalAdminController_Test.cls:320 mocks.when(mockSvc.createAccessCodeForDonor(null,
accountId)).thenReturn(stub);
classes/DonorPortalService.cls:572 public AccessCode createAccessCodeForDonor(Id contactId, Id
accountId) {
classes/DonorPortalService.cls:576 AccessCode code = buildDonorAccessCode(contactId, accountId,
false);
classes/DonorPortalService.cls:596 private AccessCode buildDonorAccessCode(Id contactId, Id
accountId, Boolean forEmail) {
classes/DonorPortalService.cls:600 String email = resolveStaffDonorEmail(contactId, accountId);
classes/DonorPortalService.cls:634 private String resolveStaffDonorEmail(Id contactId, Id
accountId) {
classes/DonorPortalService.cls:650 rows =
AccountsSelector.newInstance().selectPersonDonorById(accountId);
classes/AccountsSelector.cls:199 public List<Account> selectPersonDonorById(Id accountId) {
classes/AccountsSelector.cls:203 soql, new Map<String, Object>{ 'accountId' => accountId },
AccessLevel.USER_MODE
classes/AccountsSelector.cls:202 return (List<Account>) Database.queryWithBinds(
classes/DonorPortalService.cls:650 rows =
AccountsSelector.newInstance().selectPersonDonorById(accountId);
classes/DonorPortalService.cls:654 if (rows.isEmpty()) { throw new
AppException(NO_PORTAL_FOR_ORG_ACCOUNT); }
classes/DonorPortalService.cls:655 return (String) rows[0].get('PersonEmail');
classes/DonorPortalService.cls:600 String email = resolveStaffDonorEmail(contactId, accountId);
classes/DonorPortalService.cls:618 code.message = buildCodeEmail(email, rawCode, ttlMinutes);
classes/DonorPortalService.cls:503 private Messaging.SingleEmailMessage buildCodeEmail(String
email, String rawCode, Integer ttlMinutes) {
classes/DonorPortalService.cls:510 msg.setToAddresses(new List<String>{ email });
classes/DonorPortalService.cls:511 msg.setSubject('Your sign-in code for ' + orgName);
classes/DonorPortalService.cls:512 msg.setHtmlBody(buildCodeEmailBody(formatCode(rawCode),
ttlMinutes, orgName, footer));
classes/DonorPortalService.cls:513 msg.setSaveAsActivity(false);
classes/DonorPortalService.cls:515 return msg;
classes/DonorPortalService.cls:484 buildCodeEmail(email, rawCode, ttlMinutes)
classes/DonorPortalService.cls:483 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{
```

EVIDENCE CHECKED

- base/main/default/classes/donor/service/DonorPortalService.cls:481-490 sendCodeEmail
- buildCodeEmail: setToAddresses, setSaveAsActivity(false)
- fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.

27. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:149` (R-006; Apex CRUD Violation paths 6, 11)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

28. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

29. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

WHY THE CLAIM IS FALSE

The claim is false because `Messaging.sendEmail` with `setSaveAsActivity(false)` performs no create, read, update or delete on any sObject, so no CRUD check applies; the recipient Contact Id is read from the finalized ticket order, not from a caller.

SUPPORTING DETAIL

The event-ticket receipt is sent to the purchaser's own Contact after the purchase is finalized; `setSaveAsActivity(false)` means the send creates no activity record, so there is no create/read/update/delete for a CRUD check to guard. The recipient Id comes from the purchase record, not from any request parameter. The only reported source is the SOQL builder class, which is a helper rather than an entry point. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:149`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

30. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:149
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 6 (ONE OF 6, 11)

```
classes/fflib_IDGenerator.cls:37  public static Id generate(Schema.SObjectType objectType)
classes/ReceiptService.cls:146  msg.setWhatId(opportunityId);           // {!Opportunity.*} merge
source
classes/ReceiptService.cls:147  msg.setSaveAsActivity(false);
classes/ReceiptService.cls:149  Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:143-149 — setTargetObjectId, setWhatId, setSaveAsActivity(false), sendEmail
- base/main/default/classes/event/service/EventPurchaseService.cls:533 caller (sendTicketReceiptQuietly, :1281)
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

31. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:329` (R-007; Apex CRUD Violation paths 7, 16, 26)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

32. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

33. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }`

WHY THE CLAIM IS FALSE

The claim is false because every reported dataflow source is test-support framework code reachable only from test classes, and the sink is an email send with `setSaveAsActivity(false)` that creates no record; in production the method runs from the platform-event subscriber after a gift is finalized, to that gift's own donor.

SUPPORTING DETAIL

Every source reported for this sink is test-support framework code (the mocking library's mock/verify methods and its fake-Id generator), which is only called from test classes. In production the method runs from a platform-event subscriber after a gift is finalized and emails matching-gift instructions to that gift's own donor Contact. `setSaveAsActivity(false)` is set, so no activity record is written and there is no DML to check. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:329`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

34. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:329
if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 7 (ONE OF 7, 16, 26)

```
classes/fflib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)
classes/ReceiptService.cls:323 msg.setTargetObjectId(targetContactId); // recipient +
{!Contact.*} merge source
classes/ReceiptService.cls:324 msg.setWhatId(oppId); // {!Opportunity.*} merge
source
classes/ReceiptService.cls:325 msg.setSaveAsActivity(false);
classes/ReceiptService.cls:327 msgs.add(msg);
classes/ReceiptService.cls:329 if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:313-327 — loop builds messages, setSaveAsActivity(false)
- base/main/default/classes/donation/service/CompanyMatchService.cls:65 sole production caller
- fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.

35. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:603` (R-008; Apex CRUD Violation paths 8, 13)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

36. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

37. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

WHY THE CLAIM IS FALSE

The claim is false because the send has no target record (`setTargetObjectId(null)`) and `setSaveAsActivity(false)`, so it writes nothing; it fires once during server-side finalization, to the honoree address the donor supplied with their own gift, and only when the donor opted in.

SUPPORTING DETAIL

The tribute notice is a one-time email to the honoree address the donor entered with their gift, sent during server-side finalization on first creation and only when the donor opted in. It has no target record (`setTargetObjectId(null)`) and `setSaveAsActivity(false)`, so it writes nothing. The reported sources are a test-only fake-Id generator and the SOQL builder. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:603`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

38. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

`classes/ReceiptService.cls:603`
`Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 8 (ONE OF 8, 13)

```

classes/fflib_IDGenerator.cls:37 public static Id generate(Schema.SObjectType objectType)
classes/fflib_IDGenerator.cls:39 String keyPrefix = objectType.getDescribe().getKeyPrefix();
classes/fflib_IDGenerator.cls:44 return Id.valueOf(keyPrefix + fakeIdPrefix + fakeIdCount);
classes/ReceiptService_Test.cls:695
.buildTributeNotification(fflib_IDGenerator.generate(Opportunity.SObjectType));
classes/ReceiptService.cls:626 private Messaging.SingleEmailMessage buildTributeNotification(Id
opportunityId) {
classes/ReceiptService.cls:695 Messaging.renderStoredEmailTemplate(templateId, donorContactId,
opportunityId);
classes/ReceiptService.cls:694 Messaging.SingleEmailMessage msg =
classes/ReceiptService.cls:702 msg.setTargetObjectId(null);
classes/ReceiptService.cls:703 msg.setToAddresses(new List<String>{
o.Tribute_Notification_Email__c });
classes/ReceiptService.cls:704 msg.setSaveAsActivity(false);
classes/ReceiptService.cls:706 return msg;
classes/ReceiptService.cls:601 Messaging.SingleEmailMessage msg =
buildTributeNotification(opportunityId);
classes/ReceiptService.cls:603 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });

```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:702-704 setTargetObjectId(null), setToAddresses(honoree), setSaveAsActivity(false)
- base/main/default/classes/donation/service/DonationService.cls:404 caller
- fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

39. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:734` (R-009; Apex CRUD Violation paths 12)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

40. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

41. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

WHY THE CLAIM IS FALSE

The claim is false because the send writes no record (`setSaveAsActivity(false)`), is reached only from the finalize path and a scheduled renewal job, and addresses the recurring schedule's own donor Contact; no user- or guest-callable entry point selects the recipient.

SUPPORTING DETAIL

Recurring-gift notices (confirmation, failed payment, dunning, re-authorization) are sent by the finalize path and a scheduled renewal job to the schedule's own donor Contact, with `setSaveAsActivity(false)`, so the send writes no record. No user- or guest-callable entry point reaches this method. The reported sources are the SOQL builder's parameter methods. The send was reviewed for a code change on 2026-10-01 and none applies:

`Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:734`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

42. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:734
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 12

```
classes/fflib_QueryFactory.cls:360 public fflib_QueryFactory setCondition(String
conditionExpression){
classes/ReceiptService.cls:731 msg.setWhatId(recurringDonationId);          //
{!Recurring_Donation__c.*} merge source
classes/ReceiptService.cls:732 msg.setSaveAsActivity(false);
classes/ReceiptService.cls:734 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:709-734
- base/main/default/classes/recurring/async/RecurringRenewalBatch.cls:197-202;
base/main/default/classes/recurring/service/RecurringDonationService.cls:956
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

43. Vulnerability Name

Apex CRUD Violation / Apex SOQL SOSL USER MODE MISSING —
classes/setup/service/CommunityService.cls:513 (R-010; Apex CRUD Violation paths 15; Apex SOQL SOSL USER MODE MISSING paths 9)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

44. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

45. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. `USER_MODE` is recommended for SOQL or SOSL operations Flagged statement: Integer assignedCount = [

WHY THE CLAIM IS FALSE

The claim is false because the statement is a read-only `COUNT()` of `PermissionSetAssignment`, a setup object with no sharing model, returning a yes/no verdict and no record data; it is reachable only from the administrator-only setup console, and a user-mode read of setup objects requires View Setup and Configuration, which the package's admin permission set cannot assume every administrator holds.

SUPPORTING DETAIL

This is a read-only count of the site guest user's permission-set assignments, run from the administrator-only setup console to report whether the payment credential is granted to that guest user; it returns a yes/no verdict and no record data. It runs in system mode because `PermissionSetAssignment` is setup data that the running administrator can read only with 'View Setup and Configuration', which the package's admin permission set does not grant, and without it the console would falsely report the grant as missing. Only users holding the administrator permission set can reach it. The site carries its own `SYSTEM_MODE` comment saying so, as does every other setup-object read in the class.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/service/CommunityService.cls:513

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (system mode ignores the running user's FLS and object permissions; record sharing is governed by the class sharing keyword. Verified via search excerpt only; page body not fetchable)

46. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CommunityService.cls:513
Integer assignedCount = [
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 15

```
classes/SetupController.cls:642 public static Map<String, Object> checkGuestPermissionSet(String
networkId) {
classes/SetupController.cls:643 return new CheckGuestPermissionSet(networkId).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2811 Map<String, Object> result =
communityServiceInstance.checkGuestPermissionSet(networkId);
classes/SetupController.cls:2812 result.put('stripeCredential',
communityServiceInstance.checkStripeCredentialAccess(networkId));
classes/CommunityService.cls:473 Set<Id> principalIds = queryStripePrincipalIds();
classes/CommunityService_Test.cls:657 return principalIds;
classes/CommunityService.cls:473 Set<Id> principalIds = queryStripePrincipalIds();
classes/CommunityService.cls:474 Boolean precise = !principalIds.isEmpty();
classes/CommunityService.cls:488 ? queryGrantingPermSetIds(principalIds)
classes/CommunityService.cls:603 protected virtual Set<Id> queryGrantingPermSetIds(Set<Id>
principalIds) {
classes/CommunityService.cls:610 WHERE SetupEntityId IN :principalIds AND SetupEntityType =
'ExternalCredentialParameter'
classes/CommunityService.cls:608 for (SetupEntityAccess a : [
classes/CommunityService.cls:612 ]) { grantingPermSetIds.add(a.ParentId); }
classes/CommunityService.cls:613 return grantingPermSetIds;
classes/CommunityService.cls:488 ? queryGrantingPermSetIds(principalIds)
classes/CommunityService.cls:487 Set<Id> grantingPermSetIds = precise
classes/CommunityService.cls:496 if (grantingPermSetIds.isEmpty()) {
classes/CommunityService.cls:515 WHERE AssigneeId = :guestUserId AND PermissionSetId IN
:grantingPermSetIds
classes/CommunityService.cls:513 Integer assignedCount = [
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 9

```
classes/SetupController.cls:642 public static Map<String, Object> checkGuestPermissionSet(String
networkId) {
classes/SetupController.cls:643 return new CheckGuestPermissionSet(networkId).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2811 Map<String, Object> result =
communityServiceInstance.checkGuestPermissionSet(networkId);
classes/SetupController.cls:2812 result.put('stripeCredential',
communityServiceInstance.checkStripeCredentialAccess(networkId));
classes/CommunityService.cls:456 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService_Test.cls:509 return guestUserId;
classes/CommunityService.cls:456 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService.cls:515 WHERE AssigneeId = :guestUserId AND PermissionSetId IN
:grantingPermSetIds
classes/CommunityService.cls:513 Integer assignedCount = [
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:511-516 - // SYSTEM_MODE: the guest user's assignments ... a count only, for the Fundraising_Admin-only Settings console. above the query
- Every SYSTEM_MODE query and DML statement in the package carries a // SYSTEM_MODE: reason comment directly at the call site (grep -rn 'SYSTEM_MODE' base/main/default/classes shows the comment above each use); for this statement it is at :511-512.
- SetupController granted only in Fundraising_Admin; Fundraising_Admin carries no ViewSetup userPermission

47. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:408` (R-011; Apex CRUD Violation paths 17, 23, 27)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

48. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

49. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }`

WHY THE CLAIM IS FALSE

The claim is false because the send writes no record (`setSaveAsActivity(false)`), it runs only after a refund has already been processed under the `Process_Refunds` custom permission or by the reconciliation job, and the recipient is the refunded gift's own donor Contact.

SUPPORTING DETAIL

The refund notice is sent only after a refund has been processed, to the refunded gift's own donor Contact, with `setSaveAsActivity(false)`, so the send itself writes no record. The interactive path requires a dedicated custom permission checked in the controller before any work, and the controller declares with sharing, which the service inherits. Two of the reported sources are test-only mocking framework methods; the third is that permission-gated controller. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:408`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (system mode ignores the running user's FLS and object permissions; record sharing is governed by the class sharing keyword. Verified via search excerpt only; page body not fetchable)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm (sharing mode of the class where a method is DEFINED applies, not the caller's; inherited sharing takes the caller's. Page body not fetchable; the 'defined, not called' rule confirmed only via secondary sources, e.g. <https://salesforcegeek.in/with-sharing-and-without-sharing-in-apex/> — treat as partially verified)

50. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:408
if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 17 (ONE OF 17, 23, 27)

```
classes/fflib_ApexMocks.cls:69 public Object mock(Type classToMock)
classes/fflib_ApexMocks.cls:71 return Test.createStub(classToMock, this);
classes/RefundReconciliationBatch_Test.cls:774 IReceiptService mockReceipt = (IReceiptService)
mocks.mock(IReceiptService.class);
classes/RefundReconciliationBatch_Test.cls:784 ((IReceiptService) mocks.verify(mockReceipt,
1)).sendRefundNotifications(new Set<Id>{ opp.Id });
classes/fflib_ApexMocks.cls:115 public Object verify(Object mockInstance, fflib_VerificationMode
verificationMode)
classes/fflib_ApexMocks.cls:120 return mockInstance;
classes/RefundReconciliationBatch_Test.cls:784 ((IReceiptService) mocks.verify(mockReceipt,
1)).sendRefundNotifications(new Set<Id>{ opp.Id });
classes/ReceiptService.cls:383 Id templateId = emailTemplateId('RefundNotification');
classes/ReceiptService.cls:419 if (templateIdOverrideByName != null &&
templateIdOverrideByName.containsKey(developerName)) {
classes/ReceiptService.cls:420 return templateIdOverrideByName.get(developerName);
classes/ReceiptService.cls:383 Id templateId = emailTemplateId('RefundNotification');
classes/ReceiptService.cls:401 msg.setTemplateId(templateId);
classes/ReceiptService.cls:402 msg.setTargetObjectId(targetContactId); // recipient +
{!Contact.*} merge source
classes/ReceiptService.cls:403 msg.setWhatId(opp.Id); // {!Opportunity.*} merge
source
classes/ReceiptService.cls:404 msg.setSaveAsActivity(false);
classes/ReceiptService.cls:406 msgs.add(msg);
classes/ReceiptService.cls:408 if (!msgs.isEmpty()) { Messaging.sendEmail(msgs); }
```

EVIDENCE CHECKED

- base/main/default/classes/donation/controller/RefundController.cls:22 refundDonation; doValidate checks FeatureManagement.checkPermission('Process_Refunds')
- base/main/default/classes/donation/service/RefundService.cls:15 public inherited sharing class RefundService; :328-334 sendRefundNotification after commit
- base/main/default/classes/donation/service/ReceiptService.cls:404-408 setSaveAsActivity(false)
- base/main/default/classes/donation/selector/OpportunitiesSelector.cls:865 selectByIdForRefund SYSTEM_MODE FOR UPDATE
- fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.
- base/main/default/classes/donation/async/RefundReconciliationBatch.cls:734 batch caller (sendRefundNotifications, ReceiptService:380)

51. Vulnerability Name

Apex CRUD Violation — `classes/guestrequest/handler/RefundRequestHandler.cls:138` (R-012; Apex CRUD Violation paths 19)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

52. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

53. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

WHY THE CLAIM IS FALSE

The claim is false because the send performs no DML (`setSaveAsActivity(false)`, explicit addresses); the gift Id it refers to was validated against the authenticated donor's own giving history when the request was recorded, and the message goes only to that gift's owner and the configured reply-to address.

SUPPORTING DETAIL

This notifies staff that a donor asked for a refund through the donor portal; the gift Id was checked against the authenticated donor's own giving history when the request was recorded, and the message goes to that gift's owner and the configured reply-to address, never to a caller-supplied address. It is plain text with explicit addresses and `setSaveAsActivity(false)`, so it writes no record. The reported sources are the SOQL builder's parameter methods, not entry points. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/guestrequest/handler/RefundRequestHandler.cls:138`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)

54. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

`classes/RefundRequestHandler.cls:138`

```
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 19

```
classes/fflib_QueryFactory.cls:218 public fflib_QueryFactory selectField(String fieldName){
classes/RefundRequestHandler.cls:195 msg.setToAddresses(new List<String>(recipients));
classes/RefundRequestHandler.cls:196 msg.setSubject((String.isNotBlank(orgName) ? orgName + ' - '
: '' ) +
classes/RefundRequestHandler.cls:198 msg.setPlainTextBody(body);
classes/RefundRequestHandler.cls:199 msg.setSaveAsActivity(false);
classes/RefundRequestHandler.cls:201 return msg;
classes/RefundRequestHandler.cls:136 Messaging.SingleEmailMessage msg = buildStaffAlert(request,
gift, reason);
classes/RefundRequestHandler.cls:138 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{
msg });
```

EVIDENCE CHECKED

- base/main/default/classes/guestrequest/handler/RefundRequestHandler.cls:194-199 setToAddresses + setSaveAsActivity(false)
- DonorPortalService.submitRefundRequest -> requireOwnedDonation
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

55. Vulnerability Name

Apex CRUD Violation — `classes/donation/service/ReceiptService.cls:173` (R-013; Apex CRUD Violation paths 28)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

56. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

57. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD operations that are performed without checking for `isAccessible()`, `isUpdateable()` or `isDeletable()`. When an object uses `Whold`, `WhatId`, `ParentId`, `LinkedEntityId` fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields. Flagged statement: `Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });`

WHY THE CLAIM IS FALSE

The claim is false because the send writes no record (`setSaveAsActivity(false)`), and the only records involved, the gift and its donor Contact, are read in user mode before the message is built, so a staff user who cannot see them gets nothing to send.

SUPPORTING DETAIL

Resending a receipt is a staff action whose record access is enforced before the message is built: the gift and the donor Contact are read in user mode (object, field and sharing checks of the running user), so a user who cannot see either gets nothing to send. The recipient is always the gift's own donor Contact, not a caller-supplied address, and `setSaveAsActivity(false)` means the send writes no record. The other two sources reported are the SOQL builder's parameters, not entry points. The send was reviewed for a code change on 2026-10-01 and none applies: `Messaging.sendEmail` takes no access-level argument, and with `setSaveAsActivity(false)` there is no record operation for a CRUD check to guard.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/ReceiptService.cls:173`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexref.meta/apexref/apex_classes_email_outbound_base.htm (Email base class: `setSaveAsActivity` is true by default; saving as activity applies to the `targetObjectId` record. Verified via search excerpt; the page body returned 403 to direct fetch and via `r.jina.ai` only a cookie shell, so the exact wording is not quoted. Whether `saveAsActivity=false` also suppresses an Enhanced Email `EmailMessage` row: unverified)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (system mode ignores the running user's FLS and object permissions; record sharing is governed by the class sharing keyword. Verified via search excerpt only; page body not fetchable)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm (sharing mode of the class where a method is DEFINED applies, not the caller's; inherited sharing takes the caller's. Page body not fetchable; the

'defined, not called' rule confirmed only via secondary sources, e.g. <https://salesforcegeek.in/with-sharing-and-without-sharing-in-apex/> — treat as partially verified)

58. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptService.cls:173  
Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

REPORTED DATAFLOW — APEX CRUD VIOLATION, PATH 28

```
classes/ReceiptAdminController.cls:38 public static Map<String, Object> resendReceipt(Id  
opportunityId) {  
classes/ReceiptAdminController.cls:39 return new ResendReceiptAction(opportunityId).run();  
classes/ReceiptAdminController.cls:67 ResendReceiptAction(Id opportunityId) { this.opportunityId =  
opportunityId; }  
classes/ReceiptAdminController.cls:39 return new ResendReceiptAction(opportunityId).run();  
classes/ControllerAction.cls:52 Object result = doExecute();  
classes/ReceiptAdminController.cls:75 .resendReceipt(opportunityId);  
classes/ReceiptService.cls:170 public void resendReceipt(Id opportunityId) {  
classes/ReceiptService.cls:171 Messaging.SingleEmailMessage msg =  
buildResendReceipt(opportunityId);  
classes/ReceiptService.cls:191 private Messaging.SingleEmailMessage buildResendReceipt(Id  
opportunityId) {  
classes/ReceiptService.cls:196 List<Opportunity> opps = oppSel.selectById(new Set<Id>{  
opportunityId });  
classes/ReceiptService.cls:226 msg.setWhatId(opportunityId); // {!Opportunity.*} merge  
source  
classes/ReceiptService.cls:227 msg.setSaveAsActivity(false);  
classes/ReceiptService.cls:229 return msg;  
classes/ReceiptService.cls:171 Messaging.SingleEmailMessage msg =  
buildResendReceipt(opportunityId);  
classes/ReceiptService.cls:173 Messaging.sendEmail(new List<Messaging.SingleEmailMessage>{ msg });
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/ReceiptService.cls:196 oppSel.selectById (USER_MODE), :211 conSel.selectById (USER_MODE)
- base/main/default/classes/donation/service/ReceiptService.cls:223-227 setTargetObjectId + setSaveAsActivity(false)
- base/main/default/classes/donation/controller/ReceiptAdminController.cls:38 resendReceipt, class declared with sharing
- Fundraising_User / Fundraising_Admin permission sets grant ReceiptAdminController
- fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

59. Vulnerability Name

Apex CRUD ContentDistribution — `classes/campaign/service/CampaignPostService.cls:555` (R-014; Apex CRUD ContentDistribution paths 1–2)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

60. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

61. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for DML operations involving "ContentDistribution" object Flagged statement: `delete as system revokeDistributions;`

WHY THE CLAIM IS FALSE

The claim that this delete should run in user mode is false because the user was already authorized for the action that triggers it (deleting or replacing a campaign post passes the controller's deletable/editable check on the post in user mode), and ContentDistribution is a standard object a 2GP permission set cannot grant: a user-mode delete of a public link created by a different staff member fails with `INSUFFICIENT_ACCESS_OR_READONLY` (measured), which would leave a revoked file publicly downloadable.

SUPPORTING DETAIL

This delete revokes the public ContentDistribution link a campaign post served, after staff have deleted the post or replaced its file. It runs only after an action the user was already authorised for: deleting a post first passes `requireDeletable` on `Campaign_Post__c` and commits the delete through a user-mode Unit of Work, so the platform refuses it without delete access; replacing a file first filters the posts through `RecordAccess.editableIds`. The revocation set is narrow: `planRevocations` keeps any link that another post still serves, so only the link the released post exposed is removed. ContentDistribution is a standard object a second-generation package permission set cannot grant, so a user-mode delete would depend on a manual admin step. The path is never reachable by a guest, and revoking a public link reduces exposure; it never widens it. Converting this delete to user mode was tested and rejected because it breaks the feature for the users it is built for. Measured 2026-10-01 in a scratch org, running as a Standard User who holds the `Fundraising_Admin` permission set: deleting a ContentDistribution created by another staff member with `Database.delete(rows, AccessLevel.USER_MODE)` fails with `INSUFFICIENT_ACCESS_OR_READONLY`. In user mode the public link of a post one colleague published could not be revoked when another colleague deletes that post, and the file would stay publicly reachable. System mode is what guarantees the link is withdrawn.

LOCATION IN THE SUBMITTED SOURCE

`classes/campaign/service/CampaignPostService.cls:555`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (user-mode DML enforces the running user's object permissions and sharing)

- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

62. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CampaignPostService.cls:555  
delete as system revokeDistributions;
```

REPORTED DATAFLOW — APEX CRUD CONTENTDISTRIBUTION, PATH 1 (ONE OF 1-2)

```
classes/CampaignPostService.cls:456 private List<ContentDistribution> revokeDistributions = new  
List<ContentDistribution>();  
classes/CampaignPostService.cls:553 if (!revokeDistributions.isEmpty()) {  
classes/CampaignPostService.cls:555 delete as system revokeDistributions;
```

EVIDENCE CHECKED

- base/main/default/classes/campaign/controller/CampaignPostController.cls:156 - `requireDeletable(Campaign_Post__c.SObjectType, 'campaign posts')` before :166 `deletePost(postId)`
- base/main/default/classes/campaign/service/CampaignPostService.cls:163-187 - `deletePost`: the `UserModeDML` delete commits at :179-183 before `retirement.execute(false)` at :186
- base/main/default/classes/campaign/service/CampaignPostService.cls:379-381 - `stampablePosts` filters through `RecordAccess.editableIds` before a file replace; :438 runs the retirement
- base/main/default/classes/campaign/service/CampaignPostService.cls:515-545 - `planRevocations` keeps any link another post still serves (`selectByFileUrlsSystemMode`, :530)
- base/main/default/classes/campaign/service/CampaignPostService.cls:547-555 - `execute()` rationale and the `SYSTEM_MODE` comment at the site
- base/main/default/classes/campaign/service/CampaignPostService.cls:453 - `private with sharing class FileRetirement`; outer class with `sharing` at :28

63. Vulnerability Name

Apex CRUD ContentDistribution / FLS Create — `classes/shared/AppLogger.cls:125` (R-015; Apex CRUD ContentDistribution paths 3–4, 6; FLS Create paths 2–7)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

64. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

65. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for DML operations involving "ContentDistribution" object This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. Flagged statement: `insert as system new Log__c(`

WHY THE CLAIM IS FALSE

The claim is false because the insert is the package's diagnostic log, which must succeed from catch blocks in every context including guest controllers; no permission set grants Create on Log__c by design, so a user-mode insert fails for every user (measured: `insert as user new Log__c` throws `System.TypeException "DML operation INSERT not allowed on Log__c"`), and the row holds only a class name, level and message with no caller-controlled routing.

SUPPORTING DETAIL

AppLogger persists diagnostic entries from catch blocks in every context, including guest controllers whose users cannot hold Create on any internal object; no permission set grants Create on Log__c by design, so logs are writable only through this class. Values are truncated to field length, Log__c is Private with read granted only to internal staff sets, and no client-callable method takes a log payload - the message text comes from server-side exceptions and developer-written strings. The class-level comment documents why it is `without sharing` and bypasses the Unit of Work. Converting this insert to user mode was tested and rejected. Measured 2026-10-01 in a scratch org, running as a Standard User who holds the Fundraising_Admin permission set: `insert as user new Log__c(...)` throws `System.TypeException: DML operation INSERT not allowed on Log__c`, because no permission set grants Create on the log object - by design, so that no user can author or forge diagnostic rows. A user-mode insert would therefore lose every log entry, including the ones that record security-relevant failures.

LOCATION IN THE SUBMITTED SOURCE

`classes/shared/AppLogger.cls:125`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (user-mode DML throws when the running user lacks object Create)
- Measured in a scratch org (2026-09-30): `insert as user new Log__c(...)` throws `System.TypeException "DML operation INSERT not allowed on Log__c"`

66. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/AppLogger.cls:125  
insert as system new Log__c(
```

REPORTED DATAFLOW — APEX CRUD CONTENTDISTRIBUTION, PATH 3 (ONE OF 3–4, 6)

```
classes/CampaignPostService.cls:654 List<ContentDistribution> toCreate = new  
List<ContentDistribution>();  
classes/CampaignPostService.cls:665 if (toCreate.isEmpty()) { return urlByDocumentId; }  
classes/CampaignPostService.cls:683 failures.add(toCreate[i].ContentVersionId + ': ' +  
results[i].getErrors()[0].getMessage());  
classes/CampaignPostService.cls:689 if (!failures.isEmpty()) {  
classes/CampaignPostService.cls:692 + String.join(failures, '; '); }  
classes/AppLogger.cls:83 public static void warn (String context, String message) { write('WARN',  
context, message, null, null); }  
classes/AppLogger.cls:111 private static void write(String level, String context, String message,  
String stackTrace, Id recordId) {  
classes/AppLogger.cls:128 Message__c = leftOrNull(message, 32768),  
classes/AppLogger.cls:153 private static String leftOrNull(String value, Integer maxLength) {  
classes/AppLogger.cls:154 return value != null ? value.left(maxLength) : null;  
classes/AppLogger.cls:128 Message__c = leftOrNull(message, 32768),  
classes/AppLogger.cls:125 insert as system new Log__c(
```

REPORTED DATAFLOW — FLS CREATE, PATH 2 (ONE OF 2–7)

```
classes/AppLogger.cls:126 Level__c = level,  
classes/AppLogger.cls:125 insert as system new Log__c(
```

EVIDENCE CHECKED

- base/main/default/classes/shared/AppLogger.cls:1-9 - without sharing with rationale
- base/main/default/classes/shared/AppLogger.cls:117-135 - DML-limit guard; left() truncation; failures swallowed
- Log__c OWD Private; Fundraising_Admin/User/ReadOnly: Read only, no Create; GuestDonor: no grant

67. Vulnerability Name

Apex CRUD ContentDistribution / FLS Create / FLS Update / Apex SOQL SOSL USER MODE MISSING — `classes/setup/service/SettingsService.cls:345` (R-016; Apex CRUD ContentDistribution paths 5, 7; FLS Create paths 15, 28, 50–54, 56–61, 63–65, 67–68, 74–75, 77–78, 81, 88, 90, 92, 94, 96, 98, 100; FLS Update paths 2, 12–21, 26–27, 30–31, 35, 37–38, 41–42, 44, 46, 48, 50, 52, 54, 56, 58, 60; Apex SOQL SOSL USER MODE MISSING paths 7, 15–16, 27)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

68. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

69. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for DML operations involving "ContentDistribution" object This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for isUpdateable() permisison before performing the Update operation on the Object and its fields. USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `upsert as system settings;`

WHY THE CLAIM IS FALSE

The claim is false on both counts: the upsert is shared by the InstallHandler (package system user, no permission set) and the admin console (gated by the Manage_Fundraising_Settings custom permission), and in both contexts a user-mode write on the package's hierarchy custom setting requires Customize Application, which neither the install user nor the package's admin permission set can hold (measured: `upsert as user` throws `SecurityException`). The ContentDistribution query reads only a Content Delivery the same code created from a packaged static resource.

SUPPORTING DETAIL

This upsert is shared by the package install handler, which runs as the package's system user with no permission set, and by the settings console controller, which is granted only in the Fundraising_Admin permission set. System mode is kept because the install path has no FLS to enforce and because DML on a Hierarchy Custom Setting in user mode requires Customize Application, a system permission no packaged permission set can carry. The console path does not rely on Apex class access alone: every controller action that reaches this write (`SaveGeneralSettings`, `DetectOrgFeatures`, `ResetToDefaults`, `SaveExperienceSite`) first checks the packaged custom permission `Manage_Fundraising_Settings`, granted only in `Fundraising_Admin`, and refuses the save with a generic error when the running user does not hold it. The site carries a `SYSTEM_MODE` comment naming that gate. The user-mode alternative was tested and does not work for the people who use this screen. Measured 2026-10-01 in a scratch org, running as a Standard User who holds the `Fundraising_Admin` permission set: `Schema.sObjectType.Settings__c` reports `isCreatable`, `isUpdateable` and `isAccessible` all false, and `upsert as user` on the settings row throws `System.SecurityException: Access to entity 'Settings__c' denied`. The platform ties custom-setting DML to `Customize Application`, which is a system permission the fundraising administrator is not expected to hold, so a user-

mode write would lock every non-system-administrator out of the settings console. The custom-permission check before the write is the access control; it is enforced in Apex on every action that reaches this line.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/service/SettingsService.cls:345

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.cs_schema_settings.htm
- <https://applicationperfection.com/2024/02/29/control-who-gets-read-access-to-custom-settings/>
- <https://github.com/patronmanager/apex-dml-manager/issues/2>
- https://help.salesforce.com/s/articleView?language=en_US&id=release-notes.rn_apex_default_user_mode.htm&release=262&type=5
- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

70. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/SettingsService.cls:345
upsert as system settings;
```

REPORTED DATAFLOW — APEX CRUD CONTENTDISTRIBUTION, PATH 5 (ONE OF 5, 7)

```
classes/SettingsService.cls:571 ContentDistribution cd = new ContentDistribution(
classes/SettingsService.cls:581 Database.insert(cd, AccessLevel.SYSTEM_MODE);
classes/SettingsService.cls:584 ContentDistribution resolved = (ContentDistribution)
Database.query(
classes/SettingsService.cls:591 result.publicUrl = resolved.ContentDownloadUrl;
classes/SettingsService.cls:592 return result;
classes/SettingsService.cls:431 seeder.distribute(packaged, DEFAULT_SOCIAL_RESOURCE_NAME +
'.webp').publicUrl;
classes/SettingsService.cls:430 s.Default_Social_Share_Image_URL__c =
classes/SettingsService.cls:436 if (changed) { saveSettings(s); }
classes/SettingsService.cls:320 public void saveSettings(Settings__c settings) {
classes/SettingsService.cls:327 settings.Donor_Portal_Path__c = DEFAULT_PORTAL_PATH;
classes/SettingsService.cls:345 upsert as system settings;
```

REPORTED DATAFLOW — FLS CREATE, PATH 15 (ONE OF 15, 28, 50–54, 56–61, 63–65, 67–68, 74–75, 77–78, 81, 88, 90, 92, 94, 96, 98, 100)

```
classes/SettingsService.cls:327 settings.Donor_Portal_Path__c = DEFAULT_PORTAL_PATH;
classes/SettingsService.cls:345 upsert as system settings;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 2 (ONE OF 2, 12–21, 26–27, 30–31, 35, 37–38, 41–42, 44, 46, 48, 50, 52, 54, 56, 58, 60)

```
classes/SettingsService.cls:327 settings.Donor_Portal_Path__c = DEFAULT_PORTAL_PATH;
classes/SettingsService.cls:345 upsert as system settings;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 7 (ONE OF 7, 15–16, 27)

```
classes/SetupController.cls:632 public static Map<String, Object> saveExperienceSite(String
networkId, String siteUrl) {
classes/SetupController.cls:633 return new SaveExperienceSite(networkId, siteUrl).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2778 s.Experience_Network_Id__c = networkId;
classes/SetupController.cls:2782 settingsSvc.saveSettings(s);
classes/SettingsService.cls:320 public void saveSettings(Settings__c settings) {
classes/SettingsService.cls:327 settings.Donor_Portal_Path__c = DEFAULT_PORTAL_PATH;
classes/SettingsService.cls:345 upsert as system settings;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/SettingsService.cls:338-345 - `// SYSTEM_MODE:` reason naming the Manage_Fundraising_Settings gate, then `upsert as system settings`
- base/main/default/classes/setup/controller/SetupController.cls:1737-1742 - `SettingsWriteAction.requireSettingsPermission(): FeatureManagement.checkPermission('Manage_Fundraising_Settings') else addError(SETTINGS_NOT_AUTHORIZED)`
- base/main/default/classes/setup/controller/SetupController.cls:1745/1754 `SaveGeneralSettings, :2666-2667 DetectOrgFeatures, :2702-2703 ResetToDefaults, :2762/2771 SaveExperienceSite` - each `doValidate()` starts with `requireSettingsPermission()`

- base/main/default/customPermissions/Manage_Fundraising_Settings.customPermission-meta.xml; Fundraising_Admin.permissionset-meta.xml grants it; Fundraising_User / Fundraising_ReadOnly / Fundraising_GuestDonor do not
- SetupController_Test: five deny tests (bare Standard User), one deny test (Fundraising_User), one allow test (Fundraising_Admin); 312 tests pass, SetupController 96%, SettingsService 98%
- PostInstallHandler.onInstall -> seedRecordTypeMappings / ensureDefaultLogoSeeded still reach this write with no permission check: install context, no running user to check
- Every settings write in the package is reached only through a SetupController action whose doValidate() calls requireSettingsPermission(), i.e. FeatureManagement.checkPermission('Manage_Fundraising_Settings'); only the Fundraising_Admin permission set grants that custom permission. The install-time seeds are the one other caller and run with no interactive user (hardened 2026-09-25).

71. Vulnerability Name

Client DOM Stored XSS — `lwc/pfGivingStatement/pfGivingStatement.html:34` (R-017; Client DOM Stored XSS paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

72. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

73. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query detects external data flowing into a javascript execution context when that data comes from the database or other stored parameters influenced by external users. This may be a false positive if the datatype is safe to render unescaped (such as an integer or rich text field). Flagged statement: `<p class="gs-err" role="alert">{errorMessage}</p>`

WHY THE CLAIM IS FALSE

The claim that stored, externally influenced data reaches a JavaScript execution context is false because the reported source (the donor's portal session token) is only passed as an Apex parameter and never written to the DOM; the value rendered at the flagged line is the response envelope's error text or a packaged constant, bound through an LWC `{expression}`, which the framework renders as escaped text and never as HTML or script.

SUPPORTING DETAIL

The flagged source is the donor's own portal session token read from sessionStorage; it is passed as an Apex parameter to DonorPortalController.getGivingStatement and is never written into the DOM. The value rendered at `base/main/default/lwc/pfGivingStatement/pfGivingStatement.html:34` is either the `error` string of the controller's response envelope or a package-authored literal. The controller's action classes extend GuestAction, whose `callerSafeMessage` returns an `AppException` message (every one on this path is a constant: the invalid-session message, 'Choose a tax year.', 'That tax year is not available.', 'A donor is required to build a giving statement.') or one fixed generic sentence for any other exception - no record field, request parameter or token is echoed. Finally, the sink is an LWC `{expression}` text binding, which the framework renders as a text node, not HTML; neither `pfGivingStatement` nor `publicDonorDashboard` uses `innerHTML`, `lwc:inner-html` or `lwc:dom="manual"`. The flagged source is also shape-checked: the value read from sessionStorage is accepted only when it matches the exact shape of a session token the server issues (64 lowercase hexadecimal characters); anything else is discarded and removed from storage before it reaches component state or an Apex call. The finding is a false positive - the value is never rendered - and storage content that the component did not write cannot enter it at all.

LOCATION IN THE SUBMITTED SOURCE

`lwc/pfGivingStatement/pfGivingStatement.html:34`

SOURCES

- https://lwc.dev/guide/html_templates
- <https://trailhead.salesforce.com/content/learn/modules/secure-clientside-development/mitigate-crosssite-scripting>

- <https://developer.salesforce.com/docs/platform/lwc/guide/security-lwsec-sanitize.html>

74. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
lwc/pfGivingStatement/pfGivingStatement.html:34
<p class="gs-err" role="alert">{errorMessage}</p>
```

REPORTED DATAFLOW — CLIENT DOM STORED XSS, PATH 1

```
lwc/publicDonorDashboard/publicDonorDashboard.js:316  stored =
window.sessionStorage.getItem(SESSION_KEY);
lwc/publicDonorDashboard/publicDonorDashboard.js:321  this.token = stored;
lwc/publicDonorDashboard/publicDonorDashboard.js:614  const res = await getGivingStatement({ token:
this.token, taxYear });
classes/DonorPortalController.cls:126  public static Map<String, Object> getGivingStatement(String
token, Integer taxYear) {
classes/DonorPortalController.cls:127  return new GetGivingStatement(token, taxYear).run();
lwc/pfGivingStatement/pfGivingStatement.js:115  const res = await getGivingStatement({ token:
this.token, taxYear });
lwc/pfGivingStatement/pfGivingStatement.js:120  this.errorMessage = res?.error || 'We could not
build your statement.';
lwc/pfGivingStatement/pfGivingStatement.html:34  <p class="gs-err" role="alert">{errorMessage}</p>
```

EVIDENCE CHECKED

- base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.js:314-331 - stored = window.sessionStorage.getItem(SESSION_KEY) (SESSION_KEY = 'pf-donor-portal-session', :41); assigned to this.token then loadDashboard(); not bound into markup
- base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.js:45 and :320-330 - SESSION_TOKEN_SHAPE = /^[0-9a-f]{64}\$/; a stored value that fails the test is removed and the sign-in form is shown
- base/main/default/classes/donor/service/DonorPortalService.cls:809-811 - generateToken() returns EncodingUtil.convertToHex(Crypto.generateAesKey(256)), i.e. 64 lowercase hex characters
- base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.html:389 - token={token} passed as a component property only; the only other {token} use is if:false={token} (line 47), a boolean
- base/main/default/lwc/pfGivingStatement/pfGivingStatement.js:96-104 and :115-121 - errorMessage = res?.error || literal, or the printStatement() return value
- base/main/default/lwc/uiStatementPrint/uiStatementPrint.js:249 - printStatement returns only the literal 'Pop-up blocked. Allow pop-ups ...' or null; the statement document itself is built with createElement/textContent (el() helper :31-35), never innerHTML
- base/main/default/classes/donor/controller/DonorPortalController.cls:126-128, :383-399, :472-478 - getGivingStatement -> TokenAction.doValidate requireNotBlank(token, 'token') -> validateToken -> service
- base/main/default/classes/shared/GuestAction.cls:36-38 - callerSafeMessage returns AppException message verbatim, otherwise GENERIC_FAILURE constant
- base/main/default/classes/shared/ControllerAction.cls:45-57 - validation errors joined from addError literals; exceptions routed through callerSafeMessage; full message to AppLogger only
- base/main/default/classes/donor/service/DonorPortalService.cls:54-55, :696-711 - validateToken throws AppException(INVALID_MSG) constant for every failure
- base/main/default/classes/donation/service/GivingStatementService.cls:298, :303, :310-312 - the only AppExceptions on the statement path are constant strings
- grep lwc:dom|lwc:inner-html|innerHTML in lwc/pfGivingStatement and lwc/publicDonorDashboard - zero hits

75. Vulnerability Name

CRUD Delete — classes/shared/async/RetentionPurgeBatch.cls:90 (R-018; CRUD Delete paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

76. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

77. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Delete operations that are performed without checking for isDeletable() permisison before performing the delete operation. Flagged statement: delete as system scope;

WHY THE CLAIM IS FALSE

The claim that an isDeletable() check is missing is false because the delete runs in batch Apex, which the scan's own rule exempts, over a scope produced only by the retention selectors (diagnostic, staging and request rows past the administrator-configured window); no caller chooses the rows, and a job owner without Delete on an internal object would otherwise silently leave expired data in place.

SUPPORTING DETAIL

This is the data-retention purge: the scope is produced only by the per-target selector locators (Log__c and Transaction_Log__c older than the admin-configured retention window, terminal Donation_Staging__c and Guest_Request__c older than it, and terminal or stale portal tokens after 7 days). It runs as a scheduled batch or when an administrator runs it from the setup console; no caller supplies record Ids. No packaged permission set grants Delete on these append-only tables by design, so the purge must delete in system mode.

LOCATION IN THE SUBMITTED SOURCE

classes/shared/async/RetentionPurgeBatch.cls:90

SOURCES

unverified against primary docs (developer.salesforce.com apex_scheduler.htm returned 403 / cookie wall); secondary: https://help.salesforce.com/s/articleView?id=sf.code_schedule_batch_apex.htm (search snippet: scheduled Apex executes under the user who scheduled the job)

78. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

classes/RetentionPurgeBatch.cls:90
delete as system scope;

REPORTED DATAFLOW — CRUD DELETE, PATH 1

classes/RetentionPurgeBatch.cls:90 delete as system scope;

EVIDENCE CHECKED

- base/main/default/classes/shared/async/RetentionPurgeBatch.cls:1-16 - rationale; without sharing
- base/main/default/classes/shared/async/RetentionPurgeBatch.cls:41-78 - fixed selector locators per Target; else throws
- base/main/default/classes/setup/service/SettingsService.cls:927-932 - dataRetentionDays default 90 (no lower floor; admin-controlled)

79. Vulnerability Name

FLS Create — `classes/donation/async/ReconciliationHeartbeat.cls:59` (R-019; FLS Create paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

80. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

81. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. Flagged statement: `insert as system new Transaction_Log__c(Event_Type__c = 'HEARTBEAT_ALERT', Status__c = 'Rejected',`

WHY THE CLAIM IS FALSE

The claim is false because the insert is an operations alarm written by a scheduled job with no user input, every field a constant or a count of stuck rows; the job runs as whoever scheduled it, including the install context that holds no permission set, and Salesforce's own guidance accepts system-mode DML in scheduled context.

SUPPORTING DETAIL

This is an operations alarm written by a scheduled job with no user input: every field is a constant or a message built from a count of stuck staging rows. The job is scheduled at package install (post-install context, which holds no permission sets) or by an administrator from the setup console, so the insert must not depend on the scheduling user's `Transaction_Log__c` grants; `Transaction_Log__c` is an internal audit object not granted to guests. No record Id or value from a caller reaches the insert.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/async/ReconciliationHeartbeat.cls:59`

SOURCES

- unverified against primary docs (developer.salesforce.com apex_scheduler.htm returned 403 / cookie wall); secondary: https://help.salesforce.com/s/articleView?id=sf.code_schedule_batch_apex.htm (search snippet: scheduled Apex executes under the user who scheduled the job)

82. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReconciliationHeartbeat.cls:59
insert as system new Transaction_Log__c(Event_Type__c = 'HEARTBEAT_ALERT', Status__c = 'Rejected',
```

REPORTED DATAFLOW — FLS CREATE, PATH 1

```
classes/ReconciliationHeartbeat.cls:60  Error__c = msg, Processed_At__c = System.now());
classes/ReconciliationHeartbeat.cls:59  insert as system new Transaction_Log__c(Event_Type__c =
'HEARTBEAT_ALERT', Status__c = 'Rejected',
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/ReconciliationHeartbeat.cls:8-11 - without sharing with rationale (scheduled job; runs as whoever scheduled it)
- base/main/default/classes/donation/async/ReconciliationHeartbeat.cls:26-62 - execute(): selector count -> constant-valued log insert -> admin email
- base/main/default/classes/setup/controller/PostInstallHandler.cls:495 - scheduleIfAbsent schedules it at install

83. Vulnerability Name

FLS Create — `classes/donation/async/StripePaymentSweep.cls:203` (R-020; FLS Create paths 8–12)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

84. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

85. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. Flagged statement: `insert as system new Transaction_Log__c(`

WHY THE CLAIM IS FALSE

The claim is false because the insert records the outcome of a scheduled repair sweep with constant values, the staging Id being repaired and a caught exception message; it runs in batch context, including when scheduled at install by a user with no permission set, and no caller-supplied value reaches it.

SUPPORTING DETAIL

logSweep records the outcome of the scheduled Stripe-to-Salesforce repair sweep; its arguments are constants chosen by the sweep, the staging Id it is repairing, and a caught exception message. The sweep is scheduled at install or started by an administrator from the setup console, and the install-context owner holds no permission sets, so the audit insert runs in system mode. No caller-supplied value reaches it.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/async/StripePaymentSweep.cls:203`

SOURCES

- unverified against primary docs (developer.salesforce.com apex_scheduler.htm returned 403 / cookie wall); secondary: https://help.salesforce.com/s/articleView?id=sf.code_schedule_batch_apex.htm (search snippet: scheduled Apex executes under the user who scheduled the job)

86. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/StripePaymentSweep.cls:203
insert as system new Transaction_Log__c(
```

REPORTED DATAFLOW — FLS CREATE, PATH 8 (ONE OF 8–12)

```
classes/StripePaymentSweep.cls:204 Event_Type__c      = eventType,
classes/StripePaymentSweep.cls:203 insert as system new Transaction_Log__c(
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/StripePaymentSweep.cls:23-26 - without sharing with rationale
- base/main/default/classes/donation/async/StripePaymentSweep.cls:200-210 - private logSweep, all values from sweep internals

87. Vulnerability Name

FLS Create — `classes/donation/async/StagingReconciliationBatch.cls:281` (R-021; FLS Create paths 13–14, 24, 41, 48–49)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

88. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

89. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. Flagged statement: `insert as system log;`

WHY THE CLAIM IS FALSE

The claim is false because the insert writes the job's own audit row with every field system-derived (Ids created in the same transaction, a constant event type, an exception message, a timestamp), in a scheduled batch context the scan's own rule exempts and that may run as a user with no permission set.

SUPPORTING DETAIL

This inserts the reconciliation audit row (`Transaction_Log__c`) for each staging the job processes; every field is system-derived (staging Id, Opportunity Id created by the same transaction, a constant event type/status, an exception message, a timestamp). It runs in the scheduled reconciler and the internal retry action; the scheduled run can be owned by the install context user, which holds no permission sets, so the audit write must not depend on the running user's grants. `Transaction_Log__c` is internal and not granted to the guest profile.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/async/StagingReconciliationBatch.cls:281`

SOURCES

- unverified against primary docs (developer.salesforce.com apex_scheduler.htm returned 403 / cookie wall); secondary: https://help.salesforce.com/s/articleView?id=sf.code_schedule_batch_apex.htm (search snippet: scheduled Apex executes under the user who scheduled the job)

90. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/StagingReconciliationBatch.cls:281
insert as system log;
```

REPORTED DATAFLOW — FLS CREATE, PATH 13 (ONE OF 13–14, 24, 41, 48–49)

```
classes/StagingReconciliationBatch.cls:214 log.Opportunity__c = oppId;
classes/StagingReconciliationBatch.cls:281 insert as system log;
```

EVIDENCE CHECKED

- `base/main/default/classes/donation/async/StagingReconciliationBatch.cls:186-250` - log fields populated from staging Id, oppld, constants, `e.getMessage()`
- `base/main/default/classes/donation/async/StagingReconciliationBatch.cls:281` - single insert per staging

91. Vulnerability Name

FLS Create / FLS Update — `classes/donation/async/RefundReconciliationBatch.cls:344` (R-022; FLS Create paths 16–17, 29; FLS Update paths 3–4)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

92. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

93. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permisison before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permisison before performing the Update operation on the Object and its fields. Flagged statement: `upsert as system s;`

WHY THE CLAIM IS FALSE

The claim that this write bypasses a required createable/updateable check is false: the row is the package's own job cursor (two timestamps computed from the payment gateway's responses), the statement runs only inside a scheduled batch with no interactive user, and Salesforce's own guidance accepts system-mode DML in batch context as a false positive. A user-mode write would make the job's correctness depend on which administrator happened to schedule it.

SUPPORTING DETAIL

This write stores two Datetime high-water marks (refund and dispute cursors) computed by the batch from the payment gateway's list responses; no user-supplied value reaches it. It runs only in the scheduled reconciliation job or when an administrator starts that job from the settings console, and the cursor must advance regardless of the scheduling user's field permissions or the next run re-reads the whole window. Enforcing FLS here would not protect any user data; it would only let a missing grant silently stall reconciliation.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/async/RefundReconciliationBatch.cls:344`

SOURCES

- https://help.salesforce.com/s/articleView?id=platform.code_schedule_batch_apex.htm&language=en_US&type=5

94. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/RefundReconciliationBatch.cls:344
upsert as system s;
```

REPORTED DATAFLOW — FLS CREATE, PATH 16 (ONE OF 16–17, 29)

```
classes/RefundReconciliationBatch.cls:340 if (cursorTarget != null) { s.Refund_Reconcile_Cursor__c
= cursorTarget; }
classes/RefundReconciliationBatch.cls:344 upsert as system s;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 3 (ONE OF 3–4)

```
classes/RefundReconciliationBatch.cls:340 if (cursorTarget != null) { s.Refund_Reconcile_Cursor__c
= cursorTarget; }
classes/RefundReconciliationBatch.cls:344 upsert as system s;
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/RefundReconciliationBatch.cls:334-344 finish(): only when !hadError; sets Refund_Reconcile_Cursor__c / Dispute_Reconcile_Cursor__c from cursorTarget/disputeCursorTarget (system-computed), then `upsert as system s`
- base/main/default/classes/donation/async/RefundReconciliationBatch.cls:170-171 reads the same cursors with a 2h overlap
- Scheduled Apex executes in the context of the user who scheduled it (CronTrigger owner), in system mode - not the Automated Process user
- Fundraising_Admin holds edit on both cursor fields; the only interactive trigger (runJobNow) is Fundraising_Admin-only
- base/main/default/classes/donation/async/RefundReconciliationBatch.cls:155 and :336 use Settings__c.getOrgDefaults() (the org-default row only)

95. Vulnerability Name

FLS Create / FLS Update / Apex SOQL SOSL USER MODE MISSING —
`classes/setup/service/SettingsService.cls:1026` (R-023; FLS Create paths 18–19, 43; FLS Update paths 6–7; Apex SOQL SOSL USER MODE MISSING paths 14)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

96. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

97. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `upsert as system s;`

WHY THE CLAIM IS FALSE

The claim is false because the write is to the org-default row of the package's own custom setting, reached only through an administrator console gated by the `Manage_Fundraising_Settings` custom permission, with both the field name and the value validated against fixed allow-lists; and a user-mode upsert on a hierarchy custom setting requires `Customize Application`, which the package's own admin permission set cannot grant (measured: `upsert as user` throws `SecurityException` for a `Fundraising_Admin` user).

SUPPORTING DETAIL

This writes one of two scheduling-interval fields on the org-default `Settings__c` row; the family is checked against two fixed names and the interval against a fixed allow-list before the write. It is reached only from the settings console controller's `ScheduleJobFamily` action, which is granted only in the `Fundraising_Admin` permission set. System mode is retained because DML on a Hierarchy Custom Setting in user mode requires `Customize Application`, which a packaged permission set cannot grant. `ScheduleJobFamily.doValidate()` first checks the packaged custom permission `Manage_Fundraising_Settings` (granted only in `Fundraising_Admin`) and refuses the save when the running user does not hold it; the site carries a `SYSTEM_MODE` comment naming that gate. The user-mode alternative was tested and does not work for the people who use this screen. Measured 2026-10-01 in a scratch org, running as a Standard User who holds the `Fundraising_Admin` permission set: `Schema.sObjectType.Settings__c` reports `isCreatable`, `isUpdateable` and `isAccessible` all false, and `upsert as user` on the settings row throws `System.SecurityException: Access to entity 'Settings__c' denied`. The platform ties custom-setting DML to `Customize Application`, which is a system permission the fundraising administrator is not expected to hold, so a user-mode write would lock every non-system-administrator out of the settings console. The custom-permission check before the write is the access control; it is enforced in Apex on every action that reaches this line.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/SettingsService.cls:1026`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.cs_schema_settings.htm
- <https://github.com/patronmanager/apex-dml-manager/issues/2>
- https://help.salesforce.com/s/articleView?language=en_US&id=release-notes.rn_apex_default_user_mode.htm&release=262&type=5

98. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/SettingsService.cls:1026  
upsert as system s;
```

REPORTED DATAFLOW — FLS CREATE, PATH 18 (ONE OF 18–19, 43)

```
classes/SettingsService.cls:1014 s.Finalizer_Interval_Minutes__c = intervalMinutes;  
classes/SettingsService.cls:1026 upsert as system s;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 6 (ONE OF 6–7)

```
classes/SettingsService.cls:1014 s.Finalizer_Interval_Minutes__c = intervalMinutes;  
classes/SettingsService.cls:1026 upsert as system s;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 14

```
classes/SetupController.cls:397 public static Map<String, Object> scheduleJobFamily(String family,  
Integer intervalMinutes) {  
classes/SetupController.cls:398 return new ScheduleJobFamily(family, intervalMinutes).run();  
classes/ControllerAction.cls:52 Object result = doExecute();  
classes/SetupController.cls:2218 SettingsService.saveJobIntervalMinutes(family, intervalMinutes);  
classes/SettingsService.cls:1002 public static void saveJobIntervalMinutes(String family, Integer  
intervalMinutes) {  
classes/SettingsService.cls:1014 s.Finalizer_Interval_Minutes__c = intervalMinutes;  
classes/SettingsService.cls:1026 upsert as system s;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/SettingsService.cls:1022-1026 - `// SYSTEM_MODE:` reason naming the `ScheduleJobFamily` gate, then `upsert as system s`
- base/main/default/classes/setup/controller/SetupController.cls:2192-2201 - `ScheduleJobFamily` extends `SettingsWriteAction`; `doValidate()` calls `requireSettingsPermission()` before the family / interval checks
- `SetupController_Test.test_scheduleJobFamily_userWithoutSettingsPermission_isRefused`
- `Fundraising_Admin` is the only permission set with `SetupController` classAccess and the only one carrying `Manage_Fundraising_Settings`
- Every settings write in the package is reached only through a `SetupController` action whose `doValidate()` calls `requireSettingsPermission()`, i.e. `FeatureManagement.checkPermission('Manage_Fundraising_Settings')`; only the `Fundraising_Admin` permission set grants that custom permission. The install-time seeds are the one other caller and run with no interactive user (hardened 2026-09-25).

99. Vulnerability Name

FLS Create / FLS Update — `classes/setup/controller/PostInstallHandler.cls:1515` (R-024; FLS Create paths 20, 44; FLS Update paths 9)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

100. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

101. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `upsert as system s;`

WHY THE CLAIM IS FALSE

The claim is false because the write targets the org-default row of the package's own hierarchy custom setting, runs only inside the InstallHandler as the package's system user (no permission set), and writes an Id the same install step just produced; custom-setting DML in user mode would additionally require Customize Application, which no install user holds.

SUPPORTING DETAIL

This stores the Id of the event pricebook that the same install step just found or created on the org-default custom setting row, only when that field is blank. It runs only from the InstallHandler as the package's system user, which has no permission set to enforce, and never overwrites an administrator's value. No user input reaches the write.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/controller/PostInstallHandler.cls:1515`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

102. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:1515
upsert as system s;
```

REPORTED DATAFLOW — FLS CREATE, PATH 20 (ONE OF 20, 44)

```
classes/PostInstallHandler.cls:1512 s.Event_Pricebook_Id__c = pricebookId;
classes/PostInstallHandler.cls:1515 upsert as system s;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 9

```
classes/PostInstallHandler.cls:1512 s.Event_Pricebook_Id__c = pricebookId;  
classes/PostInstallHandler.cls:1515 upsert as system s;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own `try/catch`; only `logStepFailure` on error
- `grep` of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- Only backfills when the field is blank ('only backfills the Settings lookup when blank, so an admin's own configuration is never overwritten on upgrade' - method Javadoc)
- Value is the Id of a record this same method just found or inserted; no user input

103. Vulnerability Name

FLS Create / FLS Update — `classes/setup/controller/PostInstallHandler.cls:1557` (R-025; FLS Create paths 21, 45; FLS Update paths 10)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

104. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

105. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `upsert as system s;`

WHY THE CLAIM IS FALSE

The claim is false because the write is to the org-default row of the package's own custom setting, from the InstallHandler's system user with no permission set, storing an Id the install step itself created; there is no running user whose field permissions could meaningfully be checked.

SUPPORTING DETAIL

This records the Id of the event donation product, found or created by the same install step, on the org-default custom setting row when that field is blank. It runs only from the InstallHandler as the package's system user and does not overwrite an administrator's value. No user input reaches the write.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/controller/PostInstallHandler.cls:1557`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

106. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:1557
upsert as system s;
```

REPORTED DATAFLOW — FLS CREATE, PATH 21 (ONE OF 21, 45)

```
classes/PostInstallHandler.cls:1554 s.Event_Donation_Product_Id__c = productId;
classes/PostInstallHandler.cls:1557 upsert as system s;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 10

```
classes/PostInstallHandler.cls:1554 s.Event_Donation_Product_Id__c = productId;  
classes/PostInstallHandler.cls:1557 upsert as system s;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own `try/catch`; only `logStepFailure` on error
- `grep` of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- Only backfills when the field is blank ('only backfills the Settings lookup when blank, so an admin's own configuration is never overwritten on upgrade' - method Javadoc)
- Value is the Id of a record this same method just found or inserted; no user input

107. Vulnerability Name

FLS Create / FLS Update — `classes/setup/controller/PostInstallHandler.cls:1601` (R-026; FLS Create paths 22, 46; FLS Update paths 11)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

108. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

109. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `upsert as system s;`

WHY THE CLAIM IS FALSE

The claim is false because the write is to the org-default row of the package's own custom setting, from the InstallHandler's system user with no permission set, storing an Id the install step itself created; the administrator's existing value is never overwritten.

SUPPORTING DETAIL

This records the Id of the event processing-fee product, found or created by the same install step, on the org-default custom setting row when that field is blank. It runs only from the InstallHandler as the package's system user and never overwrites an administrator's value. No user-supplied data reaches it.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/controller/PostInstallHandler.cls:1601`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

110. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:1601
upsert as system s;
```

REPORTED DATAFLOW — FLS CREATE, PATH 22 (ONE OF 22, 46)

```
classes/PostInstallHandler.cls:1598 s.Event_Fee_Product_Id__c = productId;
classes/PostInstallHandler.cls:1601 upsert as system s;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 11

```
classes/PostInstallHandler.cls:1598 s.Event_Fee_Product_Id__c = productId;  
classes/PostInstallHandler.cls:1601 upsert as system s;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own `try/catch`; only `logStepFailure` on error
- `grep` of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- Only backfills when the field is blank ('only backfills the Settings lookup when blank, so an admin's own configuration is never overwritten on upgrade' - method Javadoc)
- Value is the Id of a record this same method just found or inserted; no user input

111. Vulnerability Name

FLS Create — classes/setup/controller/PostInstallHandler.cls:260 (R-027; FLS Create paths 23, 25–27)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

112. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

113. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. Flagged statement: upsert as system s;

WHY THE CLAIM IS FALSE

The claim is false because the write seeds the org-default row of the package’s own hierarchy custom setting from compiled constants, runs only in the InstallHandler as the package’s system user (no permission set), and fills only blank fields; custom-setting DML in user mode requires Customize Application, which the install user does not hold, so a user-mode write would fail the install.

SUPPORTING DETAIL

This seeds the org-default row of the package’s hierarchy custom setting with constant defaults during package install or upgrade, filling only blank fields. It runs only from the InstallHandler, which executes as the package’s special system user; that user holds no permission set, so there is no user FLS to enforce. The method is not reachable from any controller, guest page or subscriber Apex.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/controller/PostInstallHandler.cls:260

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

114. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:260
upsert as system s;
```

REPORTED DATAFLOW — FLS CREATE, PATH 23 (ONE OF 23, 25–27)

```
classes/PostInstallHandler.cls:213  SetupOwnerId                =
UserInfo.getOrganizationId(),
classes/PostInstallHandler.cls:212  s = new Settings__c(
classes/PostInstallHandler.cls:260  upsert as system s;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own `try/catch`; only `logStepFailure` on error
- `grep` of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- base/main/default/classes/setup/controller/PostInstallHandler.cls:206-260 `seedDefaultSettings`: creates the org-default `Settings__c` only if absent (`SetupOwnerId = org Id`) and backfills blank colour/text defaults from constants; `adoptTributeMasterSwitch` reads Campaign WITH `SYSTEM_MODE`
- All values are package constants or derived from existing org data; no user input

115. Vulnerability Name

FLS Create — `classes/setup/service/SettingsService.cls:563` (R-028; FLS Create paths 30–32)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

116. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

117. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. Flagged statement: `Database.insert(cv, AccessLevel.SYSTEM_MODE);`

WHY THE CLAIM IS FALSE

The claim is false because the insert runs during install as the package's system user, which holds no permission set, and copies the package's own static-resource image into ContentVersion with constant Title and PathOnClient; ContentVersion is a standard object a 2GP permission set cannot grant, and no subscriber data is involved.

SUPPORTING DETAIL

PackagedAssetSeeder copies the package's own static-resource images (default logo, hero image, social-share image) into ContentVersion so the public pages have a default; Title/PathOnClient are constants and VersionData is the packaged resource body. It runs in the post-install context, whose user holds no permission sets, and ContentVersion is a standard object a second-generation package permission set cannot grant. The interactive admin upload of a custom logo uses user mode instead.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/SettingsService.cls:563`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm (post-install script runs as a package-specific system user)
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

118. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/SettingsService.cls:563
Database.insert(cv, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS CREATE, PATH 30 (ONE OF 30–32)

```
classes/SettingsService.cls:558 Title = fileName,  
classes/SettingsService.cls:557 ContentVersion cv = new ContentVersion(  
classes/SettingsService.cls:563 Database.insert(cv, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/SettingsService.cls:543-594 - PackagedAssetSeeder, inner without sharing with rationale; content from DefaultOrgLogo/DefaultHeroImage/DefaultSocialShareImage
- base/main/default/classes/setup/service/SettingsService.cls createLogoDistribution - USER_MODE for the admin upload path

119. Vulnerability Name

FLS Create — `classes/setup/service/SettingsService.cls:581` (R-029; FLS Create paths 33–37)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

120. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

121. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. Flagged statement: `Database.insert(cd, AccessLevel.SYSTEM_MODE);`

WHY THE CLAIM IS FALSE

The claim is false because the insert runs during install as the package's system user, which holds no permission set, and publishes a public link for the file the previous statement created from a packaged static resource; ContentDistribution is a standard object a 2GP permission set cannot grant, and the public link is the feature (default images on unauthenticated donation pages and receipts), not a leak.

SUPPORTING DETAIL

This publishes a public link for the package's own default image, which must be publicly reachable because it is rendered on unauthenticated donation pages and in receipt emails. The file is created one line earlier from a packaged static resource, so no subscriber or user file can be published through this path. It runs in the post-install context (no permission sets) or from an administrator's reset-to-default action.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/SettingsService.cls:581`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm (post-install script runs as a package-specific system user)
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for stan dard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, r etrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

122. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/SettingsService.cls:581
Database.insert(cd, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS CREATE, PATH 33 (ONE OF 33–37)

```
classes/SettingsService.cls:572 Name = fileName,  
classes/SettingsService.cls:571 ContentDistribution cd = new ContentDistribution(  
classes/SettingsService.cls:581 Database.insert(cd, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/SettingsService.cls:570-581 - ContentDistribution on the ContentVersion just inserted from a static resource

123. Vulnerability Name

FLS Create — classes/setup/controller/PostInstallHandler.cls:1503 (R-030; FLS Create paths 38)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

124. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

125. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM
This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. Flagged statement: insert as system pb;

WHY THE CLAIM IS FALSE
The claim is false because the insert runs only inside the package InstallHandler as the package's system user, which holds no permission set, and Pricebook2 is a standard object a 2GP permission set cannot grant; every value is a constant, so no user input reaches the write.

SUPPORTING DETAIL
This creates the package's event pricebook once, at install, with a constant name, only if it does not already exist. Pricebook2 is a standard object that a packaged permission set cannot grant, and the method runs only from the InstallHandler as the package's system user. No controller, guest page or subscriber code can call it.

LOCATION IN THE SUBMITTED SOURCE
classes/setup/controller/PostInstallHandler.cls:1503

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

126. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT
classes/PostInstallHandler.cls:1503
insert as system pb;

REPORTED DATAFLOW — FLS CREATE, PATH 38
classes/PostInstallHandler.cls:1501 Pricebook2 pb = new Pricebook2(Name = EVENT_PRICEBOOK_NAME, IsActive = true);
classes/PostInstallHandler.cls:1503 insert as system pb;

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 onInstall calls each seed* step in its own try/catch; only logStepFailure on error
- grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- Pricebook2 and Product2 are standard objects. A managed package cannot ship object permissions on a standard object — Salesforce ignores them at install (packaging guide, cited below) — and the per-package install user holds no permission set in any case, so a user-mode write here could never satisfy the check the scanner asks for.
- base/main/default/classes/event/service/PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a `with sharing` path could not even resolve Pricebook2 as the per-package system user
- base/main/default/classes/setup/controller/PostInstallHandler.cls:1501 `new Pricebook2(Name = EVENT_PRICEBOOK_NAME, IsActive = true)` - constant values; inserted only when neither the current nor the legacy pricebook exists

127. Vulnerability Name

FLS Create — classes/setup/controller/PostInstallHandler.cls:1537 (R-031; FLS Create paths 39)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

128. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

129. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. Flagged statement: insert as system p;

WHY THE CLAIM IS FALSE

The claim is false because the insert runs only inside the package InstallHandler as the package's system user, which holds no permission set, and Product2 is a standard object a 2GP permission set cannot grant; every field value is a compiled constant.

SUPPORTING DETAIL

This creates the package's generic event donation product once, at install, with constant field values and only if it does not already exist. Product2 is a standard object that a packaged permission set cannot grant, and the code runs only from the InstallHandler as the package's system user. It is not reachable from any user-facing entry point.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/controller/PostInstallHandler.cls:1537

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

130. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:1537
insert as system p;
```

REPORTED DATAFLOW — FLS CREATE, PATH 39

```
classes/PostInstallHandler.cls:1534  Product2 p = new Product2(Name = EVENT_DONATION_PRODUCT_NAME,
IsActive = true);
classes/PostInstallHandler.cls:1537  insert as system p;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 onInstall calls each seed* step in its own try/catch; only logStepFailure on error
- grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- Pricebook2 and Product2 are standard objects. A managed package cannot ship object permissions on a standard object — Salesforce ignores them at install (packaging guide, cited below) — and the per-package install user holds no permission set in any case, so a user-mode write here could never satisfy the check the scanner asks for.
- base/main/default/classes/event/service/PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a `with sharing` path could not even resolve Pricebook2 as the per-package system user
- base/main/default/classes/setup/controller/PostInstallHandler.cls:1534 `new Product2(Name = EVENT_DONATION_PRODUCT_NAME, IsActive = true)` - constants; only when no Product2 with that name exists (query WITH SYSTEM_MODE)

131. Vulnerability Name

FLS Create — `classes/setup/controller/PostInstallHandler.cls:1581` (R-032; FLS Create paths 40)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

132. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

133. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. Flagged statement: `insert as system p;`

WHY THE CLAIM IS FALSE

The claim is false because the insert runs only inside the package InstallHandler as the package's system user, which holds no permission set, and Product2 is a standard object a 2GP permission set cannot grant; the values are constants.

SUPPORTING DETAIL

This creates the package's event processing-fee product once, at install, with constant values and only if it does not already exist. Product2 is a standard object a packaged permission set cannot grant, and the method runs only from the InstallHandler as the package's system user. It has no interactive or guest caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/controller/PostInstallHandler.cls:1581`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

134. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:1581
insert as system p;
```

REPORTED DATAFLOW — FLS CREATE, PATH 40

```
classes/PostInstallHandler.cls:1578  Product2 p = new Product2(Name = EVENT_FEE_PRODUCT_NAME,
classes/PostInstallHandler.cls:1581  insert as system p;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own try/catch; only `logStepFailure` on error
- grep of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- `Pricebook2` and `Product2` are standard objects. A managed package cannot ship object permissions on a standard object — Salesforce ignores them at install (packaging guide, cited below) — and the per-package install user holds no permission set in any case, so a user-mode write here could never satisfy the check the scanner asks for.
- base/main/default/classes/event/service/PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a `with sharing` path could not even resolve `Pricebook2` as the per-package system user
- base/main/default/classes/setup/controller/PostInstallHandler.cls:1578 `new Product2(Name = EVENT_FEE_PRODUCT_NAME, IsActive = true)` - constants; only when absent

135. Vulnerability Name

FLS Create — `classes/event/service/EventPurchaseService.cls:590` (R-033; FLS Create paths 42)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

136. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

137. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permisison before performing the Create operation on the Object and its fields. Flagged statement: `insert as system toAdd; // bulk — never per-attendee DML`

WHY THE CLAIM IS FALSE

The claim is false because the insert runs in the reconciliation job that finalizes a paid ticket order, a context the scan's own rule exempts, and CampaignMember is a standard object a 2GP permission set cannot grant; the Contact and Campaign Ids come from the finalized order, not from a caller.

SUPPORTING DETAIL

After a paid ticket order is finalized by the reconciliation job, attendees with a Contact are added to the event Campaign as CampaignMembers. CampaignMember is a standard object that a second-generation package permission set cannot grant, and the finalizer runs in scheduled context, so the insert runs in system mode. The Campaign comes from the server-side staging record and the Contacts from the attendees created in the same finalization; existing members are skipped, and no browser input chooses either.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService.cls:590`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_batch_interface.htm (batch Apex runs asynchronously; Salesforce false-positive guidance exempts batch and async context)
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/pkg2_dev_packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

138. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService.cls:590
insert as system toAdd; // bulk — never per-attendee DML
```

REPORTED DATAFLOW — FLS CREATE, PATH 42

```
classes/EventPurchaseService.cls:587  toAdd.add(new CampaignMember(CampaignId = campaignId,  
ContactId = cid));  
classes/EventPurchaseService.cls:590  insert as system toAdd; // bulk – never per-attendee DML
```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService.cls:570-590 - campaign from staging, contacts from attendees, existing members excluded
- Comment cites 'CampaignMemberSyncService.syncForOpportunities', which does not exist (method is syncForDonations); 'after a guest order is committed' - it actually runs in the batch/retry finalizer

139. Vulnerability Name

FLS Create — `classes/donation/service/CampaignMemberSyncService.cls:80` (R-034; FLS Create paths 47)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

140. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

141. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. Flagged statement: `List<Database.SaveResult> results = Database.insert(toAdd, false, AccessLevel.SYSTEM_MODE);`

WHY THE CLAIM IS FALSE

The claim is false because the insert runs inside the platform-event subscriber trigger as the Automated Process entity, which can hold no permission set, and CampaignMember is a standard object a 2GP permission set cannot grant; the Contact and Campaign Ids come from the finalized donation itself, not from a caller.

SUPPORTING DETAIL

This adds the donor to the donation's campaign as a CampaignMember after a gift is finalized; it runs in the platform-event subscriber trigger, which executes as the Automated Process entity. CampaignMember is a standard object that a second-generation package permission set cannot grant, and the Automated Process context has no user permissions to enforce. CampaignId and ContactId are read from the finalized Opportunity itself, and existing memberships are skipped, so the insert cannot target arbitrary campaigns or contacts.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/service/CampaignMemberSyncService.cls:80`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.platform_events.meta/platform_events/platform_events_subscribe_apex.htm
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/pkg2_dev_packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

142. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CampaignMemberSyncService.cls:80
List<Database.SaveResult> results = Database.insert(toAdd, false, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS CREATE, PATH 47

```
classes/CampaignMemberSyncService.cls:68  toAdd.add(new CampaignMember(CampaignId = campaignId,  
ContactId = contactId));  
classes/CampaignMemberSyncService.cls:71  if (toAdd.isEmpty()) { return; }  
classes/CampaignMemberSyncService.cls:80  List<Database.SaveResult> results =  
Database.insert(toAdd, false, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/CampaignMemberSyncService.cls:68 - CampaignMember built from Opportunity CampaignId + resolved contact
- base/main/default/classes/donation/service/CampaignMemberSyncService.cls:80 - comment present and accurate

143. Vulnerability Name

FLS Create — classes/setup/controller/PostInstallHandler.cls:1645 (R-035; FLS Create paths 55, 80, 83–87)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

144. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

145. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM
This query looks for CRUD Delete operations that are performed without checking for isCreatable() permisison before performing the Create operation on the Object and its fields. Flagged statement: insert as system toInsert;

WHY THE CLAIM IS FALSE
The claim is false because the insert runs only inside the package InstallHandler as the package's system user, which holds no permission set, and the rows are starter templates whose text is literal in the package source; no user supplies any value and no user's permissions exist to check.

SUPPORTING DETAIL
This inserts a starter set of question and FAQ templates, whose text is literal in the package source, the first time the package is installed and only when the template table is empty. It runs only from the InstallHandler as the package's system user, which holds no permission set. Administrators edit or delete these templates afterwards through the normal, permission-checked console.

LOCATION IN THE SUBMITTED SOURCE
classes/setup/controller/PostInstallHandler.cls:1645

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

146. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT
classes/PostInstallHandler.cls:1645
insert as system toInsert;

REPORTED DATAFLOW — FLS CREATE, PATH 55 (ONE OF 55, 80, 83–87)
classes/PostInstallHandler.cls:1670 Answer__c = answer,
classes/PostInstallHandler.cls:1666 return new Content_Template__c(
classes/PostInstallHandler.cls:1640 toInsert.add(newFaq(faqRt, 'How is my payment information
protected?'),
classes/PostInstallHandler.cls:1645 insert as system toInsert;

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own `try/catch`; only `logStepFailure` on error
- `grep` of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- base/main/default/classes/setup/controller/PostInstallHandler.cls:1615-1672 `seedContentTemplates` inserts starter question/FAQ `Content_Template__c` rows (`RecordTypeId`, `Name`, `Prompt__c`, `Question_Type__c`, `Is_Active__c`, `Picklist_Options__c`, `Answer__c`) only when the table is empty; all text is literal in source

147. Vulnerability Name

FLS Create / FLS Update — `classes/setup/controller/PostInstallHandler.cls:758` (R-036; FLS Create paths 62, 66, 73, 76, 79, 82, 89, 91, 93, 95, 97, 99, 101–109; FLS Update paths 29, 36, 40, 43, 45, 47, 49, 51, 53, 55, 57, 59, 61–69)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

148. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

149. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permission before performing the Create operation on the Object and its fields. This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `upsert as system toUpsert;`

WHY THE CLAIM IS FALSE

The claim is false because the upsert creates or refreshes the six packaged theme records from constants compiled into the package, runs only in the InstallHandler as the package's system user with no permission set, and cannot be invoked by any user at runtime.

SUPPORTING DETAIL

This creates or refreshes the six packaged page-design theme records from constants compiled into the package, during install or upgrade. It runs only from the InstallHandler as the package's system user, which holds no permission set, and every assigned value is a literal from the package source. Packaged themes are read-only to administrators, who clone them to customise, so no administrator data is overwritten.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/controller/PostInstallHandler.cls:758`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

150. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:758
upsert as system toUpsert;
```

REPORTED DATAFLOW — FLS CREATE, PATH 62 (ONE OF 62, 66, 73, 76, 79, 82, 89, 91, 93, 95, 97, 99, 101–109)

```
classes/PostInstallHandler.cls:1254  d.Form_Builder_JSON__c      = canvasJson(new List<Map<String,
Object>>{
classes/PostInstallHandler.cls:1268  return d;
```

```
classes/PostInstallHandler.cls:750 toUpsert.add(buildTheme(  
classes/PostInstallHandler.cls:758 upsert as system toUpsert;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 29 (ONE OF 29, 36, 40, 43, 45, 47, 49, 51, 53, 55, 57, 59, 61–69)

```
classes/PostInstallHandler.cls:1254 d.Form_Builder_JSON__c      = canvasJson(new List<Map<String,  
Object>>{  
classes/PostInstallHandler.cls:1268 return d;  
classes/PostInstallHandler.cls:750 toUpsert.add(buildTheme(  
classes/PostInstallHandler.cls:758 upsert as system toUpsert;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 public without sharing class PostInstallHandler implements InstallHandler; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 onInstall calls each seed* step in its own try/catch; only logStepFailure on error
- grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only)
- Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- base/main/default/classes/setup/controller/PostInstallHandler.cls:687-758 seedDefaultPageDesign upserts the six packaged Campaign_Design__c theme rows; buildTheme (:1196+) assigns colours, fonts, radius, widths from compile-time theme constants; reads WITH SYSTEM_MODE; followed by retireDeletedDesigns
- Packaged themes are read-only in the console (clone to edit), so overwriting their style fields on upgrade is the intended contract

151. Vulnerability Name

FLS Create — `classes/event/service/PricebookService.cls:125` (R-037; FLS Create paths 69, 71)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

152. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

153. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permisison before performing the Create operation on the Object and its fields. Flagged statement: `if (!newStd.isEmpty()) { insert as system newStd; } // MUST precede the custom-pricebook insert below`

WHY THE CLAIM IS FALSE

The claim is false because PricebookEntry is a standard object a 2GP permission set cannot grant, and the insert runs from install (package system user, no permission set), admin ticket-tier saves and guest purchases, where the Guest licence cannot hold Create; every value is fixed by Apex from a Product2 the package itself created.

SUPPORTING DETAIL

This creates the standard pricebook PricebookEntry a ticket Product2 needs before an OpportunityLineItem can reference it. Values are fixed by Apex (the Product2 the package created for the ticket tier, the pricebook Id, a placeholder unit price, IsActive=true, the org currency) - the real price lives on the line item.

PricebookEntry/Pricebook2 are standard objects the package permission sets cannot grant, and the same method runs in the post-install context and the scheduled finalizer; the staff entry point first verifies the user can edit the event Campaign and that the tier belongs to it.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/PricebookService.cls:125`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

154. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PricebookService.cls:125
if (!newStd.isEmpty()) { insert as system newStd; } // MUST precede the custom-pricebook insert
below
```

REPORTED DATAFLOW — FLS CREATE, PATH 69 (ONE OF 69, 71)

```
classes/PricebookService.cls:142 PricebookEntry pbe = new PricebookEntry(Product2Id = productId,
Pricebook2Id = pricebookId,
classes/PricebookService.cls:145 return pbe;
classes/PricebookService.cls:120 newStd.add(newEntry(pid, stdPbId, iso));
classes/PricebookService.cls:125 if (!newStd.isEmpty()) { insert as system newStd; } // MUST
precede the custom-pricebook insert below
```

EVIDENCE CHECKED

- base/main/default/classes/event/service/PricebookService.cls - class `without sharing` with doc rationale (Pricebook2 unresolvable under with sharing in post-install context)
- base/main/default/classes/event/service/PricebookService.cls:142-143 - PricebookEntry(Product2Id, Pricebook2Id, UnitPrice=PLACEHOLDER_PRICE, IsActive=true)
- base/main/default/classes/event/controller/EventTicketAdminController.cls:156-176, 197-263 - requireCampaignWritable + requireTiersBelongToCampaign before ensureEntriesFor; wrapped non-fatal

155. Vulnerability Name

FLS Create — `classes/event/service/PricebookService.cls:135` (R-038; FLS Create paths 70, 72)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

156. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

157. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Delete operations that are performed without checking for `isCreatable()` permisison before performing the Create operation on the Object and its fields. Flagged statement: `insert as system newEvt;`

WHY THE CLAIM IS FALSE

The claim is false because PricebookEntry is a standard object a 2GP permission set cannot grant, and the insert runs from install (package system user, no permission set), admin ticket-tier saves and guest purchases, where the Guest licence cannot hold Create; every value is fixed by Apex from a Product2 the package itself created.

SUPPORTING DETAIL

This creates the package event pricebook PricebookEntry a ticket Product2 needs before an OpportunityLineItem can reference it. Values are fixed by Apex (the Product2 the package created for the ticket tier, the pricebook Id, a placeholder unit price, IsActive=true, the org currency) - the real price lives on the line item.

PricebookEntry/Pricebook2 are standard objects the package permission sets cannot grant, and the same method runs in the post-install context and the scheduled finalizer; the staff entry point first verifies the user can edit the event Campaign and that the tier belongs to it.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/PricebookService.cls:135`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

158. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PricebookService.cls:135
insert as system newEvt;
```

REPORTED DATAFLOW — FLS CREATE, PATH 70 (ONE OF 70, 72)

```
classes/PricebookService.cls:142 PricebookEntry pbe = new PricebookEntry(Product2Id = productId,
Pricebook2Id = pricebookId,
```

```
classes/PricebookService.cls:145 return pbe;  
classes/PricebookService.cls:130 newEvt.add(newEntry(pid, eventPbId, iso));  
classes/PricebookService.cls:133 if (!newEvt.isEmpty()) {  
classes/PricebookService.cls:135 insert as system newEvt;
```

EVIDENCE CHECKED

- base/main/default/classes/event/service/PricebookService.cls - class without sharing with doc rationale (Pricebook2 unresolvable under with sharing in post-install context)
- base/main/default/classes/event/service/PricebookService.cls:142-143 - PricebookEntry(Product2Id, Pricebook2Id, UnitPrice=PLACEHOLDER_PRICE, IsActive=true)
- base/main/default/classes/event/controller/EventTicketAdminController.cls:156-176, 197-263 - requireCampaignWritable + requireTiersBelongToCampaign before ensureEntriesFor; wrapped non-fatal

159. Vulnerability Name

FLS Update — `classes/donation/async/StagingReconciliationBatch.cls:275` (R-039; FLS Update paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

160. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

161. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `update as system upd;`

WHY THE CLAIM IS FALSE

The claim is false because the update runs in a scheduled batch (and the equivalent staff 'Retry now' path that re-reads the gateway), writing only the caught exception message and the gateway's own payment status onto a guest-created staging row that no running user is granted Edit on; the values never come from the caller.

SUPPORTING DETAIL

The reconciler writes the finalization error and, for an unpaid staging past its TTL, sets `Status__c='Expired'`; the values come from the caught exception and Stripe's `PaymentIntent` status, never from the caller. It runs in a scheduled batch and in an internal 'retry now' action; `Fundraising_User` can view and retry stagings but deliberately has no Edit on `Donation_Staging__c` (the row is system-owned state), so the status transition must run in system mode. The only caller input is the staging Id on the retry path, and the action it triggers is the same idempotent reconciliation the scheduler would perform anyway.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/async/StagingReconciliationBatch.cls:275`

SOURCES

- unverified against primary docs (developer.salesforce.com apex_scheduler.htm returned 403 / cookie wall); secondary: https://help.salesforce.com/s/articleView?id=sf.code_schedule_batch_apex.htm (search snippet: scheduled Apex executes under the user who scheduled the job)

162. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/StagingReconciliationBatch.cls:275
update as system upd;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 1

```
classes/StagingReconciliationBatch.cls:269  upd.Status__c      = 'Expired';
classes/StagingReconciliationBatch.cls:275  update as system upd;
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/StagingReconciliationBatch.cls:260-276 - upd built from e.getMessage() and pi.status; Expired only when past TTL and payment not succeeded
- base/main/default/permissionsets/Fundraising_User - Donation_Staging__c Create/Read, no Edit
- base/main/default/classes/donation/staging/DonationStagingSelector.cls selectById - SYSTEM_MODE read, so retry has no record-visibility gate (minor; controller granted only to staff sets)

163. Vulnerability Name

FLS Update — `classes/donor/service/DonorPortalService.cls:383` (R-040; FLS Update paths 5)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

164. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

165. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `Database.update(bump, AccessLevel.SYSTEM_MODE);`

WHY THE CLAIM IS FALSE

The claim is false because the write increments the failed-attempt counter on a portal access code and locks it, a brute-force defence that must run as the Experience Cloud guest user; the Guest User licence cannot hold Edit on any object, and the credential table carries no guest grant at all, so a user-mode update would disable the lockout.

SUPPORTING DETAIL

This increments the failed-attempt counter on a donor-portal access code and locks it after the maximum attempts - a brute-force defence. The guest user cannot hold Edit on any object, and the credential table carries no guest grant at all, so the write must be system mode. The row is resolved server-side from the submitted email under FOR UPDATE, never from a client-supplied Id, and the only fields written are `Attempt_Count__c` and `Status__c='Locked'`, both computed by Apex. The worst a caller can do is lock a code, which the legitimate donor replaces by requesting a new one.

LOCATION IN THE SUBMITTED SOURCE

`classes/donor/service/DonorPortalService.cls:383`

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.networks_guest_policies_timelines.htm — Guest User Security Policies and Timelines: since Spring '21 the Edit, Delete, View All and Modify All object permissions are removed from guest users, and a permission set that grants any of them cannot be assigned to a guest user; guest users can hold only Read and Create.

166. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/DonorPortalService.cls:383
Database.update(bump, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS UPDATE, PATH 5

```
classes/DonorPortalService.cls:374  if (attempts >= MAX_CODE_ATTEMPTS) { bump.Status__c = 'Locked';
}
```

```
classes/DonorPortalService.cls:383 Database.update(bump, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/donor/service/DonorPortalService.cls:367-383 - bump built from selector row; attempts computed server-side
- base/main/default/classes/donor/service/DonorPortalService.cls class header - without sharing with rationale
- Portal_Access_Token__c has no Fundraising_GuestDonor grant (permset doc comment)
- ControllerAction.run has no savepoint rollback on caught error, so the increment persists after a failed verify (intended)

167. Vulnerability Name

FLS Update — classes/setup/controller/PostInstallHandler.cls:1498 (R-041; FLS Update paths 8)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

168. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

169. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Update operations that are performed without checking for isUpdateable() permission before performing the Update operation on the Object and its fields. Flagged statement: update as system legacy;

WHY THE CLAIM IS FALSE

The claim is false because the statement runs only inside the package InstallHandler, which executes as a package-specific system user that holds no permission set, so there is no user whose isUpdateable() could be consulted; and Pricebook2 is a standard object that a second-generation package permission set cannot grant, so no permission check could ever be satisfied by package metadata.

SUPPORTING DETAIL

This renames the package's own event pricebook from its earlier name to the current one during upgrade, so existing price book entries are kept. Pricebook2 is a standard object that a packaged permission set cannot grant, and the code runs only from the InstallHandler as the package's system user. The new name is a constant; nothing user-supplied is written.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/controller/PostInstallHandler.cls:1498

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5
- https://developer.salesforce.com/docs/atlas.en-us.pkg2_dev.meta/pkg2_dev/packaging_permission_set_groups.htm — "You can't include object permissions for standard objects in managed packages. During package installation, all object permissions for standard objects are ignored, and aren't installed in the org." Confirmed for this package on 2026-08-16: the installed permission set, retrieved from a subscriber org, carried none of the standard-object grants present in the source XML.

170. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:1498
update as system legacy;
```

REPORTED DATAFLOW — FLS UPDATE, PATH 8

```
classes/PostInstallHandler.cls:1495  legacy.Name = EVENT_PRICEBOOK_NAME;
classes/PostInstallHandler.cls:1498  update as system legacy;
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own try/catch; only `logStepFailure` on error
- grep of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- `Pricebook2` and `Product2` are standard objects. A managed package cannot ship object permissions on a standard object — Salesforce ignores them at install (packaging guide, cited below) — and the per-package install user holds no permission set in any case, so a user-mode write here could never satisfy the check the scanner asks for.
- base/main/default/classes/event/service/PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a `with sharing` path could not even resolve `Pricebook2` as the per-package system user
- base/main/default/classes/setup/controller/PostInstallHandler.cls:1477-1499 `seedEventPricebook`: if only the pre-rename pricebook exists, renames it in place to `EVENT_PRICEBOOK_NAME` ('Fundraising Events') so its `PricebookEntry` rows survive; the new name is a constant

171. Vulnerability Name

FLS Update — classes/guestrequest/handler/AttendeeNamingHandler.cls:129 (R-042; FLS Update paths 22–23, 32)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

172. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

173. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Update operations that are performed without checking for isUpdateable() permisison before performing the Update operation on the Object and its fields. Flagged statement: Database.SaveResult[] results = Database.update(toUpdate, false, AccessLevel.SYSTEM_MODE);

WHY THE CLAIM IS FALSE

The claim is false because the write runs asynchronously from the request queue, after ownership of the ticket order was verified synchronously against the donor's portal session, and only the attendee-name fields of that order's own seats are written; the running user is the guest user or the sweep's scheduler, neither of whom can hold Edit on the object.

SUPPORTING DETAIL

A donor who is signed in to the donor portal with a verified access code may name the blank guest seats on their own ticket order. Ownership is checked synchronously before anything is queued (requireOwnedOrder against the portal session), the verified order Id is stored server-side in Subject_Id__c, and this handler re-reads the seats of that order only - seat Ids in the payload that are not on the order, cancelled seats, and seats already named are ignored. The only fields written are First_Name__c, Last_Name__c and (when blank) Email__c, length-clipped and email-validated, which are exactly the data the donor is entitled to supply; the Guest licence cannot hold Edit, hence system mode.

LOCATION IN THE SUBMITTED SOURCE

classes/guestrequest/handler/AttendeeNamingHandler.cls:129

SOURCES

- unverified in this pass: Guest User licence cannot hold object Edit (project-documented platform limit)

174. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/AttendeeNamingHandler.cls:129
Database.SaveResult[] results = Database.update(toUpdate, false, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS UPDATE, PATH 22 (ONE OF 22–23, 32)

```
classes/AttendeeNamingHandler.cls:106 attendee.Last_Name__c = clip(seat.lastName, NAME_MAX);
classes/AttendeeNamingHandler.cls:116 toUpdate.add(attendee);
classes/AttendeeNamingHandler.cls:119 if (toUpdate.isEmpty()) {
classes/AttendeeNamingHandler.cls:129 Database.SaveResult[] results = Database.update(toUpdate,
false, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/donor/service/DonorPortalService.cls:1231-1283 - requireOwnedOrder(ctx, orderId); payload rebuilt from owned seats, never echoed from the browser
- base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:83-117 - seats re-read from Subject_Id__c order; unmatched/cancelled/already-named seats skipped; NAME_MAX/EMAIL_MAX
- base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:10-14 - without sharing with rationale
- base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:19 - MAX_SEATS payload cap

175. Vulnerability Name

FLS Update — `classes/guestrequest/service/GuestRequestService.cls:138` (R-043; FLS Update paths 24, 33)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

176. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

177. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement: `Database.update(claimed, false, AccessLevel.SYSTEM_MODE);`

WHY THE CLAIM IS FALSE

The claim is false because the write claims queued requests (status and attempt counter only) so the queueable and the sweep never process a row twice; it runs in the guest user's own queueable, where the Guest User licence cannot hold Edit on any object, or in the scheduled sweep, so a user-mode update could never succeed.

SUPPORTING DETAIL

This claims queued public requests (`Status__c Pending -> Processing`, `Attempt_Count__c + 1`) so the queueable and the sweep never process the same row twice. It runs in the guest user's own queueable - the Guest licence cannot hold Edit on any object - or in the scheduled sweep; the request Ids come from the row the server just inserted or from the sweep's query, and only rows still Pending are claimed. Both written values are computed by Apex.

LOCATION IN THE SUBMITTED SOURCE

`classes/guestrequest/service/GuestRequestService.cls:138`

SOURCES

- unverified against primary docs (developer.salesforce.com apex_scheduler.htm returned 403 / cookie wall); secondary: https://help.salesforce.com/s/articleView?id=sf.code_schedule_batch_apex.htm (search snippet: scheduled Apex executes under the user who scheduled the job)

178. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/GuestRequestService.cls:138
Database.update(claimed, false, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS UPDATE, PATH 24 (ONE OF 24, 33)

```
classes/GuestRequestService.cls:129 request.Attempt_Count__c = attempts(request) + 1;
classes/GuestRequestService.cls:130 claimed.add(request);
classes/GuestRequestService.cls:132 if (claimed.isEmpty()) { return; }
classes/GuestRequestService.cls:138 Database.update(claimed, false, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/guestrequest/service/GuestRequestService.cls:120-138 - only Pending rows; status/attempts computed
- base/main/default/classes/guestrequest/async/GuestRequestQueueable.cls:31, base/main/default/classes/guestrequest/async/GuestRequestSweepBatch.cls:48 - sole callers of process()
- Fundraising_GuestDonor has no Edit on Guest_Request__c

179. Vulnerability Name

FLS Update — `classes/guestrequest/service/GuestRequestService.cls:237` (R-044; FLS Update paths 25, 34, 39)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

180. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

181. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

This query looks for CRUD Update operations that are performed without checking for `isUpdateable()` permission before performing the Update operation on the Object and its fields. Flagged statement:

```
Database.update(resolving, false, AccessLevel.SYSTEM_MODE);
```

WHY THE CLAIM IS FALSE

The claim is false because the write closes the donor's own refund request only after the refund itself succeeded under the refund controller's `Process_Refunds` authorization; it selects rows by the refunded gift's Id and writes only a status, and the staff user is not granted Edit on the guest-request object by design, so a user-mode update would leave the portal showing a completed refund as pending.

SUPPORTING DETAIL

After staff refund a gift, this closes the donor's matching refund request that was parked for review so the donor portal stops showing it as pending. It runs only after the refund itself succeeded under the refund controller's own authorization, it selects requests by the refunded Opportunity Id and only those in `Awaiting_Review` of the refund type, and it writes a fixed status, a fixed donor-facing sentence and a timestamp. The request rows are created by the guest user and owned by the site's default owner, so an internal user generally has no sharing on them; system mode is what lets the refund close its own request.

LOCATION IN THE SUBMITTED SOURCE

```
classes/guestrequest/service/GuestRequestService.cls:237
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm (user-mode DML requires the running user's Edit permission on the object)
- https://help.salesforce.com/s/articleView?id=sf.perm_sets_custom.htm (custom permission `Process_Refunds` is the authorization the refund controller enforces; unverified exact URL)

182. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/GuestRequestService.cls:237
Database.update(resolving, false, AccessLevel.SYSTEM_MODE);
```

REPORTED DATAFLOW — FLS UPDATE, PATH 25 (ONE OF 25, 34, 39)

```
classes/GuestRequestService.cls:229 request.Processed_At__c = System.now();  
classes/GuestRequestService.cls:230 resolving.add(request);  
classes/GuestRequestService.cls:232 if (resolving.isEmpty()) { return 0; }  
classes/GuestRequestService.cls:237 Database.update(resolving, false, AccessLevel.SYSTEM_MODE);
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/RefundService.cls:352-357 - sole caller, constant status/message
- base/main/default/classes/guestrequest/service/GuestRequestService.cls:214-238 - filters to Awaiting_Review + type
- Fundraising_User has Edit but not View All on Guest_Request__c; Admin has Modify All - so the real blocker for a user-mode update is record sharing, not the object grant

183. Vulnerability Name

FLS Update — classes/setup/controller/PostInstallHandler.cls:409 (R-045; FLS Update paths 28)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

184. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

185. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

This query looks for CRUD Update operations that are performed without checking for isUpdateable() permission before performing the Update operation on the Object and its fields. Flagged statement: `if (!toUpdate.isEmpty()) { update as system toUpdate; }`

WHY THE CLAIM IS FALSE

The claim is false because the update runs only inside the InstallHandler as the package's system user, which holds no permission set, touches only the package's own theme records (selected by their packaged names) and writes a URL computed from the org's own site settings; no user input and no user permissions are involved.

SUPPORTING DETAIL

This backfills the default hero image URL on the package's own theme records during install or upgrade, limited to the packaged theme names. It runs only from the InstallHandler as the package's system user, which has no permission set, and the value is a URL the install step itself generated from a packaged static resource. No interactive or guest caller reaches it.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/controller/PostInstallHandler.cls:409

SOURCES

- https://help.salesforce.com/s/articleView?id=sf.apex_post_install_script.htm&language=en_US&type=5

186. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:409
if (!toUpdate.isEmpty()) { update as system toUpdate; }
```

REPORTED DATAFLOW — FLS UPDATE, PATH 28

```
classes/PostInstallHandler.cls:402 d.Default_Hero_Image_URL__c = s.Default_Hero_Image_URL__c;
classes/PostInstallHandler.cls:405 if (changed) { toUpdate.add(d); }
classes/PostInstallHandler.cls:409 if (!toUpdate.isEmpty()) { update as system toUpdate; }
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:18 `public without sharing class PostInstallHandler implements InstallHandler`; lines 1-4 header: 'runs in package install/upgrade context'
- base/main/default/classes/setup/controller/PostInstallHandler.cls:169-173 doc: 'the script runs as a per-package system user that does not exist before runtime'
- Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet)
- base/main/default/classes/setup/controller/PostInstallHandler.cls:183-186 `onInstall` calls each `seed*` step in its own `try/catch`; only `logStepFailure` on error
- `grep` of non-test classes: `seedDefaultSettings`, `seedDefaultImages`, `seedDefaultPageDesign`, `seedEventPricebook`, `seedEventDonationProduct`, `seedEventFeeProduct`, `seedContentTemplates` have NO callers outside `PostInstallHandler` (mentions in `PricebookService/SettingsService` are comments/strings only)
- Class is `public`, not `global` (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods
- base/main/default/classes/setup/controller/PostInstallHandler.cls:383-409 `seedDefaultImages`: copies the seeded default hero image URL from `Settings__c` onto `Campaign_Design__c.Default_Hero_Image_URL__c` for the packaged theme names only, and only when changed; the query is `WITH SYSTEM_MODE`
- Value originates from the packaged static-resource distribution URL seeded by `SettingsService.ensureDefaultImagesSeeded`, not user input

187. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/shared/CurrencyResolver.cls:265` (R-046; Apex SOQL SOSL USER MODE MISSING paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

188. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

189. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `Database.queryWithBinds(soql, new Map<String, Object>{ 'recordIds' => recordIds }, AccessLevel.SYSTEM_MODE),`

WHY THE CLAIM IS FALSE

The claim is false because the query reads only Id and CurrencyIsoCode for parent records whose Ids a trigger-driven rollup already holds, in order to convert amounts before writing the rollup total; the object name comes from the Id's schema token, not from input, and the read runs in trigger context as the DML writer, where a user without the parent's currency field would otherwise see the rollup silently fail.

SUPPORTING DETAIL

The query reads only Id and CurrencyIsoCode for parent records whose Ids the trigger-driven rollup already holds, so it can convert gift amounts into the parent's currency before writing the total. The object name comes from the Id's own schema token, not from input, so the dynamic FROM cannot be injected. The result is a map of Id to ISO code that is used in the arithmetic and never returned to a user. Running in user mode would make a rollup fail or mis-convert for a staff user who can save a gift but lacks read FLS on a standard CurrencyIsoCode field. The code catches any exception and falls back to the corporate currency.

LOCATION IN THE SUBMITTED SOURCE

`classes/shared/CurrencyResolver.cls:265`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

190. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CurrencyResolver.cls:265
Database.queryWithBinds(soql, new Map<String, Object>{ 'recordIds' => recordIds },
AccessLevel.SYSTEM_MODE),
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 1

```
classes/CurrencyResolver.cls:260 for (Id recordId : recordIds) { parentType =
recordId.getSObjectType(); break; }
```

```
classes/CurrencyResolver.cls:265 Database.queryWithBinds(soql, new Map<String, Object>{  
  'recordIds' => recordIds }, AccessLevel.SYSTEM_MODE),
```

EVIDENCE CHECKED

- base/main/default/classes/shared/CurrencyResolver.cls:258-269 - dynamic FROM built from `Id.getSObjectType().getDescribe().getName()`; bind is `Set<Id>`; `SYSTEM_MODE`; catch returns empty map
- base/main/default/classes/shared/CurrencyResolver.cls - `isoCodesByRecordId` doc states the reason (currency code is not customer data)
- base/main/default/classes/donation/selector/OpportunitiesSelector.cls:189 - upstream `SYSTEM_MODE` rollup read, itself commented

191. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/donor/selector/AccountsSelector.cls:311` (R-047; Apex SOQL SOSL USER MODE MISSING paths 2, 4)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

192. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

193. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `public List<Account> selectPersonDonorDetailById(Id accountId) {`

WHY THE CLAIM IS FALSE

The claim that USER_MODE is missing is false: the query is executed with `Database.queryWithBinds(..., AccessLevel.USER_MODE)`, which enforces the running user's object permissions, field-level security and sharing. The scanner recognises only the literal `WITH USER_MODE` clause, and adding that clause to this query is impossible: the platform rejects a dynamic query that carries both (measured: "Cannot use the WITH AccessLevel clause in dynamic queries that also specify an access level").

SUPPORTING DETAIL

This query already runs in user mode: it is executed with `Database.queryWithBinds(..., AccessLevel.USER_MODE)`, which enforces object permissions, field-level security and sharing for the running user. The scanner only recognises the literal `WITH USER_MODE` clause and does not read the `AccessLevel` argument. The caller, `DonorDetailController.requireDonor`, uses this user-mode, sharing-enforced read as its IDOR gate: if the record Id supplied by the component is not visible to the user, zero rows come back and the controller throws "Donor not found" before any related data is read. A literal `WITH USER_MODE` clause cannot be added to satisfy the pattern: the query is built by the FFLib query factory as a dynamic string, and the platform rejects a dynamic query that carries both the clause and an `AccessLevel` argument. Measured 2026-10-01 in a scratch org, running as a Standard User who holds the Fundraising_Admin permission set: `Database.queryWithBinds('SELECT Id FROM Account WITH USER_MODE', binds, AccessLevel.USER_MODE)` throws `System.SecurityException: Cannot use the WITH AccessLevel clause in dynamic queries that also specify an access level.` The `AccessLevel` argument is the documented way to run a dynamic query in user mode.

LOCATION IN THE SUBMITTED SOURCE

`classes/donor/selector/AccountsSelector.cls:311`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

194. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/AccountsSelector.cls:311
public List<Account> selectPersonDonorDetailById(Id accountId) {
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 2 (ONE OF 2, 4)

```
classes/FundraiserDetailController.cls:39 public static Map<String, Object> getRecurring(Id
campaignId, Integer pageSize, Integer offset) {
classes/FundraiserDetailController.cls:40 return new GetRecurring(campaignId, pageSize,
offset).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/DonorDetailController.cls:215 Donor d = requireDonor(donorId);
classes/DonorDetailController.cls:352 private static Donor requireDonor(Id donorId) {
classes/DonorDetailController.cls:359 .selectPersonDonorDetailById(donorId);
classes/AccountsSelector.cls:311 public List<Account> selectPersonDonorDetailById(Id accountId) {
```

EVIDENCE CHECKED

- base/main/default/classes/donor/selector/AccountsSelector.cls:311~~322 - Database.queryWithBinds(..., AccessLevel.USER_MODE); class is inherited sharing
- base/main/default/classes/donor/controller/DonorDetailController.cls:352 - requireDonor calls the Account/Contact detail selector and throws QueryException("Donor not found") on an empty result
- base/main/default/classes/donor/controller/DonorDetailController.cls:102,142,176,205,238,272 - every @AuraEnabled action calls requireDonor before any other read
- base/main/default/classes/donor/controller/DonorDetailController.cls header - documents requireDonor as the gate in front of the SYSTEM_MODE reads of Donation_Designation__c and Guest_Request__c
- base/main/default/classes/campaign/controller/FundraiserDetailController.cls:39 - getRecurring never calls AccountsSelector; Checkmarx path 4/6 source is spurious

195. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/donor/selector/ContactsSelector.cls:228` (R-048; Apex SOQL SOSL USER MODE MISSING paths 3, 5)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

196. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

197. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `public List<Contact> selectDonorDetailById(Id contactId) {`

WHY THE CLAIM IS FALSE

The claim that USER_MODE is missing is false: the query factory is built with CRUD and FLS enforcement on and the SOQL is executed with `Database.queryWithBinds(..., AccessLevel.USER_MODE)`, which enforces object permissions, FLS and sharing for the running user. The scanner recognises only the literal `WITH USER_MODE` clause, which the platform forbids in a dynamic query that already specifies an access level (measured).

SUPPORTING DETAIL

The SOQL string is built by the query factory and executed with `Database.queryWithBinds(..., AccessLevel.USER_MODE)`, so object permissions, FLS and sharing are enforced for the running user. The factory is also constructed with CRUD enforcement on. The scanner does not recognise the `AccessLevel` argument. The only caller that passes a client-supplied Id is `DonorDetailController.requireDonor`, which throws "Donor not found" when this user-mode read returns nothing, so a user cannot reach another donor's gifts, recurring plans or requests by guessing an Id. A literal `WITH USER_MODE` clause cannot be added to satisfy the pattern: the query is built by the `FFLib` query factory as a dynamic string, and the platform rejects a dynamic query that carries both the clause and an `AccessLevel` argument. Measured 2026-10-01 in a scratch org, running as a Standard User who holds the `Fundraising_Admin` permission set: `Database.queryWithBinds('SELECT Id FROM Account WITH USER_MODE', binds, AccessLevel.USER_MODE)` throws `System.SecurityException: Cannot use the WITH AccessLevel clause in dynamic queries that also specify an access level.` The `AccessLevel` argument is the documented way to run a dynamic query in user mode.

LOCATION IN THE SUBMITTED SOURCE

`classes/donor/selector/ContactsSelector.cls:228`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

198. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ContactsSelector.cls:228  
public List<Contact> selectDonorDetailById(Id contactId) {
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 3 (ONE OF 3, 5)

```
classes/FundraiserDetailController.cls:39 public static Map<String, Object> getRecurring(Id  
campaignId, Integer pageSize, Integer offset) {  
classes/FundraiserDetailController.cls:40 return new GetRecurring(campaignId, pageSize,  
offset).run();  
classes/ControllerAction.cls:52 Object result = doExecute();  
classes/DonorDetailController.cls:215 Donor d = requireDonor(donorId);  
classes/DonorDetailController.cls:352 private static Donor requireDonor(Id donorId) {  
classes/DonorDetailController.cls:371 .selectDonorDetailById(donorId);  
classes/ContactsSelector.cls:228 public List<Contact> selectDonorDetailById(Id contactId) {
```

EVIDENCE CHECKED

- base/main/default/classes/donor/selector/ContactsSelector.cls:228--242 - newQueryFactory() (fflib defaults enforceCRUD=true) then queryWithBinds with AccessLevel.USER_MODE
- base/main/default/classes/donor/controller/DonorDetailController.cls:352 - requireDonor gate; empty result -> QueryException
- base/main/default/classes/donor/controller/DonorDetailController.cls:102,142,176,205,238,272 - every action gated by requireDonor first
- base/main/default/classes/campaign/controller/FundraiserDetailController.cls:39 - getRecurring uses RecurringDonationsSelector.selectByCampaignPaged, not ContactsSelector

199. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — classes/setup/service/CommunityService.cls:269 (R-049; Apex SOQL SOSL USER MODE MISSING paths 6, 8)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

200. Detected By

☐ Chimera

☐ PMD

☐ Security Review

☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

201. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER’S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: protected virtual List<NetworkRow> queryNetworkById(String networkId) {

WHY THE CLAIM IS FALSE

The claim is false because the read returns only the Experience site's Id, name, URL prefix and status, org configuration rather than record data, and is reachable only from the administrator-only setup console; Network is a setup object, and a user-mode read of setup objects requires View Setup and Configuration, which the package's admin permission set cannot assume every administrator holds.

SUPPORTING DETAIL

This read resolves the Experience Cloud site that the administrator is configuring. It returns only the Network's Id, name, URL prefix and status, which are org configuration and not record data. It is reachable only from the package's setup console, whose controller is granted solely by the admin permission set. Network visibility in user mode is limited to sites the user is a member of, unless the user holds Create and Set Up Experiences, View All Data or Modify All Data. The admin must be able to resolve a site they are about to repoint the package at, including one still in Preview. The Id binds as a variable, and the query sits in a try/catch that reports "site not found" instead of exposing an error.

LOCATION IN THE SUBMITTED SOURCE

classes/setup/service/CommunityService.cls:269

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_network.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

202. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

classes/CommunityService.cls:269
protected virtual List<NetworkRow> queryNetworkById(String networkId) {

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 6 (ONE OF 6, 8)

```

classes/SetupController.cls:632 public static Map<String, Object> saveExperienceSite(String
networkId, String siteUrl) {
classes/SetupController.cls:633 return new SaveExperienceSite(networkId, siteUrl).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2788
withEnablementFlag(commUNITYServiceInstance.resolveByNetworkId(networkId));
classes/CommunityService.cls:242 public virtual Map<String, Object> resolveByNetworkId(String
networkId) {
classes/CommunityService.cls:252 List<NetworkRow> networks = queryNetworkById(networkId);
classes/CommunityService.cls:269 protected virtual List<NetworkRow> queryNetworkById(String
networkId) {

```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:269-277 - Database.query with AccessLevel.SYSTEM_MODE; bind variable, not concatenation
- base/main/default/classes/setup/service/CommunityService.cls:251-266 - resolveByNetworkId wraps it in try/catch and logs via AppLogger.info
- base/main/default/classes/setup/controller/SetupController.cls:632,642 - saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller
- base/main/default/permissionsets - only Fundraising_Admin grants classAccess to SetupController; Fundraising_User/ReadOnly deliberately omit it
- base/main/default/classes/setup/service/CommunityService.cls:6-13 - public virtual without sharing; header rationale: User is the only record-shared read; Network and the other setup objects carry per-site SYSTEM_MODE reasons
- https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_network.htm - special access rules: users with Create and Set Up Experiences / View All Data / Modify All Data see all Network rows; others see only sites they are members of

203. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/setup/service/CommunityService.cls:328` (R-050; Apex SOQL SOSL USER MODE MISSING paths 10)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

204. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

205. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `List<PermissionSetAssignment> assignments = [`

WHY THE CLAIM IS FALSE

The claim is false because the read is a diagnostic over `PermissionSetAssignment`, a setup object with no sharing model, returning only a boolean and a remediation message to the administrator-only setup console; the guest user Id is resolved on the server, and a user-mode read would require View Setup and Configuration, which the package cannot grant.

SUPPORTING DETAIL

This is a read-only diagnostic in the admin setup console. It checks whether the site's guest user has been assigned the package's guest permission set and returns only a boolean and a remediation message. The guest user Id is resolved on the server from the selected site, not taken from the client. No record data is returned, and the read is wrapped in a try/catch that degrades to 'could not verify'. `PermissionSetAssignment` is a setup object whose visibility is governed by View Setup and Configuration rather than record sharing, which the package's admin permission set does not grant; the read stays in system mode so an administrator without it gets a true answer. The site carries its own `SYSTEM_MODE` comment stating this.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/CommunityService.cls:328`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_permissionsetassignment.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm
- <https://developer.salesforce.com/blogs/2021/05/boost-security-by-auditing-your-privileged-users-with-soql>

206. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CommunityService.cls:328
List<PermissionSetAssignment> assignments = [
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 10

```
classes/SetupController.cls:642 public static Map<String, Object> checkGuestPermissionSet(String
networkId) {
classes/SetupController.cls:643 return new CheckGuestPermissionSet(networkId).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2811 Map<String, Object> result =
communityServiceInstance.checkGuestPermissionSet(networkId);
classes/CommunityService.cls:300 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService_Test.cls:509 return guestUserId;
classes/CommunityService.cls:300 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService.cls:305 Boolean assigned = queryGuestPermSetAssigned(guestUserId);
classes/CommunityService.cls:324 protected virtual Boolean queryGuestPermSetAssigned(Id
guestUserId) {
classes/CommunityService.cls:330 WHERE AssigneeId = :guestUserId AND PermissionSet.Name =
'Fundraising_GuestDonor'
classes/CommunityService.cls:328 List<PermissionSetAssignment> assignments = [
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:325-331 - per-site `// SYSTEM_MODE:` comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method)
- Every SYSTEM_MODE query and DML statement in the package carries a `// SYSTEM_MODE:` reason comment directly at the call site (`grep -rn 'SYSTEM_MODE' base/main/default/classes` shows the comment above each use); for this statement it is at :325-331.
- SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin

207. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/setup/service/CommunityService.cls:569` (R-051; Apex SOQL SOSL USER MODE MISSING paths 11)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

208. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

209. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `for (PermissionSetAssignment psa : [`

WHY THE CLAIM IS FALSE

The claim is false because the read checks the guest user's permission-set assignments for a standard-object grant the administrator must add by hand and returns only a boolean to the administrator-only setup console; the objects are setup objects with no sharing model, and a user-mode read would require View Setup and Configuration, which the package cannot grant.

SUPPORTING DETAIL

This read-only check verifies that the site guest user has read/create on User External Credential, a standard-object grant the admin must add by hand because a 2GP permission set cannot carry it. The method returns only a boolean for the setup console checklist. The guest user Id is derived on the server, the read never runs as or for a guest request, and failures degrade to a 'check manually' message. The reads are setup data governed by View Setup and Configuration, so they stay in system mode; each carries its own SYSTEM_MODE comment.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/CommunityService.cls:569`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_permissionsetassignment.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

210. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CommunityService.cls:569
for (PermissionSetAssignment psa : [
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 11

```
classes/SetupController.cls:642 public static Map<String, Object> checkGuestPermissionSet(String
networkId) {
```

```

classes/SetupController.cls:643 return new CheckGuestPermissionSet(networkId).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2811 Map<String, Object> result =
communityServiceInstance.checkGuestPermissionSet(networkId);
classes/SetupController.cls:2812 result.put('stripeCredential',
communityServiceInstance.checkStripeCredentialAccess(networkId));
classes/CommunityService.cls:456 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService_Test.cls:509 return guestUserId;
classes/CommunityService.cls:456 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService.cls:523 Boolean objGranted =
queryGuestUserExternalCredentialAccess(guestUserId);
classes/CommunityService.cls:564 protected virtual Boolean
queryGuestUserExternalCredentialAccess(Id guestUserId) {
classes/CommunityService.cls:571 WHERE AssigneeId = :guestUserId
classes/CommunityService.cls:569 for (PermissionSetAssignment psa : [

```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:566-583 - per-site `// SYSTEM_MODE:` comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method)
- Every SYSTEM_MODE query and DML statement in the package carries a `// SYSTEM_MODE:` reason comment directly at the call site (`grep -rn 'SYSTEM_MODE' base/main/default/classes` shows the comment above each use); for this statement it is at :566-568.
- SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin

211. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/setup/service/CommunityService.cls:608` (R-052; Apex SOQL SOSL USER MODE MISSING paths 12)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

212. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

213. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `for (SetupEntityAccess a : [`

WHY THE CLAIM IS FALSE

The claim is false because the read is over `SetupEntityAccess`, a setup object with no sharing model, returning only permission-set Ids used for an in-memory comparison in the administrator-only setup console; a user-mode read would require View Setup and Configuration, which the package's admin permission set cannot grant.

SUPPORTING DETAIL

This read-only check finds which permission sets grant access to the Stripe external credential's principal, so the setup console can tell the admin whether the guest user can make the payment callout. It returns only permission-set Ids used for an in-memory set intersection, never record data. `SetupEntityAccess` is a setup object whose visibility is governed by View Setup and Configuration, which the admin permission set does not grant, so the read stays in system mode. The inputs are resolved on the server, the call is reachable only from the admin-only setup controller, and the site carries its own `SYSTEM_MODE` comment.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/CommunityService.cls:608`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_setupentityaccess.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

214. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CommunityService.cls:608
for (SetupEntityAccess a : [
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 12

```
classes/SetupController.cls:642 public static Map<String, Object> checkGuestPermissionSet(String
networkId) {
classes/SetupController.cls:643 return new CheckGuestPermissionSet(networkId).run();
```

```

classes/ControllerAction.cls:52  Object result = doExecute();
classes/SetupController.cls:2811 Map<String, Object> result =
communityServiceInstance.checkGuestPermissionSet(networkId);
classes/SetupController.cls:2812 result.put('stripeCredential',
communityServiceInstance.checkStripeCredentialAccess(networkId));
classes/CommunityService.cls:473 Set<Id> principalIds = queryStripePrincipalIds();
classes/CommunityService_Test.cls:657 return principalIds;
classes/CommunityService.cls:473 Set<Id> principalIds = queryStripePrincipalIds();
classes/CommunityService.cls:474 Boolean precise = !principalIds.isEmpty();
classes/CommunityService.cls:488 ? queryGrantingPermSetIds(principalIds)
classes/CommunityService.cls:603 protected virtual Set<Id> queryGrantingPermSetIds(Set<Id>
principalIds) {
classes/CommunityService.cls:610 WHERE SetupEntityId IN :principalIds AND SetupEntityType =
'ExternalCredentialParameter'
classes/CommunityService.cls:608 for (SetupEntityAccess a : [

```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:605-611 - per-site `// SYSTEM_MODE:` comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method)
- Every SYSTEM_MODE query and DML statement in the package carries a `// SYSTEM_MODE:` reason comment directly at the call site (`grep -rn 'SYSTEM_MODE' base/main/default/classes` shows the comment above each use); for this statement it is at :605-607.
- SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin

215. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/setup/service/CommunityService.cls:407` (R-053; Apex SOQL SOSL USER MODE MISSING paths 13)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

216. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

217. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `for (PermissionSetAssignment psa : [`

WHY THE CLAIM IS FALSE

The claim is false because the read counts ObjectPermissions rows on the guest user's permission sets and returns only a boolean to the administrator-only setup console; both are setup objects with no sharing model, and a user-mode read would require View Setup and Configuration, which the package's admin permission set cannot grant.

SUPPORTING DETAIL

This read-only check powers the setup console's 'guest user can read Campaign' step. It reads the guest user's permission-set assignments and counts ObjectPermissions rows granting Campaign read, returning only a boolean so the admin knows whether the documented manual grant is done (a managed package cannot ship that grant on a standard object). No record data leaves the method and the user Id is derived on the server. Both reads are setup data governed by View Setup and Configuration, which the admin permission set does not grant, so they stay in system mode; each carries its own SYSTEM_MODE comment.

LOCATION IN THE SUBMITTED SOURCE

`classes/setup/service/CommunityService.cls:407`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_permissionsetassignment.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

218. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CommunityService.cls:407
for (PermissionSetAssignment psa : [
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 13

```
classes/SetupController.cls:642 public static Map<String, Object> checkGuestPermissionSet(String
networkId) {
```

```

classes/SetupController.cls:643 return new CheckGuestPermissionSet(networkId).run();
classes/ControllerAction.cls:52 Object result = doExecute();
classes/SetupController.cls:2811 Map<String, Object> result =
communityServiceInstance.checkGuestPermissionSet(networkId);
classes/SetupController.cls:2812 result.put('stripeCredential',
communityServiceInstance.checkStripeCredentialAccess(networkId));
classes/SetupController.cls:2813 result.put('objectAccess',
communityServiceInstance.checkGuestObjectAccess(networkId));
classes/CommunityService.cls:375 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService_Test.cls:650 return guestUserId;
classes/CommunityService.cls:375 Id guestUserId = resolveGuestUserId(networkId);
classes/CommunityService.cls:379 Boolean canRead = queryGuestCampaignRead(guestUserId);
classes/CommunityService.cls:402 protected virtual Boolean queryGuestCampaignRead(Id guestUserId)
{
classes/CommunityService.cls:409 WHERE AssigneeId = :guestUserId
classes/CommunityService.cls:407 for (PermissionSetAssignment psa : [

```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:404-418 - per-site `// SYSTEM_MODE:` comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method)
- Every SYSTEM_MODE query and DML statement in the package carries a `// SYSTEM_MODE:` reason comment directly at the call site (`grep -rn 'SYSTEM_MODE' base/main/default/classes` shows the comment above each use); for this statement it is at :404-406.
- SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin

219. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/event/service/EventPurchaseService_Test.cls:906` (R-054; Apex SOQL SOSL USER MODE MISSING paths 17)

Meant for the Internal Salesforce Security Team

<i>Final Comment from Salesforce Team</i>	
<i>Date of Review (YYYY-MM-DD)</i>	
<i>Result</i>	

220. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

221. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `delete as system tier;`

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture delete inside an `@IsTest` class, which no user can invoke at runtime, and must succeed under whatever user the subscriber's org-wide test run executes as; it is also DML, not a query, so the SOQL/SOSL rule does not apply.

SUPPORTING DETAIL

This is a fixture write inside an `@IsTest` class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService_Test.cls:906`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

222. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService_Test.cls:906
delete as system tier;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 17

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectTypeDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:779
```

```

.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780 Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782 return p;
classes/TestDataFactory.cls:794 t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796 return t;
classes/EventPurchaseService_Test.cls:42 return TestDataFactory.createLinkedTicketTier(campaignId,
new Map<String, Object>{
classes/EventPurchaseService_Test.cls:903 Event_Ticket_Type__c tier = makeTier(camp.Id, 100, 25,
200, 0);
classes/EventPurchaseService_Test.cls:906 delete as system tier;

```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/event/service/EventPurchaseService_Test.cls:906 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

223. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/event/service/EventPurchaseService_Test.cls:261` (R-055; Apex SOQL SOSL USER MODE MISSING paths 18)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

224. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

225. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `update as system tier;`

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture write inside an `@IsTest` class, which no user can invoke at runtime, and must succeed under whatever user the subscriber's org-wide test run executes as; it is also DML, not a query, so the SOQL/SOSL rule does not apply.

SUPPORTING DETAIL

This is a fixture write inside an `@IsTest` class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService_Test.cls:261`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

226. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService_Test.cls:261
update as system tier;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 18

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:779
```

```

.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780 Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782 return p;
classes/TestDataFactory.cls:794 t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796 return t;
classes/EventPurchaseService_Test.cls:42 return TestDataFactory.createLinkedTicketTier(campaignId,
new Map<String, Object>{
classes/EventPurchaseService_Test.cls:258 Event_Ticket_Type__c tier = makeTier(camp.Id, 100, 25,
200, 0);
classes/EventPurchaseService_Test.cls:260 tier.Price__c = 150;
classes/EventPurchaseService_Test.cls:261 update as system tier;

```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/event/service/EventPurchaseService_Test.cls:261 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

227. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/event/service/EventPurchaseService_Test.cls:578` (R-056; Apex SOQL SOSL USER MODE MISSING paths 19)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

228. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

229. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `update as system tier;`

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture write inside an `@IsTest` class, which no user can invoke at runtime, and must succeed under whatever user the subscriber's org-wide test run executes as; it is also DML, not a query, so the SOQL/SOSL rule does not apply.

SUPPORTING DETAIL

This is a fixture write inside an `@IsTest` class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService_Test.cls:578`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

230. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService_Test.cls:578
update as system tier;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 19

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectTypeDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:779
```

```

.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780 Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782 return p;
classes/TestDataFactory.cls:794 t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796 return t;
classes/EventPurchaseService_Test.cls:42 return TestDataFactory.createLinkedTicketTier(campaignId,
new Map<String, Object>{
classes/EventPurchaseService_Test.cls:576 Event_Ticket_Type__c tier = makeTier(camp.Id, 100, 25,
200, 0);
classes/EventPurchaseService_Test.cls:577 tier.Deductible_Percentage__c = 60; // 60% deductible
→ 40% non-deductible
classes/EventPurchaseService_Test.cls:578 update as system tier;

```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/event/service/EventPurchaseService_Test.cls:578 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

231. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/event/service/EventPurchaseService_Test.cls:610` (R-057; Apex SOQL SOSL USER MODE MISSING paths 20)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

232. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

233. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `update as system tier;`

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture write inside an `@IsTest` class, which no user can invoke at runtime, and must succeed under whatever user the subscriber's org-wide test run executes as; it is also DML, not a query, so the SOQL/SOSL rule does not apply.

SUPPORTING DETAIL

This is a fixture write inside an `@IsTest` class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService_Test.cls:610`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

234. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService_Test.cls:610
update as system tier;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 20

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:779
```

```

.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780 Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782 return p;
classes/TestDataFactory.cls:794 t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796 return t;
classes/EventPurchaseService_Test.cls:42 return TestDataFactory.createLinkedTicketTier(campaignId,
new Map<String, Object>{
classes/EventPurchaseService_Test.cls:608 Event_Ticket_Type__c tier = makeTier(camp.Id, 100, null,
200, 0);
classes/EventPurchaseService_Test.cls:609 tier.Deductible_Percentage__c = null; // never
configured for the mode this org runs
classes/EventPurchaseService_Test.cls:610 update as system tier;

```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/event/service/EventPurchaseService_Test.cls:610 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

235. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/event/service/EventPurchaseService_Test.cls:641` (R-058; Apex SOQL SOSL USER MODE MISSING paths 21)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

236. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

237. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `update as system tier;`

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture write inside an `@IsTest` class, which no user can invoke at runtime, and must succeed under whatever user the subscriber's org-wide test run executes as; it is also DML, not a query, so the SOQL/SOSL rule does not apply.

SUPPORTING DETAIL

This is a fixture write inside an `@IsTest` class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService_Test.cls:641`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

238. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService_Test.cls:641
update as system tier;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 21

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:779
```

```

.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780 Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782 return p;
classes/TestDataFactory.cls:794 t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796 return t;
classes/EventPurchaseService_Test.cls:42 return TestDataFactory.createLinkedTicketTier(campaignId,
new Map<String, Object>{
classes/EventPurchaseService_Test.cls:639 Event_Ticket_Type__c tier = makeTier(camp.Id, 100, 25,
200, 0);
classes/EventPurchaseService_Test.cls:640 tier.Deductible_Percentage__c = null;
classes/EventPurchaseService_Test.cls:641 update as system tier;

```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/event/service/EventPurchaseService_Test.cls:641 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

239. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/event/service/EventPurchaseService_Test.cls:672` (R-059; Apex SOQL SOSL USER MODE MISSING paths 22)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

240. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

241. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `update as system tier;`

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture write inside an `@IsTest` class, which no user can invoke at runtime, and must succeed under whatever user the subscriber's org-wide test run executes as; it is also DML, not a query, so the SOQL/SOSL rule does not apply.

SUPPORTING DETAIL

This is a fixture write inside an `@IsTest` class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

`classes/event/service/EventPurchaseService_Test.cls:672`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

242. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventPurchaseService_Test.cls:672
update as system tier;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 22

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:779
```

```

.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780 Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782 return p;
classes/TestDataFactory.cls:794 t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796 return t;
classes/EventPurchaseService_Test.cls:42 return TestDataFactory.createLinkedTicketTier(campaignId,
new Map<String, Object>{
classes/EventPurchaseService_Test.cls:670 Event_Ticket_Type__c tier = makeTier(camp.Id, 100, null,
200, 0);
classes/EventPurchaseService_Test.cls:671 tier.Deductible_Percentage__c = 0;
classes/EventPurchaseService_Test.cls:672 update as system tier;

```

EVIDENCE CHECKED

- base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/event/service/EventPurchaseService_Test.cls:672 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

243. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING —
classes/fundraising/controller/EventRegistrationController_Test.cls:171 (R-060; Apex SOQL SOSL USER MODE MISSING paths 23)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

244. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

245. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: update as system t;

WHY THE CLAIM IS FALSE

The claim is false because the statement is a fixture update inside an @IsTest class, which cannot run outside Apex test execution and must succeed under whatever user the subscriber's org-wide test run executes as; it is DML, not a query, so the SOQL/SOSL rule does not apply, and the reported dataflow source is a schema describe, not user input.

SUPPORTING DETAIL

This line is a test-fixture update inside an @IsTest class. It prepares a ticket product so the controller method under test sees a particular state. It cannot run outside Apex test execution. The dataflow source is a schema describe. The statement stays in system mode on purpose: the package's tests are also run in subscriber orgs (an org-wide test run there includes managed-package tests), where the running user may lack a permission the fixture would need in user mode (edit access to Campaign, the master of the ticket-type object, which the platform ties to the Marketing User flag). A user-mode fixture would fail the subscriber's test run for a reason unrelated to the behaviour under test, while protecting nothing, because a test class has no runtime caller.

LOCATION IN THE SUBMITTED SOURCE

classes/fundraising/controller/EventRegistrationController_Test.cls:171

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_annotation_isTest.htm

246. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventRegistrationController_Test.cls:171
update as system t;
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 23

```
classes/TestDataFactory.cls:778 Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
```

```

classes/TestDataFactory.cls:779
.getRecordTypeInfoByDeveloperName().get('Event_Ticket_Type').getRecordTypeId();
classes/TestDataFactory.cls:778  Id rtId =
Product2.SObjectType.getDescribe(SObjectDescribeOptions.DEFERRED)
classes/TestDataFactory.cls:780  Product2 p = new Product2(Name = name, IsActive = true,
RecordTypeId = rtId);
classes/TestDataFactory.cls:782  return p;
classes/TestDataFactory.cls:794  t.Product2__c = createTicketProduct('Tier ' + t.Price__c).Id;
classes/TestDataFactory.cls:796  return t;
classes/EventRegistrationController_Test.cls:98  return
TestDataFactory.createLinkedTicketTier(campaignId, new Map<String, Object>{
classes/EventRegistrationController_Test.cls:169  Event_Ticket_Type__c t = makeTier(camp.Id, 100,
50, 0);
classes/EventRegistrationController_Test.cls:170  t.Sale_Start_Date__c = Datetime.now().addDays(1);
classes/EventRegistrationController_Test.cls:171  update as system t;

```

EVIDENCE CHECKED

- base/main/default/classes/fundraising/controller/EventRegistrationController_Test.cls:1 - class annotated @IsTest(SeeAllData=false)
- base/main/default/classes/shared/TestDataFactory.cls:743 - the dataflow source is the Product2 record-type describe in TestDataFactory.createTicketProduct (:741), a test fixture helper
- base/main/default/classes/fundraising/controller/EventRegistrationController_Test.cls:171 - fixture update of a test ticket product; DML, not SOQL

247. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/donation/selector/ReceiptSequenceSelector.cls:63` (R-061; Apex SOQL SOSL USER MODE MISSING paths 24–26, 29)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

248. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

249. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `return (List<Receipt_Sequence__c>) Database.queryWithBinds(`

WHY THE CLAIM IS FALSE

The claim is false because the row is an internal per-tax-year receipt counter holding only a year and the last number issued, not donor data; the FOR UPDATE lock keeps receipt numbers gapless, and the read must succeed from the guest finalize path and the renewal job, neither of whose running users can be granted the object.

SUPPORTING DETAIL

`Receipt_Sequence__c` is an internal per-tax-year counter row, not donor data. It holds only a year and the last receipt number issued. The query locks the counter (FOR UPDATE) so receipt numbers stay gapless and unique. Access must not depend on the running user, because a user without read access on the counter would otherwise break receipt numbering for their own gift. The only bind is a set of tax years derived from the Opportunity close date; no caller-supplied Id or filter reaches the query, and nothing from the counter row is returned to a UI.

LOCATION IN THE SUBMITTED SOURCE

`classes/donation/selector/ReceiptSequenceSelector.cls:63`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

250. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReceiptSequenceSelector.cls:63
return (List<Receipt_Sequence__c>) Database.queryWithBinds(
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 24 (ONE OF 24–26, 29)

```
classes/DonationService.cls:499 Id donationRtId = RecordTypeService.getRecordTypeId('Opportunity',
'Donation');
classes/RecordTypeService.cls:36 if (RT_ID_CACHE.containsKey(cacheKey)) {
classes/RecordTypeService.cls:37 return RT_ID_CACHE.get(cacheKey);
classes/DonationService.cls:499 Id donationRtId = RecordTypeService.getRecordTypeId('Opportunity',
'Donation');
```

```

classes/DonationService.cls:525 if (donationRtId != null) { opp.RecordTypeId = donationRtId; }
classes/DonationService.cls:538 .assign(new List<Opportunity>{ opp }, uow);
classes/ReceiptNumberService.cls:38 public void assign(List<Opportunity> opps,
fflib_ISObjectUnitOfWork uow) {
classes/ReceiptNumberService.cls:39 if (opps == null || opps.isEmpty() || uow == null) { return; }
classes/ReceiptNumberService.cls:44 for (Opportunity opp : opps) {
classes/ReceiptNumberService.cls:50 pendingByYear.get(year).add(opp);
classes/ReceiptNumberService.cls:52 if (pendingByYear.isEmpty()) { return; }
classes/ReceiptNumberService.cls:54 Map<Integer, Receipt_Sequence__c> counters =
lockCounters(pendingByYear.keySet(), uow);
classes/ReceiptNumberService.cls:101 Set<Integer> years, fflib_ISObjectUnitOfWork uow
classes/ReceiptNumberService.cls:107 for (Receipt_Sequence__c row :
selector.selectByTaxYearsForUpdate(years)) {
classes/ReceiptSequenceSelector.cls:50 public List<Receipt_Sequence__c>
selectByTaxYearsForUpdate(Set<Integer> taxYears) {
classes/ReceiptSequenceSelector.cls:51 if (taxYears == null || taxYears.isEmpty()) { return new
List<Receipt_Sequence__c>(); }
classes/ReceiptSequenceSelector.cls:55 for (Integer y : taxYears) {
classes/ReceiptSequenceSelector.cls:56 if (y != null) { years.add((Decimal) y); }
classes/ReceiptSequenceSelector.cls:58 if (years.isEmpty()) { return new List<Receipt_Sequence__c>
(); }
classes/ReceiptSequenceSelector.cls:64 soql, new Map<String, Object>{ 'years' => years },
AccessLevel.SYSTEM_MODE
classes/ReceiptSequenceSelector.cls:63 return (List<Receipt_Sequence__c>) Database.queryWithBinds(

```

EVIDENCE CHECKED

- base/main/default/classes/donation/selector/ReceiptSequenceSelector.cls:60-65 - SYSTEM_MODE queryWithBinds, FOR UPDATE, bind is Set<Decimal> of tax years
- base/main/default/classes/donation/service/ReceiptNumberService.cls - lockCounters/assignWithoutUnitOfWork are the only callers; class is inherited sharing
- base/main/default/classes/donation/domain/Opportunities.cls:284-296 - stampOfflineReceiptNumber (before trigger, with sharing domain) calls assignWithoutUnitOfWork for manually entered Closed Won gifts; this runs as the interactive user, not in batch
- base/main/default/objects/Receipt_Sequence__c - sharingModel ReadWrite; Fundraising_Admin CRU+ViewAll, Fundraising_User and ReadOnly Read only (User cannot create a counter, so USER_MODE would break the offline-gift path for staff)
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm - USER_MODE with no object access throws a QueryException rather than returning zero rows

251. Vulnerability Name

Apex SOQL SOSL USER MODE MISSING — `classes/shared/CurrencyResolver.cls:264` (R-062; Apex SOQL SOSL USER MODE MISSING paths 28)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

252. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

253. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

USER_MODE is recommended for SOQL or SOSL operations Flagged statement: `return toIsoMap(`

WHY THE CLAIM IS FALSE

The claim is false because the query reads only Id and CurrencyIsoCode for parent records whose Ids a trigger-driven rollup already holds, in order to convert amounts before writing the rollup total; the object name comes from the Id's schema token, not from input, and the read runs in trigger context as the DML writer, where a user without the parent's currency field would otherwise see the rollup silently fail.

SUPPORTING DETAIL

The query reads only Id and CurrencyIsoCode for parent records whose Ids the trigger-driven rollup already holds, so it can convert gift amounts into the parent's currency before writing the total. The object name comes from the Id's own schema token, not from input, so the dynamic FROM cannot be injected. The result is a map of Id to ISO code that is used in the arithmetic and never returned to a user. Running in user mode would make a rollup fail or mis-convert for a staff user who can save a gift but lacks read FLS on a standard CurrencyIsoCode field. The code catches any exception and falls back to the corporate currency.

LOCATION IN THE SUBMITTED SOURCE

`classes/shared/CurrencyResolver.cls:264`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm

254. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CurrencyResolver.cls:264
return toIsoMap(
```

REPORTED DATAFLOW — APEX SOQL SOSL USER MODE MISSING, PATH 28

```
classes/OpportunitiesSelector.cls:189 for (Opportunity opp : (List<Opportunity>)
Database.queryWithBinds(
classes/OpportunitiesSelector.cls:191 if (opp.ContactId != null) { contactByOpp.put(opp.Id,
opp.ContactId); }
```

```

classes/OpportunitiesSelector.cls:193 return contactByOpp;
classes/Opportunities.cls:394 return sel.selectDonorContactIdsByIds(unresolved);
classes/Opportunities.cls:362 Map<Id, Id> derivedContacts = resolveDerivedContactIds(opp);
classes/Opportunities.cls:367 Id donorContactId = opp.ContactId != null ? opp.ContactId :
derivedContacts.get(opp.Id);
classes/Opportunities.cls:369 contactIds.add(donorContactId);
classes/Opportunities.cls:374 if (contactIds.isEmpty() && accountIds.isEmpty()) { return; }
classes/Opportunities.cls:376 if (!contactIds.isEmpty()) { svc.rollupDonorSummary(contactIds); }
classes/CampaignService.cls:1710 public void rollupDonorSummary(Set<Id> contactIds) {
classes/CampaignService.cls:1711 if (contactIds == null || contactIds.isEmpty()) { return; }
classes/CampaignService.cls:1726 Map<Id, String> isoById =
CurrencyResolver.isoCodesByRecordId(contactIds);
classes/CurrencyResolver.cls:257 public static Map<Id, String> isoCodesByRecordId(Set<Id>
recordIds) {
classes/CurrencyResolver.cls:258 if (recordIds == null || recordIds.isEmpty() ||
!isMultiCurrency()) { return new Map<Id, String>(); }
classes/CurrencyResolver.cls:260 for (Id recordId : recordIds) { parentType =
recordId.getSObjectType(); break; }
classes/CurrencyResolver.cls:265 Database.queryWithBinds(soql, new Map<String, Object>{
'recordIds' => recordIds }, AccessLevel.SYSTEM_MODE),
classes/CurrencyResolver.cls:274 private static Map<Id, String> toIsoMap(List<SObject> rows,
String isoField) {
classes/CurrencyResolver.cls:276 for (SObject row : rows) { byId.put((Id) row.get('Id'), (String)
row.get(isoField)); }
classes/CurrencyResolver.cls:277 return byId;
classes/CurrencyResolver.cls:264 return toIsoMap(

```

EVIDENCE CHECKED

- base/main/default/classes/shared/CurrencyResolver.cls:258-269 - dynamic FROM built from Id.getSObjectType().getDescribe().getName(); bind is Set<Id>; SYSTEM_MODE; catch returns empty map
- base/main/default/classes/shared/CurrencyResolver.cls - isoCodesByRecordId doc states the reason (currency code is not customer data)
- base/main/default/classes/donation/selector/OpportunitiesSelector.cls:189 - upstream SYSTEM_MODE rollup read, itself commented

255. Vulnerability Name

Sharing — classes/recurring/selector/RecurringDonationsSelector.cls:11 (R-063; Sharing paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

256. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

257. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class RecurringDonationsSelector extends fflib_SObjectSelector
```

WHY THE CLAIM IS FALSE

The claim is false because `inherited sharing` is the documented mode for a class that is never an entry point: the selector takes the sharing of its caller, so a staff request is sharing-enforced and only the guest and job callers, which declare `without sharing` with a stated reason, bypass it.

SUPPORTING DETAIL

`inherited sharing` is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are `with sharing`, and the guest controllers and reconciliation jobs are `without sharing` for their own documented reasons. The Apex Developer Guide recommends `inherited sharing` for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit `AccessLevel`, and each `SYSTEM_MODE` query carries its own reason at the call site.

LOCATION IN THE SUBMITTED SOURCE

```
classes/recurring/selector/RecurringDonationsSelector.cls:11
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

258. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/RecurringDonationsSelector.cls:11
public inherited sharing class RecurringDonationsSelector extends fflib_SObjectSelector
```

REPORTED DATAFLOW — SHARING, PATH 1

```
classes/RecurringDonationsSelector.cls:11 public inherited sharing class  
RecurringDonationsSelector extends fflib_SObjectSelector
```

EVIDENCE CHECKED

- base/main/default/classes/recurring/selector/RecurringDonationsSelector.cls:11 - declaration
- base/main/default/classes/shared/Application.cls - resolved via the Selector factory only
- grep: no entry-point annotation or async interface in the class

259. Vulnerability Name

Sharing — `classes/recurring/selector/RecurringDesignationsSelector.cls:4` (R-064; Sharing paths 2)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

260. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

261. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class RecurringDesignationsSelector extends fflib_SObjectSelector
```

WHY THE CLAIM IS FALSE

The claim is false because `inherited sharing` is the documented mode for a class that is never an entry point: the selector takes the sharing of its caller, so a staff request is sharing-enforced and only the guest and job callers, which declare `without sharing` with a stated reason, bypass it.

SUPPORTING DETAIL

`inherited sharing` is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are `with sharing`, and the guest controllers and reconciliation jobs are `without sharing` for their own documented reasons. The Apex Developer Guide recommends `inherited sharing` for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit `AccessLevel`, and each `SYSTEM_MODE` query carries its own reason at the call site.

LOCATION IN THE SUBMITTED SOURCE

```
classes/recurring/selector/RecurringDesignationsSelector.cls:4
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

262. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/RecurringDesignationsSelector.cls:4
public inherited sharing class RecurringDesignationsSelector extends fflib_SObjectSelector
```

REPORTED DATAFLOW — SHARING, PATH 2

```
classes/RecurringDesignationsSelector.cls:4  public inherited sharing class  
RecurringDesignationsSelector extends fflib_SObjectSelector
```

EVIDENCE CHECKED

- base/main/default/classes/recurring-selector/RecurringDesignationsSelector.cls:4 - declaration
- base/main/default/classes/shared/Application.cls - resolved via the Selector factory only
- grep: no entry-point annotation or async interface in the class

263. Vulnerability Name

Sharing — `classes/donation/selector/OpportunitiesSelector.cls:19` (R-065; Sharing paths 3)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

264. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

265. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class OpportunitiesSelector extends fflib_SObjectSelector
```

WHY THE CLAIM IS FALSE

The claim is false because `inherited sharing` is the documented mode for a class that is never an entry point: the selector takes the sharing of its caller, so a staff controller's request is sharing-enforced and only the guest and job paths, which declare `without sharing` with a stated reason, bypass it.

SUPPORTING DETAIL

`inherited sharing` is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are `with sharing`, and the guest controllers and reconciliation jobs are `without sharing` for their own documented reasons. The Apex Developer Guide recommends `inherited sharing` for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit `AccessLevel`, and each `SYSTEM_MODE` query carries its own reason at the call site.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/selector/OpportunitiesSelector.cls:19
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

266. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/OpportunitiesSelector.cls:19
public inherited sharing class OpportunitiesSelector extends fflib_SObjectSelector
```

REPORTED DATAFLOW — SHARING, PATH 3

```
classes/OpportunitiesSelector.cls:19  public inherited sharing class OpportunitiesSelector extends  
fflib_SObjectSelector
```

EVIDENCE CHECKED

- base/main/default/classes/donation/selector/OpportunitiesSelector.cls:19 - declaration
- base/main/default/classes/shared/Application.cls - resolved via the Selector factory only
- grep: no entry-point annotation or async interface in the class

267. Vulnerability Name

Sharing — `classes/fflib/fflib_SObjectUnitOfWork.cls:191` (R-066; Sharing paths 4)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

268. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

269. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing virtual class SimpleDML implements IDML, IDMLUpsertable
```

WHY THE CLAIM IS FALSE

The claim is false because SimpleDML is declared `inherited sharing`, the documented mode for a non-entry-point class: a commit runs in the sharing mode of the class that called `commitWork()`, so a staff controller's commit is sharing-enforced by the platform and only callers that explicitly opt into the `SystemDML` subclass, each with a stated reason, bypass it.

SUPPORTING DETAIL

SimpleDML is the FFLib Unit of Work's default DML strategy. It is declared `inherited sharing`, so a commit follows the sharing mode of the class that called `commitWork()`. Every staff controller and service in the package is `with sharing`, so a staff commit runs with sharing and the platform enforces the running user's record access on the write. The writes that must bypass sharing (guest entry points, batch jobs, the platform-event subscriber and trigger-fired rollups) do not rely on this class: they construct their Unit of Work with `SystemDML`, a package-authored `without sharing` subclass, and each of the 24 construction sites states which of those families it belongs to. Object and field permissions are enforced one layer up, in the FFLib Selectors and by `Security.stripInaccessible`. `SystemDML_Test` proves, with a Minimum Access user, that a SimpleDML commit on a record the user is not shared is refused and a `SystemDML` commit succeeds.

LOCATION IN THE SUBMITTED SOURCE

```
classes/fflib/fflib_SObjectUnitOfWork.cls:191
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- <https://github.com/apex-enterprise-patterns/fflib-apex-common/issues/530>

270. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/fflib_SObjectUnitOfWork.cls:191  
public inherited sharing virtual class SimpleDML implements IDML, IDMLUpsertable
```

REPORTED DATAFLOW — SHARING, PATH 4

```
classes/fflib_SObjectUnitOfWork.cls:191  public inherited sharing virtual class SimpleDML  
implements IDML, IDMLUpsertable
```

EVIDENCE CHECKED

- base/main/default/classes/fflib/fflib_SObjectUnitOfWork.cls:64 - public virtual inherited sharing class fflib_SObjectUnitOfWork, rationale at :54-61
- base/main/default/classes/fflib/fflib_SObjectUnitOfWork.cls:165-191 - rationale and public inherited sharing virtual class SimpleDML implements IDML, IDMLUpsertable
- base/main/default/classes/shared/SystemDML.cls:30 - public without sharing class SystemDML extends fflib_SObjectUnitOfWork.SimpleDML, family list at :9-27
- grep: new SystemDML() at 24 production sites, each preceded by a // SystemDML: guest|job|rollup comment; none in a staff controller
- base/main/default/classes/shared/SystemDML_Test.cls:33 - test_simpleDml_withSharingCaller_cannotUpdateUnsharedRecord
- base/main/default/classes/shared/SystemDML_Test.cls:60 - test_systemDml_withSharingCaller_updatesUnsharedRecord
- This declaration is a deliberate local patch to the vendored FFLib library: upstream declares no sharing keyword on fflib_SObjectUnitOfWork or SimpleDML, and the package declares both inherited sharing (reason at :54-61 and :165-190) so a commit runs in its caller's sharing mode. The upstream proposal for the same declarations is fflib-apex-common issue #530 (cited below).
- <https://github.com/apex-enterprise-patterns/fflib-apex-common/issues/530> - upstream proposal for the same inherited sharing declarations

271. Vulnerability Name

Sharing — `classes/event/selector/EventTicketTypesSelector.cls:6` (R-067; Sharing paths 5)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

272. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

273. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class EventTicketTypesSelector extends fflib_SObjectSelector
```

WHY THE CLAIM IS FALSE

The claim is false because `inherited sharing` is the documented mode for a class that is never an entry point: the selector takes the sharing of its caller. Its reads are additionally gated on the master Campaign's visibility by the calling controller, because the object is a master-detail detail whose field permissions are inert.

SUPPORTING DETAIL

`inherited sharing` is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are `with sharing`, and the guest controllers and reconciliation jobs are `without sharing` for their own documented reasons. The Apex Developer Guide recommends `inherited sharing` for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit `AccessLevel`, and each `SYSTEM_MODE` query carries its own reason at the call site.

LOCATION IN THE SUBMITTED SOURCE

```
classes/event/selector/EventTicketTypesSelector.cls:6
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

274. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventTicketTypesSelector.cls:6
public inherited sharing class EventTicketTypesSelector extends fflib_SObjectSelector
```

REPORTED DATAFLOW — SHARING, PATH 5

```
classes/EventTicketTypesSelector.cls:6  public inherited sharing class EventTicketTypesSelector  
extends fflib_SObjectSelector
```

EVIDENCE CHECKED

- base/main/default/classes/event/selector/EventTicketTypesSelector.cls:6 - declaration
- base/main/default/classes/shared/Application.cls - resolved via the Selector factory only
- grep: no entry-point annotation or async interface in the class

275. Vulnerability Name

Sharing — `classes/fundraising/controller/EventRegistrationController.cls:196` (R-068; Sharing paths 6)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

276. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

277. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
private inherited sharing class CreateTicketIntent extends GuestAction {
```

WHY THE CLAIM IS FALSE

The claim is false because the inner action class is `inherited sharing` (matching the `GuestAction` base it extends) and is invoked only from the public event-registration controller, where the Experience Cloud guest user holds no record sharing; the controller's `without sharing` carries its reason, and the action's reads are gated on an active, published campaign.

SUPPORTING DETAIL

The inner class extends `GuestAction`, which is `inherited sharing`, and declares the same keyword so its mode is readable at the declaration. Invoked from the `without sharing` guest controller, it runs without sharing. That is required: an Experience Cloud guest creates a ticket order against a Campaign it is not shared under sharing rules, and the Guest User licence holds no record sharing. Record visibility is decided by explicit predicates instead: `requireOpenCampaign` refuses the request unless the campaign is active, published and open for sales, and checkout is not blocked. `GuestAction` also collapses any unexpected error to one generic message, so nothing internal reaches the guest.

LOCATION IN THE SUBMITTED SOURCE

```
classes/fundraising/controller/EventRegistrationController.cls:196
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

278. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventRegistrationController.cls:196  
private inherited sharing class CreateTicketIntent extends GuestAction {
```

REPORTED DATAFLOW — SHARING, PATH 6

```
classes/EventRegistrationController.cls:196 private inherited sharing class CreateTicketIntent  
extends GuestAction {
```

EVIDENCE CHECKED

- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:194-196 - rationale and private inherited sharing class CreateTicketIntent extends GuestAction
- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:9 - public without sharing class EventRegistrationController
- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:283 - requireOpenCampaign(campaignId) gates the request
- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:871-879 - requireOpenCampaign: requireActiveCampaign, CampaignService.assertAcceptingDonations, SettingsService.assertCheckoutNotBlocked
- base/main/default/classes/shared/GuestAction.cls:30 - public abstract inherited sharing class GuestAction extends ControllerAction

279. Vulnerability Name

Sharing — `classes/setup/service/EmailSenderService.cls:10` (R-069; Sharing paths 7)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

280. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

281. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class EmailSenderService {
```

WHY THE CLAIM IS FALSE

The claim is false because the class is a stateless helper that is never a transaction entry point and reads only org email configuration; `inherited sharing` makes it run in the mode of the service that builds the message, which is the documented purpose of that keyword.

SUPPORTING DETAIL

This is a stateless helper that stamps the org's configured sender identity onto outbound donor email. It is never a transaction entry point, and it takes the sharing mode of the service that builds the message. It reads only org email configuration. The keyword was reviewed for a change to `with sharing` on 2026-10-01 and kept: the class is called from the guest donation path and from the platform-event subscriber as well as from staff actions, and `inherited sharing` is the declaration that lets each of those run in its caller's mode instead of forcing one mode on all of them.

LOCATION IN THE SUBMITTED SOURCE

```
classes/setup/service/EmailSenderService.cls:10
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

282. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EmailSenderService.cls:10
public inherited sharing class EmailSenderService {
```

REPORTED DATAFLOW — SHARING, PATH 7

```
classes/EmailSenderService.cls:10  public inherited sharing class EmailSenderService {
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/EmailSenderService.cls:1-10 - header + declaration
- grep: no entry-point annotation or async interface

283. Vulnerability Name

Sharing — `classes/donation/service/DonationService.cls:7` (R-070; Sharing paths 8)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

284. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

285. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class DonationService implements IDonationService {
```

WHY THE CLAIM IS FALSE

The claim is false because DonationService is never a transaction entry point; `inherited sharing` makes it take the mode of its callers, the guest controllers (where visibility is decided by token or campaign predicates) and the reconciliation jobs, each of which declares its own keyword with its reason.

SUPPORTING DETAIL

DonationService is never an entry point. Its public methods are reached from the guest donation controllers, where visibility is decided by token or campaign predicates, and from the reconciliation jobs. Both of those callers establish `without sharing` and document why. When a `with sharing` staff controller calls it, it runs with sharing. That is the documented behavior of `inherited sharing` and the reason it is used here.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/service/DonationService.cls:7
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

286. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/DonationService.cls:7
public inherited sharing class DonationService implements IDonationService {
```

REPORTED DATAFLOW — SHARING, PATH 8

```
classes/DonationService.cls:7 public inherited sharing class DonationService implements  
IDonationService {
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/DonationService.cls:7 - declaration
- base/main/default/classes/donation/async/StagingReconciliationBatch.cls:216 - finalizeSucceededStaging caller
- base/main/default/classes/donation/async/StripePaymentSweep.cls:166 - caller

287. Vulnerability Name

Sharing — `classes/donation/selector/DonationDesignationsSelector.cls:8` (R-071; Sharing paths 9)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

288. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

289. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class DonationDesignationsSelector extends fflib_SObjectSelector
```

WHY THE CLAIM IS FALSE

The claim is false because `inherited sharing` is the mode Salesforce documents for non-entry-point classes and is accepted by its own false-positive guidance: the selector is never a transaction entry point, so it runs with the sharing of whichever controller or job called it, which is exactly the behaviour the rule asks for.

SUPPORTING DETAIL

`inherited sharing` is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are `with sharing`, and the guest controllers and reconciliation jobs are `without sharing` for their own documented reasons. The Apex Developer Guide recommends `inherited sharing` for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit `AccessLevel`, and each `SYSTEM_MODE` query carries its own reason at the call site.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/selector/DonationDesignationsSelector.cls:8
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

290. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/DonationDesignationsSelector.cls:8
public inherited sharing class DonationDesignationsSelector extends fflib_SObjectSelector
```

REPORTED DATAFLOW — SHARING, PATH 9

```
classes/DonationDesignationsSelector.cls:8  public inherited sharing class  
DonationDesignationsSelector extends fflib_SObjectSelector
```

EVIDENCE CHECKED

- base/main/default/classes/donation/selector/DonationDesignationsSelector.cls:8 - declaration
- base/main/default/classes/shared/Application.cls - resolved via the Selector factory only
- grep: no entry-point annotation or async interface in the class

291. Vulnerability Name

Sharing — `classes/shared/CurrencyResolver.cls:8` (R-072; Sharing paths 10)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

292. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

293. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class CurrencyResolver {
```

WHY THE CLAIM IS FALSE

The claim is false because the helper is never a transaction entry point; `inherited sharing` makes it run in the mode of the controller or trigger that called it, which is the documented purpose of that keyword.

SUPPORTING DETAIL

This helper resolves the currency for a campaign or payment account. It is never a transaction entry point and runs in whatever sharing mode its calling controller established, which is the purpose of `inherited sharing`.

LOCATION IN THE SUBMITTED SOURCE

```
classes/shared/CurrencyResolver.cls:8
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

294. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CurrencyResolver.cls:8
public inherited sharing class CurrencyResolver {
```

REPORTED DATAFLOW — SHARING, PATH 10

```
classes/CurrencyResolver.cls:8 public inherited sharing class CurrencyResolver {
```

EVIDENCE CHECKED

- `base/main/default/classes/shared/CurrencyResolver.cls:8` - declaration
- `grep`: no entry-point annotation or async interface

295. Vulnerability Name

Sharing — `classes/donation/service/CampaignMemberSyncService.cls:9` (R-073; Sharing paths 11)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

296. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

297. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public inherited sharing class CampaignMemberSyncService implements ICampaignMemberSyncService {
```

WHY THE CLAIM IS FALSE

The claim is false because the class has no @AuraEnabled, REST or asynchronous surface of its own, so it is not an entry point; `inherited sharing` makes it run in its caller's mode, which is the documented purpose of that keyword.

SUPPORTING DETAIL

This is a service, never a transaction entry point. It takes the sharing mode of the controller or job that calls it, which is what `inherited sharing` is documented for. It has no @AuraEnabled, REST, or async surface of its own.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/service/CampaignMemberSyncService.cls:9
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

298. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CampaignMemberSyncService.cls:9
public inherited sharing class CampaignMemberSyncService implements ICampaignMemberSyncService {
```

REPORTED DATAFLOW — SHARING, PATH 11

```
classes/CampaignMemberSyncService.cls:9 public inherited sharing class CampaignMemberSyncService
implements ICampaignMemberSyncService {
```

EVIDENCE CHECKED

- `base/main/default/classes/donation/service/CampaignMemberSyncService.cls:9` - declaration
- `grep`: no entry-point annotation or async interface

299. Vulnerability Name

Sharing — `classes/shared/SystemDML.cls:30` (R-074; Sharing paths 12)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

300. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

301. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class SystemDML extends fflib_SObjectUnitOfWork.SimpleDML {
```

WHY THE CLAIM IS FALSE

The claim is false because SystemDML is a deliberately narrow wrapper, not an entry point: it is the package's explicit, per-site opt-in for commits where the running user is by design not the authority over the records (guest entry points, batch and queueable jobs, trigger-fired rollups), each opt-in carrying its reason in code; staff commits use the user-mode strategy instead. The reason is stated at the declaration.

SUPPORTING DETAIL

SystemDML is the package's explicit opt-in for writes where the running user is, by design, not the authority over the records: Experience Cloud guest entry points (the Guest User licence holds no record sharing), batch and queueable jobs that must write every donor's records whoever scheduled them, the platform-event subscriber that runs as Automated Process, and trigger-fired rollups written for whoever saved the gift. The default Unit of Work strategy follows its caller's sharing; this class is used only where a site asks for it, and each of the 24 construction sites carries a `// SystemDML: guest|job|rollup` comment naming its family. The class contains nothing but four DML statements. Object and field permissions are enforced one layer up, in the FFLib Selectors and by `Security.stripInaccessible`. `SystemDML_Test` proves the difference with a Minimum Access user.

LOCATION IN THE SUBMITTED SOURCE

```
classes/shared/SystemDML.cls:30
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

302. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/SystemDML.cls:30  
public without sharing class SystemDML extends fflib_SObjectUnitOfWork.SimpleDML {
```

REPORTED DATAFLOW — SHARING, PATH 12

```
classes/SystemDML.cls:30 public without sharing class SystemDML extends  
fflib_SObjectUnitOfWork.SimpleDML {
```

EVIDENCE CHECKED

- base/main/default/classes/shared/SystemDML.cls:1-30 - class description, family list and public without sharing class SystemDML extends fflib_SObjectUnitOfWork.SimpleDML
- grep: new SystemDML() at 24 production sites, each preceded by a // SystemDML: guest|job|rollup comment; none in a staff controller
- base/main/default/classes/shared/SystemDML_Test.cls:33 - SimpleDML commit on an unshared record is refused
- base/main/default/classes/shared/SystemDML_Test.cls:60 - SystemDML commit on the same record succeeds

303. Vulnerability Name

Sharing — `classes/donation/async/StripePaymentSweep.cls:26` (R-075; Sharing paths 13)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

304. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

305. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class StripePaymentSweep
```

WHY THE CLAIM IS FALSE

The claim is false because this is batch Apex, which the scan's own rule exempts; the sweep compares the gateway ledger to every staging row and Opportunity in the org and takes no user input (the admin 'run now' button starts the same batch with no parameters).

SUPPORTING DETAIL

The sweep compares Stripe's payment ledger to the org's staging rows and Opportunities, and repairs gaps. That only works if it sees every row. It takes no input from users: the admin 'run now' button starts the same batch with no parameters.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/async/StripePaymentSweep.cls:26
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_scheduler.htm

306. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/StripePaymentSweep.cls:26
public without sharing class StripePaymentSweep
```

REPORTED DATAFLOW — SHARING, PATH 13

```
classes/StripePaymentSweep.cls:26  public without sharing class StripePaymentSweep
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/StripePaymentSweep.cls:26 - declaration
- base/main/default/classes/setup/controller/SetupController.cls:2142 - admin-only executeBatch, no parameters

307. Vulnerability Name

Sharing — `classes/donation/async/StagingReconciliationBatch.cls:31` (R-076; Sharing paths 14)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

308. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

309. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class StagingReconciliationBatch
```

WHY THE CLAIM IS FALSE

The claim is false because this is batch Apex, which the scan's own rule exempts; it must finalize staging rows created by the site guest user that no job owner is shared on. The single staff 'Retry now' entry point takes only a row Id and re-reads the charge from the gateway, so no caller-controlled data is written.

SUPPORTING DETAIL

The batch has to finalize donation staging rows created by the site guest user, and those rows are not owned by whoever runs the job. The one non-batch entry point is a single-row 'Retry now' action for staff. It re-reads the charge from Stripe and applies the same idempotent outcome logic as the batch. Donation_Staging__c ships with a Public Read/Write internal sharing model, so `without sharing` gives internal staff no visibility they do not already have.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/async/StagingReconciliationBatch.cls:31
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_scheduler.htm

310. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/StagingReconciliationBatch.cls:31  
public without sharing class StagingReconciliationBatch
```

REPORTED DATAFLOW — SHARING, PATH 14

```
classes/StagingReconciliationBatch.cls:31 public without sharing class StagingReconciliationBatch
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/StagingReconciliationBatch.cls:134-148 - reconcileOne: selectById (SYSTEM_MODE) then Stripe retrieve then applyOutcome
- base/main/default/classes/donation/controller/DonationMonitorController.cls:196-212 - RetryDonationStagingNow calls reconcileOne(stagingId); only requireNotNull
- base/main/default/objects/Donation_Staging__c/Donation_Staging__c.object-meta.xml:11 -
<sharingModel>ReadWrite</sharingModel>
- base/main/default/permissionsets/Fundraising_User.permissionset-meta.xml - Donation_Staging__c allowRead=true, allowEdit=false

311. Vulnerability Name

Sharing — `classes/setup/service/SettingsService.cls:543` (R-077; Sharing paths 15)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

312. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

313. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
private without sharing class PackagedAssetSeeder {
```

WHY THE CLAIM IS FALSE

The claim is false because this is a private inner helper, not an entry point, that runs only during install as the package's system user to copy the package's own static-resource images into public content distributions; that user cannot read StaticResource under sharing, and the helper never touches subscriber or donor data. The reason is stated at the declaration.

SUPPORTING DETAIL

This private helper copies the package's own static-resource images into public content distributions during install, so the default logo and hero images exist. The install user cannot read StaticResource under sharing. The helper never touches admin- or donor-supplied files, which go through the user-mode upload path. The elevation covers two short methods and nothing else.

LOCATION IN THE SUBMITTED SOURCE

```
classes/setup/service/SettingsService.cls:543
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

314. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/SettingsService.cls:543
private without sharing class PackagedAssetSeeder {
```

REPORTED DATAFLOW — SHARING, PATH 15

```
classes/SettingsService.cls:543  private without sharing class PackagedAssetSeeder {
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/SettingsService.cls:529-543 - rationale
- base/main/default/classes/setup/service/SettingsService.cls:547-552 - StaticResource read by packaged name only
- base/main/default/classes/setup/service/SettingsService.cls:378,141 - only instantiation sites

315. Vulnerability Name

Sharing — `classes/shared/async/RetentionPurgeBatch.cls:16` (R-078; Sharing paths 16)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

316. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

317. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class RetentionPurgeBatch implements Database.Batchable<SObject>,
Database.Stateful {
```

WHY THE CLAIM IS FALSE

The claim is false because this is batch Apex, which the scan's own rule exempts; it enforces the configured retention policy by deleting expired diagnostic and staging rows, and a row hidden from the job owner by sharing would otherwise never be purged. It has no entry point besides its scheduler. The reason is stated at the declaration.

SUPPORTING DETAIL

This batch enforces the configured data-retention policy by deleting expired diagnostic and staging rows. A row hidden from the job's running user by sharing would never be purged, which would defeat the policy. The batch has no entry point other than its scheduler and takes no user input.

LOCATION IN THE SUBMITTED SOURCE

```
classes/shared/async/RetentionPurgeBatch.cls:16
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_scheduler.htm

318. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/RetentionPurgeBatch.cls:16
public without sharing class RetentionPurgeBatch implements Database.Batchable<SObject>,
```

```
Database.Stateful {
```

REPORTED DATAFLOW — SHARING, PATH 16

```
classes/RetentionPurgeBatch.cls:16 public without sharing class RetentionPurgeBatch implements  
Database.Batchable<SObject>, Database.Stateful {
```

EVIDENCE CHECKED

- base/main/default/classes/shared/async/RetentionPurgeBatch.cls:16 - declaration
- base/main/default/classes/shared/async/RetentionPurgeScheduler.cls:29-33 - sole enqueuer

319. Vulnerability Name

Sharing — `classes/donation/async/RefundReconciliationBatch.cls:44` (R-079; Sharing paths 17)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

320. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

321. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class RefundReconciliationBatch
```

WHY THE CLAIM IS FALSE

The claim is false because the scan's own rule exempts batch and asynchronous Apex: this is a Batchable with no other entry point, and reconciling gateway refunds against every donation would silently skip records hidden from the job owner if it ran with sharing. Its reason is stated at the declaration.

SUPPORTING DETAIL

This is a batch with no public surface beyond the Batchable interface. It reconciles refunds recorded in Stripe against every donation in the org. If it ran with the sharing of the job owner, refunds on records that user cannot see would be silently skipped. No caller can pass it record Ids.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/async/RefundReconciliationBatch.cls:44
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_scheduler.htm

322. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/RefundReconciliationBatch.cls:44
public without sharing class RefundReconciliationBatch
```

REPORTED DATAFLOW — SHARING, PATH 17

```
classes/RefundReconciliationBatch.cls:44  public without sharing class RefundReconciliationBatch
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/RefundReconciliationBatch.cls:44 - declaration
- base/main/default/classes/donation/async/RefundReconciliationScheduler.cls:39 - sole enqueueuer

323. Vulnerability Name

Sharing — `classes/donation/async/ReconciliationHeartbeat.cls:11` (R-080; Sharing paths 18)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

324. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

325. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservices or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class ReconciliationHeartbeat implements Schedulable {
```

WHY THE CLAIM IS FALSE

The claim that this entry point should run with sharing is false because the scan's own rule says batch and asynchronous Apex should not; this is a Schedulable whose only job is to count every stuck staging row in the org, a count that would silently under-report under the sharing of whichever user scheduled it. Its reason is stated at the declaration.

SUPPORTING DETAIL

This is a Schedulable with no other entry point. It counts every non-terminal donation staging row in the org and alerts when any is stuck. A sharing-restricted count would depend on who owns the scheduled job, and would under-report. Its only writes are a Transaction_Log__c row and the alert, and nothing is returned to a user.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/async/ReconciliationHeartbeat.cls:11
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_scheduler.htm

326. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/ReconciliationHeartbeat.cls:11
public without sharing class ReconciliationHeartbeat implements Schedulable {
```

REPORTED DATAFLOW — SHARING, PATH 18

```
classes/ReconciliationHeartbeat.cls:11  public without sharing class ReconciliationHeartbeat  
implements Schedulable {
```

EVIDENCE CHECKED

- base/main/default/classes/donation/async/ReconciliationHeartbeat.cls:11 - declaration + rationale
- base/main/default/classes/setup/controller/PostInstallHandler.cls:495 - scheduled at install
- base/main/default/classes/setup/controller/SetupController.cls:2231 - admin re-schedule (SetupController granted to Fundraising_Admin only)

327. Vulnerability Name

Sharing — `classes/event/service/PricebookService.cls:25` (R-081; Sharing paths 19)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

328. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

329. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class PricebookService {
```

WHY THE CLAIM IS FALSE

The claim is false because the class is not an entry point and its only work is creating and reading the package's own event price book and its entries, standard objects a 2GP permission set cannot grant, during install (system user), admin ticket-tier saves and guest ticket purchases; none of those running users can hold sharing on Pricebook2. The reason is stated at the declaration.

SUPPORTING DETAIL

PricebookService only creates and looks up the package's event price book and its PricebookEntry rows for ticket products. It runs during install, when an admin saves ticket tiers, and during a guest ticket purchase. None of those contexts can rely on the running user's price-book sharing. It handles no donor data, and it only receives Product2 Ids that its callers have read from records they already gated. `with sharing` is not an option here: in the package install context a `with sharing` class cannot resolve the standard price book, which made the install-time seed fail when it was tried (2026-08-09).

LOCATION IN THE SUBMITTED SOURCE

```
classes/event/service/PricebookService.cls:25
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

330. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PricebookService.cls:25  
public without sharing class PricebookService {
```

REPORTED DATAFLOW — SHARING, PATH 19

```
classes/PricebookService.cls:25  public without sharing class PricebookService {
```

EVIDENCE CHECKED

- base/main/default/classes/event/service/PricebookService.cls:25 - declaration
- base/main/default/classes/event/controller/EventTicketAdminController.cls:156-176,197-263 - requireCampaignWritable gates; product Id derived from the saved tier
- base/main/default/classes/setup/controller/PostInstallHandler.cls:1544,1588 - install callers

331. Vulnerability Name

Sharing — `classes/setup/controller/PostInstallHandler.cls:18` (R-082; Sharing paths 20)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

332. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

333. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class PostInstallHandler implements InstallHandler {
```

WHY THE CLAIM IS FALSE

The claim is false because an InstallHandler is not a user entry point: it runs once, as a package-specific system user with no permission set, to seed org-wide configuration that must exist regardless of who installed the package. Salesforce's own false-positive guidance accepts install context, and the reason is stated at the declaration.

SUPPORTING DETAIL

This is the package InstallHandler. It seeds settings, themes, record-type mappings, the event price book and content templates, and schedules the package's background jobs. That data is org-wide configuration, which must be created regardless of the install user's sharing. Its public helpers are also re-run from the admin-only Settings console to repair a missing seed or a job owned by a deactivated user. They take no record Ids and are idempotent.

LOCATION IN THE SUBMITTED SOURCE

```
classes/setup/controller/PostInstallHandler.cls:18
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

334. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/PostInstallHandler.cls:18
public without sharing class PostInstallHandler implements InstallHandler {
```

REPORTED DATAFLOW — SHARING, PATH 20

```
classes/PostInstallHandler.cls:18 public without sharing class PostInstallHandler implements
InstallHandler {
```

EVIDENCE CHECKED

- base/main/default/classes/setup/controller/PostInstallHandler.cls:1-4 - rationale
- base/main/default/classes/setup/controller/SetupController.cls:834-847 - admin Fix button calls scheduleJobs(true)/seedRecordTypeMappings
- base/main/default/classes/setup/controller/SetupController.cls:1772-1784 - saveGeneralSettings re-owns jobs via scheduleJobs(true)
- base/main/default/permissionsets/Fundraising_Admin.permissionset-meta.xml - SetupController granted only here

335. Vulnerability Name

Sharing — `classes/donation/service/NpspSyncService.cls:14` (R-083; Sharing paths 21)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

336. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

337. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class NpspSyncService implements INpspSyncService {
```

WHY THE CLAIM IS FALSE

The claim is false because the class is not an entry point: it runs only from the platform-event subscriber (the Automated Process user) and the reconciliation jobs, both asynchronous contexts the scan's own rule exempts, and it writes NPSP objects the package cannot grant any user permissions on. Its reason is stated at the declaration.

SUPPORTING DETAIL

This service mirrors finalized donations into the optional NPSP objects (allocations and recurring donations). It runs from system contexts: the finalization platform-event subscriber and the reconciliation jobs that finalize donations. The records it writes belong to another package, and this package's permission sets cannot grant access to them. It never takes a record Id from a user: every Id comes from a donation or schedule the same transaction just finalized. NPSP rejections are logged and swallowed, so they cannot roll back a captured payment.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donation/service/NpspSyncService.cls:14
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.platform_events.meta/platform_events/platform_events_trigger_config.htm

338. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/NpspSyncService.cls:14  
public without sharing class NpspSyncService implements INpspSyncService {
```

REPORTED DATAFLOW — SHARING, PATH 21

```
classes/NpspSyncService.cls:14 public without sharing class NpspSyncService implements  
INpspSyncService {
```

EVIDENCE CHECKED

- base/main/default/classes/donation/service/NpspSyncService.cls:1-14 - header + declaration
- base/main/default/classes/donation/service/DonationFinalizedSubscriberHandler.cls:23-24 - syncAllocations caller
- base/main/default/classes/recurring/service/RecurringDonationService.cls:965-974 - its own doc comment: callers are StagingReconciliationBatch and StripePaymentSweep 'running as their batch owner, NOT the Automated Process user'
- base/main/default/classes/donation/service/DonationService.cls:593-595 - completeScheduleActivation from finalizeSucceededStaging
- No PlatformEventSubscriberConfig in base/ - the subscriber runs as the default Automated Process user

339. Vulnerability Name

Sharing — `classes/guestrequest/service/GuestRequestService.cls:13` (R-084; Sharing paths 22)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

340. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

341. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class GuestRequestService implements IGuestRequestService {
```

WHY THE CLAIM IS FALSE

The claim is false because the service is reached only after the donor portal has authorized the donor by a verified access code, or from the background sweep, and the guest user holds no sharing on the request object; the staff methods it serves filter their rows through user-mode reads. The reason is stated at the declaration.

SUPPORTING DETAIL

This service queues and processes public requests (attendee naming, refund requests) submitted from the donor portal. It is only reached after the portal has authorized the donor, and by the background sweep. The staff methods it also serves read and close requests for a gift. They are gated by the Process_Refunds custom permission, and Guest_Request__c ships with a Public Read/Write internal sharing model, so running without sharing gives staff no visibility they would not already have.

LOCATION IN THE SUBMITTED SOURCE

```
classes/guestrequest/service/GuestRequestService.cls:13
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

342. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/GuestRequestService.cls:13
public without sharing class GuestRequestService implements IGuestRequestService {
```

REPORTED DATAFLOW — SHARING, PATH 22

```
classes/GuestRequestService.cls:13  public without sharing class GuestRequestService implements  
IGuestRequestService {
```

EVIDENCE CHECKED

- base/main/default/classes/guestrequest/service/GuestRequestService.cls:8-13 - rationale
- base/main/default/classes/donation/controller/RefundController.cls:95-105 - staff caller gated by Process_Refunds
- base/main/default/objects/Guest_Request__c/Guest_Request__c.object-meta.xml:11 -
<sharingModel>ReadWrite</sharingModel>
- base/main/default/classes/donor/service/DonorPortalService.cls:1286,1269 - submit callers

343. Vulnerability Name

Sharing — `classes/fundraising/controller/EventRegistrationController.cls:9` (R-085; Sharing paths 23)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

344. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

345. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class EventRegistrationController {
```

WHY THE CLAIM IS FALSE

The claim is false because this is a guest-facing Experience Cloud controller: the guest user has no sharing that could expose an event campaign, so `with sharing` would make the public page empty. Reads are gated on an active, published campaign resolved by slug or Id, the single write is a staging row, and the reason is stated at the declaration.

SUPPORTING DETAIL

This is the public event-registration controller for an Experience Cloud site, and the guest user has no sharing that would expose an event campaign. Every method is narrow. Reads are gated on an active, published campaign resolved by slug or Id. The write is gated on the event being open for sales. The two status methods require the unguessable access token issued at checkout. Errors are sanitized through GuestAction. Staff hold the same class grant, but reach nothing beyond what an anonymous visitor can.

LOCATION IN THE SUBMITTED SOURCE

`classes/fundraising/controller/EventRegistrationController.cls:9`

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

346. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/EventRegistrationController.cls:9  
public without sharing class EventRegistrationController {
```

REPORTED DATAFLOW — SHARING, PATH 23

```
classes/EventRegistrationController.cls:9 public without sharing class EventRegistrationController  
{
```

EVIDENCE CHECKED

- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:25-112 - the five @AuraEnabled methods
- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:856-879 - requireActiveCampaign/requireOpenCampaign
- base/main/default/classes/fundraising/controller/EventRegistrationController.cls:781-807 - token-gated status/receipt methods
- base/main/default/permissionsets/Fundraising_GuestDonor.permissionset-meta.xml:36 - guest grant

347. Vulnerability Name

Sharing — `classes/donor/service/DonorPortalService.cls:48` (R-086; Sharing paths 24)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

348. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

349. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class DonorPortalService implements IDonorPortalService {
```

WHY THE CLAIM IS FALSE

The claim is false because the class serves an Experience Cloud guest user, who holds no record sharing on Contact, Account or the access-code object, so `with sharing` would return nothing; every guest method is instead authorized by possession of a verified access code, and the staff twins re-read their records in user mode. The reason is stated at the declaration.

SUPPORTING DETAIL

The class is `without sharing` so the Experience Cloud guest user, which has no sharing on Contact, Account or Portal_Access_Token__c, can resolve a donor from an access code and mint a portal session; every guest method is authorized by possession of the code or session it produces and trusts no client-supplied record Id. The class also holds two staff methods, `issueAccessCodeForDonor` and `createAccessCodeForDonor`, which take a record Id from a Lightning component. Both staff methods re-read the donor in the staff user's mode (USER_MODE selectors, `resolveStaffDonorEmail`) and refuse a donor the user cannot see before anything is minted or returned, and the class header states that its `without sharing` must not become a way to reach records outside the caller's access.

LOCATION IN THE SUBMITTED SOURCE

```
classes/donor/service/DonorPortalService.cls:48
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

350. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/DonorPortalService.cls:48  
public without sharing class DonorPortalService implements IDonorPortalService {
```

REPORTED DATAFLOW — SHARING, PATH 24

```
classes/DonorPortalService.cls:48  public without sharing class DonorPortalService implements  
IDonorPortalService {
```

EVIDENCE CHECKED

- base/main/default/classes/donor/service/DonorPortalService.cls:38-47 - header rationale for `without sharing` and the staff-twin exception; :48 declaration
- base/main/default/classes/donor/controller/DonorPortalAdminController.cls:156 / :175 - USER_MODE reads of the Contact / Person Account before the service is called
- Every top-level class in the package declares a sharing keyword, and each `without sharing` declaration carries its rationale in the class header (this one at :38-47). The staff-facing entry points re-read the donor under the staff user's own sharing before this class acts (DonorPortalAdminController.cls:156 and :175, USER_MODE; hardened 2026-09-25).

351. Vulnerability Name

Sharing — `classes/setup/service/CommunityService.cls:13` (R-087; Sharing paths 25)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

352. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

353. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public virtual without sharing class CommunityService implements ICommunityService {
```

WHY THE CLAIM IS FALSE

The claim is false because the service is reachable only from the administrator-only settings console, and the one record-shared object it reads is User, where a Private user-sharing model can hide the site's guest user from the administrator and turn every guest-setup check into a false failure; all other reads are setup objects with no sharing model. The reason is stated at the declaration.

SUPPORTING DETAIL

CommunityService backs the admin Settings console's Experience Cloud panel. The one record-shared object it reads is User: it looks up the site's guest user, which a Private User sharing model can hide from the admin, turning every guest check into a false "no guest user". Its other reads (Network, BackgroundOperation, PermissionSetAssignment, ObjectPermissions and SetupEntityAccess) are setup objects with no record sharing, and each carries its own SYSTEM_MODE reason. The only caller is the admin-only settings controller. It returns status flags and names only.

LOCATION IN THE SUBMITTED SOURCE

```
classes/setup/service/CommunityService.cls:13
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

354. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/CommunityService.cls:13  
public virtual without sharing class CommunityService implements ICommunityService {
```

REPORTED DATAFLOW — SHARING, PATH 25

```
classes/CommunityService.cls:13 public virtual without sharing class CommunityService implements  
ICommunityService {
```

EVIDENCE CHECKED

- base/main/default/classes/setup/service/CommunityService.cls:6-13 - rationale
- base/main/default/classes/setup/controller/SetupController.cls:44-45 - communityServiceInstance, the only reference (e.g. :2811)
- grep: CommunityService referenced only by SetupController, Application and TestDataFactory among non-test classes (others are comments)

355. Vulnerability Name

Sharing — `classes/guestrequest/handler/AttendeeNamingHandler.cls:14` (R-088; Sharing paths 26)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

356. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

357. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class AttendeeNamingHandler implements IGuestRequestHandler {
```

WHY THE CLAIM IS FALSE

The claim is false because the handler runs asynchronously from the request queue, a context the scan's own rule exempts, where no sharing relationship to the donor's order exists; the authorization (verified portal access code plus ownership of the order) was performed synchronously before the request was queued. The reason is stated at the declaration.

SUPPORTING DETAIL

This handler fills in guest names on the seats of one ticket order, for a request the donor submitted through the portal. It runs asynchronously from the request queue, where no sharing relationship to the donor's order exists. The authorization was performed when the request was accepted (portal session or code, then the order Id recorded server-side). The payload is size-capped and parsed defensively.

LOCATION IN THE SUBMITTED SOURCE

```
classes/guestrequest/handler/AttendeeNamingHandler.cls:14
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_scheduler.htm

358. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/AttendeeNamingHandler.cls:14  
public without sharing class AttendeeNamingHandler implements IGuestRequestHandler {
```

REPORTED DATAFLOW — SHARING, PATH 26

```
classes/AttendeeNamingHandler.cls:14 public without sharing class AttendeeNamingHandler implements  
IGuestRequestHandler {
```

EVIDENCE CHECKED

- base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:10-14 - rationale
- base/main/default/classes/guestrequest/handler/GuestRequestRouter.cls:28 - sole constructor site
- base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:19 - MAX_SEATS cap on untrusted payload

359. Vulnerability Name

Sharing — `classes/shared/AppLogger.cls:9` (R-089; Sharing paths 27)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

360. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

361. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservice or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app. Flagged statement:

```
public without sharing class AppLogger {
```

WHY THE CLAIM IS FALSE

The claim is false because the class only inserts diagnostic rows, performs no queries and returns no records, so sharing could not expose any data through it; it must succeed from every context, including a guest user and a failure caused by sharing itself, or the error being logged would be lost. The reason is stated at the declaration.

SUPPORTING DETAIL

AppLogger only inserts diagnostic Log__c rows. It performs no queries and returns no records, so there is no data a caller could read through it. It must succeed from any context, including the guest user and failures caused by sharing, or the error being logged is lost. Log__c is read-only to staff and not granted to the guest user.

LOCATION IN THE SUBMITTED SOURCE

```
classes/shared/AppLogger.cls:9
```

SOURCES

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_keywords_sharing.htm

362. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
classes/AppLogger.cls:9
public without sharing class AppLogger {
```

REPORTED DATAFLOW — SHARING, PATH 27

```
classes/AppLogger.cls:9 public without sharing class AppLogger {
```

EVIDENCE CHECKED

- base/main/default/classes/shared/AppLogger.cls:1-9 - rationale
- base/main/default/classes/shared/AppLogger.cls:125 - the only DML: insert as system Log__c

363. Vulnerability Name

Apex VF Dynamic JS Resource — `pages/stripePayment.page:53` (R-090; Apex VF Dynamic JS Resource paths 1)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

364. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

365. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Static resources must be used load third-party javascript code Flagged statement: `<script src="https://js.stripe.com/v3/"></script>`

WHY THE CLAIM IS FALSE

The claim that the script resource is dynamic is false because the src is a literal `https://js.stripe.com/v3/` string with no merge field, parameter or stored value contributing to it; and the rule's remedy (a static resource) is prohibited for this library, because Stripe requires Stripe.js to be loaded from `js.stripe.com` for PCI compliance and does not permit self-hosting.

SUPPORTING DETAIL

This is a static `<script>` tag with a literal `https://js.stripe.com` URL; no merge field, parameter or stored value contributes to the src, so it is not a dynamically constructed resource. Stripe's documentation requires Stripe.js to be loaded directly from `https://js.stripe.com` and not bundled or self-hosted, so it cannot be moved into a static resource; `js.stripe.com` is shipped as a packaged CSP Trusted Site. The page exists precisely to keep Stripe.js out of the LWC runtime: the LWC frames this Visualforce page by relative URL and talks to it by `postMessage`, Stripe Elements tokenizes card data in Stripe's own nested iframe, and only a payment-method id is returned to Apex. The page has no Apex controller and renders no server value into its script: the `postMessage` peer is the page's own origin (`window.location.origin`), and inbound messages are accepted only from that origin and from `window.parent`. Moving the script into a static resource was reviewed again on 2026-10-01 and is not permitted: Stripe's integration guidance states that Stripe.js must always be loaded directly from `js.stripe.com` and must not be included in a bundle or self-hosted, as a condition of PCI compliance.

LOCATION IN THE SUBMITTED SOURCE

`pages/stripePayment.page:53`

SOURCES

- <https://docs.stripe.com/js/including>
- <https://docs.stripe.com/security/guide>
- <https://docs.stripe.com/sdks/stripejs-versioning>
- <https://stripe.com/guides/pci-compliance>

366. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
pages/stripePayment.page:52
<script src="https://js.stripe.com/v3/"></script>
```

REPORTED DATAFLOW — APEX VF DYNAMIC JS RESOURCE, PATH 1

```
pages/stripePayment.page:52 <script src="https://js.stripe.com/v3/"></script>
```

EVIDENCE CHECKED

- base/main/default/pages/stripePayment.page:48-53 - justification comment + static script tag
- base/main/default/pages/stripePayment.page:1-7 - <apex:page> declares no controller; the page contains no {...} merge field
- base/main/default/pages/stripePayment.page:89 - var PARENT_ORIGIN = window.location.origin; (the page is always framed same-origin)
- base/main/default/pages/stripePayment.page:134 - message listener drops any event whose origin !== PARENT_ORIGIN or whose source !== window.parent
- base/main/default/pages/stripePayment.page:173-174 - returnUrl built with encodeURIComponent on publishableKey and stagingId
- base/main/default/lwc/dfForm/dfForm.js:441 - parent side checks event.origin === ALLOWED_ORIGIN (window.location.origin)
- https://docs.stripe.com/js/including - 'it should always be loaded directly from https://js.stripe.com, rather than included in a bundle or hosted yourself'
- https://docs.stripe.com/security/guide - Stripe.js CSP directives: script-src https://*.js.stripe.com, https://js.stripe.com; frame-src https://*.js.stripe.com, https://js.stripe.com, https://hooks.stripe.com; connect-src https://api.stripe.com
- base/main/default/cspTrustedSites/Stripe_js.cspTrustedSite-meta.xml - endpointUrl https://js.stripe.com, isActive true, connect-src + frame-src, context All (CspTrustedSite metadata has no script-src flag)
- base/main/default/cspTrustedSites/ - also Stripe_api (api.stripe.com), Stripe_hooks (hooks.stripe.com), Stripe_m, Stripe_m_network; no *.js.stripe.com entry (Stripe lists it as optional, for performance)

367. Vulnerability Name

Apex VF Dynamic JS Resource — `pages/stripePaymentReturn.page:40` (R-091; Apex VF Dynamic JS Resource paths 2)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

368. Detected By

- ☐ Chimera
- ☐ PMD
- ☐ Security Review
- ☒ Others,

If case of others Please provide details : Checkmarx — Force.com Source Code Scanner, run by the partner through the Partner Security Portal as job type ZIP_UPLOAD on the package source. Scan Id a0OKX000001JTAA2A4, CxEngine 9.7, preset PortalAll, 2026-10-06 21:57:40 to 2026-10-07 03:41:59; 273 security paths on 91 code locations. Source commit a4b2d3f1.

369. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Static resources must be used load third-party javascript code Flagged statement: `<script src="https://js.stripe.com/v3/"></script>`

WHY THE CLAIM IS FALSE

The claim that the script resource is dynamic is false because the src is a literal `https://js.stripe.com/v3/` string with nothing dynamic contributing to it; and Stripe requires Stripe.js to be loaded from `js.stripe.com` rather than bundled as a static resource, so the rule's remedy is not available for this library.

SUPPORTING DETAIL

This is a static `<script>` tag with a literal `https://js.stripe.com` URL, the second of the two Stripe.js loads in the package; nothing dynamic contributes to the src. Stripe redirects the donor here after an off-site authentication step (3D Secure, bank redirect), and the page needs Stripe.js to call `retrievePaymentIntent/retrieveSetupIntent`; Stripe's documentation requires Stripe.js to be loaded from `js.stripe.com` rather than self-hosted, which is why it is not a static resource. URL parameters read by the page (pk and the Stripe intent client secret) are passed only to Stripe.js calls, and status text is written with `textContent`. The page has no Apex controller. Its only server-rendered value is the 'Return to the site' link, whose href is the org's saved Experience site URL read through a `$Setup` merge field, rendered only when it begins with `https://`, and never taken from the query string. Moving the script into a static resource was reviewed again on 2026-10-01 and is not permitted: Stripe's integration guidance states that Stripe.js must always be loaded directly from `js.stripe.com` and must not be included in a bundle or self-hosted, as a condition of PCI compliance.

LOCATION IN THE SUBMITTED SOURCE

`pages/stripePaymentReturn.page:40`

SOURCES

- <https://docs.stripe.com/js/including>
- <https://docs.stripe.com/security/guide>
- <https://docs.stripe.com/sdks/stripejs-versioning>
- <https://stripe.com/guides/pci-compliance>

370. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED STATEMENT

```
pages/stripePaymentReturn.page:39
<script src="https://js.stripe.com/v3/"></script>
```

REPORTED DATAFLOW — APEX VF DYNAMIC JS RESOURCE, PATH 2

```
pages/stripePaymentReturn.page:39 <script src="https://js.stripe.com/v3/"></script>
```

EVIDENCE CHECKED

- base/main/default/pages/stripePaymentReturn.page:35-40 - justification comment + static script tag
- base/main/default/pages/stripePaymentReturn.page:1-7 - <apex:page> declares no controller
- base/main/default/pages/stripePaymentReturn.page:82-87 - only merge fields: the return link, rendered only when \$Setup.Settings__c.Experience_Site_URL__c BEGINS 'https://', value from the same setting (never from a URL parameter)
- base/main/default/pages/stripePaymentReturn.page:91-96 - pk and intent client secrets read from URLSearchParams; pk only passed to Stripe(pk); the opp parameter is never read
- base/main/default/pages/stripePaymentReturn.page:109-115 - PARENT_ORIGIN = window.location.origin; postMessage targets only that origin
- base/main/default/pages/stripePaymentReturn.page:117-124 - showStatus writes title/message/icon via textContent
- https://docs.stripe.com/js/including - 'it should always be loaded directly from https://js.stripe.com, rather than included in a bundle or hosted yourself'
- https://docs.stripe.com/security/guide - Stripe.js CSP directives: script-src https://*.js.stripe.com, https://js.stripe.com; frame-src https://*.js.stripe.com, https://js.stripe.com, https://hooks.stripe.com; connect-src https://api.stripe.com
- base/main/default/cspTrustedSites/Stripe_js.cspTrustedSite-meta.xml - endpointUrl https://js.stripe.com, isActive true, connect-src + frame-src, context All (CspTrustedSite metadata has no script-src flag)
- base/main/default/cspTrustedSites/ - also Stripe_api (api.stripe.com), Stripe_hooks (hooks.stripe.com), Stripe_m, Stripe_m_network; no *.js.stripe.com entry (Stripe lists it as optional, for performance)

Appendix A — scan summary and every reported path

Scanner	Force.com Source Scanner (Checkmarx)
Scan Id	a0OKX000001JTAA2A4
Engine / preset	CxEngine 9.7 / PortalAll
Job type	ZIP_UPLOAD
Scan start / end	2026-10-06 21:57:40 / 2026-10-07 03:41:59
Security issues reported	273 paths, 91 distinct code locations
Quality issues reported	100 paths (Appendix B)
Source commit	a4b2d3f1
Prepared	2026-10-09

Checkmarx reports one *path* per source-to-sink dataflow, so one line of code is often reported many times. Each entry above answers one code location once; this table maps every path in the scan report to its entry.

Query	Paths	Locations	False positive	Fixed since scan
Apex CRUD Violation	28	13	28	0
Apex CRUD ContentDistribution	7	3	7	0
Client DOM Stored XSS	1	1	1	0
CRUD Delete	1	1	1	0
FLS Create	109	22	109	0
FLS Update	69	14	69	0
Apex SOQL SOSL USER MODE MISSING	29	20	29	0
Sharing	27	27	27	0
Apex VF Dynamic JS Resource	2	2	2	0
Total	273	91	273	0

Query descriptions (from the scan report)

Apex CRUD Violation	This query looks for CRUD operations that are performed without checking for <code>isAccessible()</code> , <code>isUpdateable()</code> or <code>isDeletable()</code> . When an object uses <code>Whold</code> , <code>WhatId</code> , <code>ParentId</code> , <code>LinkedEntityId</code> fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields.
Apex CRUD ContentDistribution	USER_MODE is recommended for DML operations involving "ContentDistribution" object
Client DOM Stored XSS	This query detects external data flowing into a javascript execution context when that data comes from the database or other stored parameters influenced by external users. This may be a false positive if the datatype is safe to render unescaped (such as an integer or rich text field).
CRUD Delete	This query looks for CRUD Delete operations that are performed without checking for <code>isDeletable()</code> permission before performing the delete operation.
FLS Create	This query looks for CRUD Delete operations that are performed without checking for <code>isCreatable()</code> permission before performing the Create operation on the Object and its fields.

FLS Update	This query looks for CRUD Update operations that are performed without checking for isUpdateable() permission before performing the Update operation on the Object and its fields.				
Apex SOQL SOSL USER MODE MISSING	USER_MODE is recommended for SOQL or SOSL operations				
Sharing	All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservices or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app.				
Apex VF Dynamic JS Resource	Static resources must be used load third-party javascript code				
Query	Path	Source (scan)	Sink (scan)	Entry	Status
Apex CRUD Violation	1	classes/fflib_IDGenerator.cls:37	classes/PaymentSetupGuideService.cls:1918	R-001 (Q7)	False positive
Apex CRUD Violation	2	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:518	R-002 (Q11)	False positive
Apex CRUD Violation	3	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:103	R-003 (Q15)	False positive
Apex CRUD Violation	4	classes/fflib_IDGenerator.cls:37	classes/DonorPortalService.cls:548	R-004 (Q19)	False positive
Apex CRUD Violation	5	classes/fflib_IDGenerator.cls:37	classes/DonorPortalService.cls:483	R-005 (Q23)	False positive
Apex CRUD Violation	6	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:149	R-006 (Q27)	False positive
Apex CRUD Violation	7	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:329	R-007 (Q31)	False positive
Apex CRUD Violation	8	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:603	R-008 (Q35)	False positive
Apex CRUD Violation	9	classes/fflib_QueryFactory.cls:360	classes/PaymentSetupGuideService.cls:1918	R-001 (Q7)	False positive
Apex CRUD Violation	10	classes/fflib_QueryFactory.cls:360	classes/ReceiptService.cls:103	R-003 (Q15)	False positive
Apex CRUD Violation	11	classes/fflib_QueryFactory.cls:360	classes/ReceiptService.cls:149	R-006 (Q27)	False positive
Apex CRUD Violation	12	classes/fflib_QueryFactory.cls:360	classes/ReceiptService.cls:734	R-009 (Q39)	False positive
Apex CRUD Violation	13	classes/fflib_QueryFactory.cls:360	classes/ReceiptService.cls:603	R-008 (Q35)	False positive
Apex CRUD Violation	14	classes/SetupController.cls:479	classes/PaymentSetupGuideService.cls:1918	R-001 (Q7)	False positive
Apex CRUD Violation	15	classes/SetupController.cls:642	classes/CommunityService.cls:513	R-010 (Q43)	False positive
Apex CRUD Violation	16	classes/fflib_ApexMocks.cls:69	classes/ReceiptService.cls:329	R-007 (Q31)	False positive
Apex CRUD Violation	17	classes/fflib_ApexMocks.cls:69	classes/ReceiptService.cls:408	R-011 (Q47)	False positive
Apex CRUD Violation	18	classes/fflib_QueryFactory.cls:218	classes/ReceiptService.cls:518	R-002 (Q11)	False positive
Apex CRUD Violation	19	classes/fflib_QueryFactory.cls:218	classes/RefundRequestHandler.cls:138	R-012 (Q51)	False positive
Apex CRUD Violation	20	classes/DonorPortalAdminController.cls:40	classes/DonorPortalService.cls:548	R-004 (Q19)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
Apex CRUD Violation	21	classes/DonorPortalAdminController.cls:40	classes/DonorPortalService.cls:483	R-005 (Q23)	False positive
Apex CRUD Violation	22	classes/DonationMonitorController.cls:57	classes/ReceiptService.cls:103	R-003 (Q15)	False positive
Apex CRUD Violation	23	classes/RefundController.cls:22	classes/ReceiptService.cls:408	R-011 (Q47)	False positive
Apex CRUD Violation	24	classes/DonorPortalAdminController.cls:50	classes/DonorPortalService.cls:548	R-004 (Q19)	False positive
Apex CRUD Violation	25	classes/DonorPortalAdminController.cls:50	classes/DonorPortalService.cls:483	R-005 (Q23)	False positive
Apex CRUD Violation	26	classes/fflib_ApexMocks.cls:115	classes/ReceiptService.cls:329	R-007 (Q31)	False positive
Apex CRUD Violation	27	classes/fflib_ApexMocks.cls:115	classes/ReceiptService.cls:408	R-011 (Q47)	False positive
Apex CRUD Violation	28	classes/ReceiptAdminController.cls:38	classes/ReceiptService.cls:173	R-013 (Q55)	False positive
Apex CRUD ContentDistribution	1	classes/CampaignPostService.cls:456	classes/CampaignPostService.cls:555	R-014 (Q59)	False positive
Apex CRUD ContentDistribution	2	classes/CampaignPostService.cls:537	classes/CampaignPostService.cls:555	R-014 (Q59)	False positive
Apex CRUD ContentDistribution	3	classes/CampaignPostService.cls:654	classes/AppLogger.cls:125	R-015 (Q63)	False positive
Apex CRUD ContentDistribution	4	classes/CampaignPostService.cls:657	classes/AppLogger.cls:125	R-015 (Q63)	False positive
Apex CRUD ContentDistribution	5	classes/SettingsService.cls:571	classes/SettingsService.cls:345	R-016 (Q67)	False positive
Apex CRUD ContentDistribution	6	classes/CampaignPostService.cls:678	classes/AppLogger.cls:125	R-015 (Q63)	False positive
Apex CRUD ContentDistribution	7	classes/SettingsService.cls:616	classes/SettingsService.cls:345	R-016 (Q67)	False positive
Client DOM Stored XSS	1	lwc/publicDonorDashboard/publicDonorDashboard.js:316	lwc/pfGivingStatement/pfGivingStatement.html:34	R-017 (Q71)	False positive
CRUD Delete	1	classes/RetentionPurgeBatch.cls:90	classes/RetentionPurgeBatch.cls:90	R-018 (Q75)	False positive
FLS Create	1	classes/ReconciliationHeartbeat.cls:60	classes/ReconciliationHeartbeat.cls:59	R-019 (Q79)	False positive
FLS Create	2	classes/AppLogger.cls:126	classes/AppLogger.cls:125	R-015 (Q63)	False positive
FLS Create	3	classes/AppLogger.cls:127	classes/AppLogger.cls:125	R-015 (Q63)	False positive
FLS Create	4	classes/AppLogger.cls:128	classes/AppLogger.cls:125	R-015 (Q63)	False positive
FLS Create	5	classes/AppLogger.cls:129	classes/AppLogger.cls:125	R-015 (Q63)	False positive
FLS Create	6	classes/AppLogger.cls:130	classes/AppLogger.cls:125	R-015 (Q63)	False positive
FLS Create	7	classes/AppLogger.cls:131	classes/AppLogger.cls:125	R-015 (Q63)	False positive
FLS Create	8	classes/StripePaymentSweep.cls:204	classes/StripePaymentSweep.cls:203	R-020 (Q83)	False positive
FLS Create	9	classes/StripePaymentSweep.cls:205	classes/StripePaymentSweep.cls:203	R-020 (Q83)	False positive
FLS Create	10	classes/StripePaymentSweep.cls:206	classes/StripePaymentSweep.cls:203	R-020 (Q83)	False positive
FLS Create	11	classes/StripePaymentSweep.cls:207	classes/StripePaymentSweep.cls:203	R-020 (Q83)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
FLS Create	12	classes/StripePaymentSweep.cls:208	classes/StripePaymentSweep.cls:203	R-020 (Q83)	False positive
FLS Create	13	classes/StagingReconciliationBatch.cls:214	classes/StagingReconciliationBatch.cls:281	R-021 (Q87)	False positive
FLS Create	14	classes/StagingReconciliationBatch.cls:250	classes/StagingReconciliationBatch.cls:281	R-021 (Q87)	False positive
FLS Create	15	classes/SettingsService.cls:327	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	16	classes/RefundReconciliationBatch.cls:340	classes/RefundReconciliationBatch.cls:344	R-022 (Q91)	False positive
FLS Create	17	classes/RefundReconciliationBatch.cls:341	classes/RefundReconciliationBatch.cls:344	R-022 (Q91)	False positive
FLS Create	18	classes/SettingsService.cls:1014	classes/SettingsService.cls:1026	R-023 (Q95)	False positive
FLS Create	19	classes/SettingsService.cls:1016	classes/SettingsService.cls:1026	R-023 (Q95)	False positive
FLS Create	20	classes/PostInstallHandler.cls:1512	classes/PostInstallHandler.cls:1515	R-024 (Q99)	False positive
FLS Create	21	classes/PostInstallHandler.cls:1554	classes/PostInstallHandler.cls:1557	R-025 (Q103)	False positive
FLS Create	22	classes/PostInstallHandler.cls:1598	classes/PostInstallHandler.cls:1601	R-026 (Q107)	False positive
FLS Create	23	classes/PostInstallHandler.cls:213	classes/PostInstallHandler.cls:260	R-027 (Q111)	False positive
FLS Create	24	classes/StagingReconciliationBatch.cls:213	classes/StagingReconciliationBatch.cls:281	R-021 (Q87)	False positive
FLS Create	25	classes/PostInstallHandler.cls:214	classes/PostInstallHandler.cls:260	R-027 (Q111)	False positive
FLS Create	26	classes/PostInstallHandler.cls:215	classes/PostInstallHandler.cls:260	R-027 (Q111)	False positive
FLS Create	27	classes/PostInstallHandler.cls:221	classes/PostInstallHandler.cls:260	R-027 (Q111)	False positive
FLS Create	28	classes/SettingsService.cls:324	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	29	classes/RefundReconciliationBatch.cls:338	classes/RefundReconciliationBatch.cls:344	R-022 (Q91)	False positive
FLS Create	30	classes/SettingsService.cls:558	classes/SettingsService.cls:563	R-028 (Q115)	False positive
FLS Create	31	classes/SettingsService.cls:559	classes/SettingsService.cls:563	R-028 (Q115)	False positive
FLS Create	32	classes/SettingsService.cls:560	classes/SettingsService.cls:563	R-028 (Q115)	False positive
FLS Create	33	classes/SettingsService.cls:572	classes/SettingsService.cls:581	R-029 (Q119)	False positive
FLS Create	34	classes/SettingsService.cls:573	classes/SettingsService.cls:581	R-029 (Q119)	False positive
FLS Create	35	classes/SettingsService.cls:574	classes/SettingsService.cls:581	R-029 (Q119)	False positive
FLS Create	36	classes/SettingsService.cls:575	classes/SettingsService.cls:581	R-029 (Q119)	False positive
FLS Create	37	classes/SettingsService.cls:576	classes/SettingsService.cls:581	R-029 (Q119)	False positive
FLS Create	38	classes/PostInstallHandler.cls:1501	classes/PostInstallHandler.cls:1503	R-030 (Q123)	False positive
FLS Create	39	classes/PostInstallHandler.cls:1534	classes/PostInstallHandler.cls:1537	R-031 (Q127)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
FLS Create	40	classes/PostInstallHandler.cls:1578	classes/PostInstallHandler.cls:1581	R-032 (Q131)	False positive
FLS Create	41	classes/StagingReconciliationBatch.cls:212	classes/StagingReconciliationBatch.cls:281	R-021 (Q87)	False positive
FLS Create	42	classes/EventPurchaseService.cls:587	classes/EventPurchaseService.cls:590	R-033 (Q135)	False positive
FLS Create	43	classes/SettingsService.cls:1011	classes/SettingsService.cls:1026	R-023 (Q95)	False positive
FLS Create	44	classes/PostInstallHandler.cls:1509	classes/PostInstallHandler.cls:1515	R-024 (Q99)	False positive
FLS Create	45	classes/PostInstallHandler.cls:1551	classes/PostInstallHandler.cls:1557	R-025 (Q103)	False positive
FLS Create	46	classes/PostInstallHandler.cls:1595	classes/PostInstallHandler.cls:1601	R-026 (Q107)	False positive
FLS Create	47	classes/CampaignMemberSyncService.cls:68	classes/CampaignMemberSyncService.cls:80	R-034 (Q139)	False positive
FLS Create	48	classes/StagingReconciliationBatch.cls:186	classes/StagingReconciliationBatch.cls:281	R-021 (Q87)	False positive
FLS Create	49	classes/StagingReconciliationBatch.cls:187	classes/StagingReconciliationBatch.cls:281	R-021 (Q87)	False positive
FLS Create	50	classes/SettingsService.cls:355	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	51	classes/SettingsService.cls:383	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	52	classes/SettingsService.cls:391	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	53	classes/SettingsService.cls:421	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	54	classes/SettingsService.cls:430	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	55	classes/PostInstallHandler.cls:1670	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	56	classes/SettingsService.cls:2319	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	57	classes/SetupController.cls:2682	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	58	classes/SetupController.cls:2723	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	59	classes/SetupController.cls:2778	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	60	classes/SettingsService.cls:382	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	61	classes/SettingsService.cls:390	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	62	classes/PostInstallHandler.cls:1254	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	63	classes/SettingsService.cls:2318	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	64	classes/SetupController.cls:2722	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	65	classes/SettingsService.cls:389	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	66	classes/PostInstallHandler.cls:1253	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	67	classes/SettingsService.cls:2317	classes/SettingsService.cls:345	R-016 (Q67)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
FLS Create	68	classes/SetupController.cls:2721	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	69	classes/PricebookService.cls:142	classes/PricebookService.cls:125	R-037 (Q151)	False positive
FLS Create	70	classes/PricebookService.cls:142	classes/PricebookService.cls:135	R-038 (Q155)	False positive
FLS Create	71	classes/PricebookService.cls:143	classes/PricebookService.cls:125	R-037 (Q151)	False positive
FLS Create	72	classes/PricebookService.cls:143	classes/PricebookService.cls:135	R-038 (Q155)	False positive
FLS Create	73	classes/PostInstallHandler.cls:1252	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	74	classes/SettingsService.cls:2316	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	75	classes/SetupController.cls:2718	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	76	classes/PostInstallHandler.cls:1251	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	77	classes/SetupController.cls:2717	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	78	classes/SettingsService.cls:300	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	79	classes/PostInstallHandler.cls:1250	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	80	classes/PostInstallHandler.cls:1660	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	81	classes/SetupController.cls:2716	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	82	classes/PostInstallHandler.cls:1249	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	83	classes/PostInstallHandler.cls:1653	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	84	classes/PostInstallHandler.cls:1654	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	85	classes/PostInstallHandler.cls:1655	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	86	classes/PostInstallHandler.cls:1656	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	87	classes/PostInstallHandler.cls:1657	classes/PostInstallHandler.cls:1645	R-035 (Q143)	False positive
FLS Create	88	classes/SetupController.cls:2715	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	89	classes/PostInstallHandler.cls:1248	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	90	classes/SetupController.cls:2714	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	91	classes/PostInstallHandler.cls:1220	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	92	classes/SetupController.cls:2713	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	93	classes/PostInstallHandler.cls:1216	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	94	classes/SetupController.cls:2712	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	95	classes/PostInstallHandler.cls:1215	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
FLS Create	96	classes/SetupController.cls:2711	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	97	classes/PostInstallHandler.cls:1206	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	98	classes/SetupController.cls:2710	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	99	classes/PostInstallHandler.cls:1205	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	100	classes/SetupController.cls:2709	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Create	101	classes/PostInstallHandler.cls:1204	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	102	classes/PostInstallHandler.cls:1203	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	103	classes/PostInstallHandler.cls:1202	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	104	classes/PostInstallHandler.cls:1201	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	105	classes/PostInstallHandler.cls:1200	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	106	classes/PostInstallHandler.cls:1199	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	107	classes/PostInstallHandler.cls:1198	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	108	classes/PostInstallHandler.cls:1197	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Create	109	classes/PostInstallHandler.cls:1196	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	1	classes/StagingReconciliationBatch.cls:269	classes/StagingReconciliationBatch.cls:275	R-039 (Q159)	False positive
FLS Update	2	classes/SettingsService.cls:327	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	3	classes/RefundReconciliationBatch.cls:340	classes/RefundReconciliationBatch.cls:344	R-022 (Q91)	False positive
FLS Update	4	classes/RefundReconciliationBatch.cls:341	classes/RefundReconciliationBatch.cls:344	R-022 (Q91)	False positive
FLS Update	5	classes/DonorPortalService.cls:374	classes/DonorPortalService.cls:383	R-040 (Q163)	False positive
FLS Update	6	classes/SettingsService.cls:1014	classes/SettingsService.cls:1026	R-023 (Q95)	False positive
FLS Update	7	classes/SettingsService.cls:1016	classes/SettingsService.cls:1026	R-023 (Q95)	False positive
FLS Update	8	classes/PostInstallHandler.cls:1495	classes/PostInstallHandler.cls:1498	R-041 (Q167)	False positive
FLS Update	9	classes/PostInstallHandler.cls:1512	classes/PostInstallHandler.cls:1515	R-024 (Q99)	False positive
FLS Update	10	classes/PostInstallHandler.cls:1554	classes/PostInstallHandler.cls:1557	R-025 (Q103)	False positive
FLS Update	11	classes/PostInstallHandler.cls:1598	classes/PostInstallHandler.cls:1601	R-026 (Q107)	False positive
FLS Update	12	classes/SettingsService.cls:324	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	13	classes/SettingsService.cls:355	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	14	classes/SettingsService.cls:383	classes/SettingsService.cls:345	R-016 (Q67)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
FLS Update	15	classes/SettingsService.cls:391	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	16	classes/SettingsService.cls:421	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	17	classes/SettingsService.cls:430	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	18	classes/SettingsService.cls:2319	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	19	classes/SetupController.cls:2682	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	20	classes/SetupController.cls:2723	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	21	classes/SetupController.cls:2778	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	22	classes/AttendeeNamingHandler.cls:106	classes/AttendeeNamingHandler.cls:129	R-042 (Q171)	False positive
FLS Update	23	classes/AttendeeNamingHandler.cls:114	classes/AttendeeNamingHandler.cls:129	R-042 (Q171)	False positive
FLS Update	24	classes/GuestRequestService.cls:129	classes/GuestRequestService.cls:138	R-043 (Q175)	False positive
FLS Update	25	classes/GuestRequestService.cls:229	classes/GuestRequestService.cls:237	R-044 (Q179)	False positive
FLS Update	26	classes/SettingsService.cls:382	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	27	classes/SettingsService.cls:390	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	28	classes/PostInstallHandler.cls:402	classes/PostInstallHandler.cls:409	R-045 (Q183)	False positive
FLS Update	29	classes/PostInstallHandler.cls:1254	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	30	classes/SettingsService.cls:2318	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	31	classes/SetupController.cls:2722	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	32	classes/AttendeeNamingHandler.cls:105	classes/AttendeeNamingHandler.cls:129	R-042 (Q171)	False positive
FLS Update	33	classes/GuestRequestService.cls:128	classes/GuestRequestService.cls:138	R-043 (Q175)	False positive
FLS Update	34	classes/GuestRequestService.cls:228	classes/GuestRequestService.cls:237	R-044 (Q179)	False positive
FLS Update	35	classes/SettingsService.cls:389	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	36	classes/PostInstallHandler.cls:1253	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	37	classes/SettingsService.cls:2317	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	38	classes/SetupController.cls:2721	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	39	classes/GuestRequestService.cls:227	classes/GuestRequestService.cls:237	R-044 (Q179)	False positive
FLS Update	40	classes/PostInstallHandler.cls:1252	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	41	classes/SettingsService.cls:2316	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	42	classes/SetupController.cls:2718	classes/SettingsService.cls:345	R-016 (Q67)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
FLS Update	43	classes/PostInstallHandler.cls:1251	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	44	classes/SetupController.cls:2717	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	45	classes/PostInstallHandler.cls:1250	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	46	classes/SetupController.cls:2716	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	47	classes/PostInstallHandler.cls:1249	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	48	classes/SetupController.cls:2715	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	49	classes/PostInstallHandler.cls:1248	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	50	classes/SetupController.cls:2714	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	51	classes/PostInstallHandler.cls:1220	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	52	classes/SetupController.cls:2713	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	53	classes/PostInstallHandler.cls:1216	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	54	classes/SetupController.cls:2712	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	55	classes/PostInstallHandler.cls:1215	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	56	classes/SetupController.cls:2711	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	57	classes/PostInstallHandler.cls:1206	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	58	classes/SetupController.cls:2710	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	59	classes/PostInstallHandler.cls:1205	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	60	classes/SetupController.cls:2709	classes/SettingsService.cls:345	R-016 (Q67)	False positive
FLS Update	61	classes/PostInstallHandler.cls:1204	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	62	classes/PostInstallHandler.cls:1203	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	63	classes/PostInstallHandler.cls:1202	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	64	classes/PostInstallHandler.cls:1201	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	65	classes/PostInstallHandler.cls:1200	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	66	classes/PostInstallHandler.cls:1199	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	67	classes/PostInstallHandler.cls:1198	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	68	classes/PostInstallHandler.cls:1197	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
FLS Update	69	classes/PostInstallHandler.cls:1196	classes/PostInstallHandler.cls:758	R-036 (Q147)	False positive
Apex SOQL SOSL USER MODE MISSING	1	classes/CurrencyResolver.cls:260	classes/CurrencyResolver.cls:265	R-046 (Q187)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
Apex SOQL SOSL USER MODE MISSING	2	classes/FundraiserDetailController.cls:39	classes/AccountsSelector.cls:311	R-047 (Q191)	False positive
Apex SOQL SOSL USER MODE MISSING	3	classes/FundraiserDetailController.cls:39	classes/ContactsSelector.cls:228	R-048 (Q195)	False positive
Apex SOQL SOSL USER MODE MISSING	4	classes/DonorDetailController.cls:56	classes/AccountsSelector.cls:311	R-047 (Q191)	False positive
Apex SOQL SOSL USER MODE MISSING	5	classes/DonorDetailController.cls:56	classes/ContactsSelector.cls:228	R-048 (Q195)	False positive
Apex SOQL SOSL USER MODE MISSING	6	classes/SetupController.cls:632	classes/CommunityService.cls:269	R-049 (Q199)	False positive
Apex SOQL SOSL USER MODE MISSING	7	classes/SetupController.cls:632	classes/SettingsService.cls:345	R-016 (Q67)	False positive
Apex SOQL SOSL USER MODE MISSING	8	classes/SetupController.cls:642	classes/CommunityService.cls:269	R-049 (Q199)	False positive
Apex SOQL SOSL USER MODE MISSING	9	classes/SetupController.cls:642	classes/CommunityService.cls:513	R-010 (Q43)	False positive
Apex SOQL SOSL USER MODE MISSING	10	classes/SetupController.cls:642	classes/CommunityService.cls:328	R-050 (Q203)	False positive
Apex SOQL SOSL USER MODE MISSING	11	classes/SetupController.cls:642	classes/CommunityService.cls:569	R-051 (Q207)	False positive
Apex SOQL SOSL USER MODE MISSING	12	classes/SetupController.cls:642	classes/CommunityService.cls:608	R-052 (Q211)	False positive
Apex SOQL SOSL USER MODE MISSING	13	classes/SetupController.cls:642	classes/CommunityService.cls:407	R-053 (Q215)	False positive
Apex SOQL SOSL USER MODE MISSING	14	classes/SetupController.cls:397	classes/SettingsService.cls:1026	R-023 (Q95)	False positive
Apex SOQL SOSL USER MODE MISSING	15	classes/SettingsService.cls:354	classes/SettingsService.cls:345	R-016 (Q67)	False positive
Apex SOQL SOSL USER MODE MISSING	16	classes/SetupController.cls:2674	classes/SettingsService.cls:345	R-016 (Q67)	False positive
Apex SOQL SOSL USER MODE MISSING	17	classes/TestDataFactory.cls:778	classes/EventPurchaseService_Test.cls:906	R-054 (Q219)	False positive
Apex SOQL SOSL USER MODE MISSING	18	classes/TestDataFactory.cls:778	classes/EventPurchaseService_Test.cls:261	R-055 (Q223)	False positive
Apex SOQL SOSL USER MODE MISSING	19	classes/TestDataFactory.cls:778	classes/EventPurchaseService_Test.cls:578	R-056 (Q227)	False positive
Apex SOQL SOSL USER MODE MISSING	20	classes/TestDataFactory.cls:778	classes/EventPurchaseService_Test.cls:610	R-057 (Q231)	False positive
Apex SOQL SOSL USER MODE MISSING	21	classes/TestDataFactory.cls:778	classes/EventPurchaseService_Test.cls:641	R-058 (Q235)	False positive
Apex SOQL SOSL USER MODE MISSING	22	classes/TestDataFactory.cls:778	classes/EventPurchaseService_Test.cls:672	R-059 (Q239)	False positive
Apex SOQL SOSL USER MODE MISSING	23	classes/TestDataFactory.cls:778	classes/EventRegistrationController_Test.cls:171	R-060 (Q243)	False positive
Apex SOQL SOSL USER MODE MISSING	24	classes/DonationService.cls:499	classes/ReceiptSequenceSelector.cls:63	R-061 (Q247)	False positive
Apex SOQL SOSL USER MODE MISSING	25	classes/EventPurchaseService.cls:1123	classes/ReceiptSequenceSelector.cls:63	R-061 (Q247)	False positive
Apex SOQL SOSL USER MODE MISSING	26	classes/RecurringDonationService.cls:1188	classes/ReceiptSequenceSelector.cls:63	R-061 (Q247)	False positive
Apex SOQL SOSL USER MODE MISSING	27	classes/SetupController.cls:334	classes/SettingsService.cls:345	R-016 (Q67)	False positive
Apex SOQL SOSL USER MODE MISSING	28	classes/OpportunitiesSelector.cls:189	classes/CurrencyResolver.cls:264	R-062 (Q251)	False positive
Apex SOQL SOSL USER MODE MISSING	29	classes/RecordTypeService.cls:133	classes/ReceiptSequenceSelector.cls:63	R-061 (Q247)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
Sharing	1	classes/RecurringDonationsSelector.cls:11	classes/RecurringDonationsSelector.cls:11	R-063 (Q255)	False positive
Sharing	2	classes/RecurringDesignationsSelector.cls:4	classes/RecurringDesignationsSelector.cls:4	R-064 (Q259)	False positive
Sharing	3	classes/OpportunitiesSelector.cls:19	classes/OpportunitiesSelector.cls:19	R-065 (Q263)	False positive
Sharing	4	classes/fflib_SObjectUnitOfWork.cls:191	classes/fflib_SObjectUnitOfWork.cls:191	R-066 (Q267)	False positive
Sharing	5	classes/EventTicketTypesSelector.cls:6	classes/EventTicketTypesSelector.cls:6	R-067 (Q271)	False positive
Sharing	6	classes/EventRegistrationController.cls:196	classes/EventRegistrationController.cls:196	R-068 (Q275)	False positive
Sharing	7	classes/EmailSenderService.cls:10	classes/EmailSenderService.cls:10	R-069 (Q279)	False positive
Sharing	8	classes/DonationService.cls:7	classes/DonationService.cls:7	R-070 (Q283)	False positive
Sharing	9	classes/DonationDesignationsSelector.cls:8	classes/DonationDesignationsSelector.cls:8	R-071 (Q287)	False positive
Sharing	10	classes/CurrencyResolver.cls:8	classes/CurrencyResolver.cls:8	R-072 (Q291)	False positive
Sharing	11	classes/CampaignMemberSyncService.cls:9	classes/CampaignMemberSyncService.cls:9	R-073 (Q295)	False positive
Sharing	12	classes/SystemDML.cls:30	classes/SystemDML.cls:30	R-074 (Q299)	False positive
Sharing	13	classes/StripePaymentSweep.cls:26	classes/StripePaymentSweep.cls:26	R-075 (Q303)	False positive
Sharing	14	classes/StagingReconciliationBatch.cls:31	classes/StagingReconciliationBatch.cls:31	R-076 (Q307)	False positive
Sharing	15	classes/SettingsService.cls:543	classes/SettingsService.cls:543	R-077 (Q311)	False positive
Sharing	16	classes/RetentionPurgeBatch.cls:16	classes/RetentionPurgeBatch.cls:16	R-078 (Q315)	False positive
Sharing	17	classes/RefundReconciliationBatch.cls:44	classes/RefundReconciliationBatch.cls:44	R-079 (Q319)	False positive
Sharing	18	classes/ReconciliationHeartbeat.cls:11	classes/ReconciliationHeartbeat.cls:11	R-080 (Q323)	False positive
Sharing	19	classes/PricebookService.cls:25	classes/PricebookService.cls:25	R-081 (Q327)	False positive
Sharing	20	classes/PostInstallHandler.cls:18	classes/PostInstallHandler.cls:18	R-082 (Q331)	False positive
Sharing	21	classes/NpsSyncService.cls:14	classes/NpsSyncService.cls:14	R-083 (Q335)	False positive
Sharing	22	classes/GuestRequestService.cls:13	classes/GuestRequestService.cls:13	R-084 (Q339)	False positive
Sharing	23	classes/EventRegistrationController.cls:9	classes/EventRegistrationController.cls:9	R-085 (Q343)	False positive
Sharing	24	classes/DonorPortalService.cls:48	classes/DonorPortalService.cls:48	R-086 (Q347)	False positive
Sharing	25	classes/CommunityService.cls:13	classes/CommunityService.cls:13	R-087 (Q351)	False positive
Sharing	26	classes/AttendeeNamingHandler.cls:14	classes/AttendeeNamingHandler.cls:14	R-088 (Q355)	False positive
Sharing	27	classes/AppLogger.cls:9	classes/AppLogger.cls:9	R-089 (Q359)	False positive
Apex VF Dynamic JS Resource	1	pages/stripePayment.page:52	pages/stripePayment.page:52	R-090 (Q363)	False positive

Query	Path	Source (scan)	Sink (scan)	Entry	Status
Apex VF Dynamic JS Resource	2	pages/stripePaymentReturn.page:39	pages/stripePaymentReturn.page:39	R-091 (Q367)	False positive

Appendix B — code-quality findings

The scan also reports code-quality rules. They are below the severity the false-positive documentation covers, and they are not security findings, but they appear in the same report, so each path is classified by the file its flagged statement sits in and each group carries one disposition.

Rule	Group	Paths	Status
Multiple Trigger On same sObject	One trigger per object — scanner misfire	4	False positive
DML Statements Inside Loops	Unit of Work commit — one statement per object type	12	By design
DML Statements Inside Loops	Batch job — per-row isolation by design	9	By design
DML Statements Inside Loops	Error logging — guarded insert	47	By design
DML Statements Inside Loops	Single statement after the loop	27	By design
DML Statements Inside Loops	Test fixture	1	By design
Total		100	

Multiple Trigger On same sObject — 4 paths

What this rule says: *This rule identifies the presence of multiple Apex triggers associated with the same sObject. Simply having triggers on the same sObject is not an issue. However, it is possible to have redundant code or logic executed in the multiple triggers. Examining multiple triggers may be a way to enhance and improve the code. Please be aware that there is no guarantee the order in which multiple triggers on the same sObject execute.*

One trigger per object — scanner misfire — 4 paths (False positive). The package has exactly one trigger per object; each is a single line that hands off to its FFLib domain class (`fflib_SObjectDomain.triggerHandler`). The reported triggers are on four different objects (Contact, the donation-designation object, the ticket-type object and the payment-account object). Reproduce with `grep -h "^trigger" base/main/default/triggers/*.trigger | awk '{print $4}' | sort | uniq -d`, which prints nothing. What the four share is an event list, in pairs: the Contact and donation-designation triggers each declare the four after events, where FFLib asserts the running user's object permission, and the ticket-type and payment-account triggers each declare `before delete` only. The rule matches triggers by event list, not by object. The previous scan reported the Contact, Opportunity and recurring-donation triggers together, when all three declared the same seven events; once the Contact and recurring-donation triggers were reduced to the events their domain classes use, the Opportunity and recurring-donation triggers each had an event list of their own and dropped out of the report, and the Contact trigger is now reported with the donation-designation trigger instead. No trigger whose event list is its own has been reported in any run.

Files: `ContactTrigger.trigger` (1), `DonationDesignationTrigger.trigger` (1), `EventTicketTypeTrigger.trigger` (1), `PaymentAccountTrigger.trigger` (1)

DML Statements Inside Loops — 96 paths

What this rule says: *This rule identifies Apex where DML statements execute within a loop. It is a best practice to ensure no SOQL or SOSL statements are executed inside a loop and instead, that the query/search statements retrieve all the necessary data in a single execution.*

Unit of Work commit — one statement per object type — 12 paths (By design).

`fflib_SObjectUnitOfWork.commitWork()` and its `SystemDML` strategy iterate over the registered object types and issue one DML statement per type, passing the full list of records of that type. The number of statements is bounded by the number of object types registered, not by the number of records, which is the bulkification pattern the Unit of Work exists to provide.

Files: `fflib_SObjectUnitOfWork.cls` (8), `SystemDML.cls` (4)

Batch job — per-row isolation by design — 9 paths (By design). The two jobs write per record on purpose.

`StripePaymentSweep` runs with a batch scope of 1 and caps repairs at 5 per run, so each execution writes for one payment account. `StagingReconciliationBatch` runs with a scope of 5, makes all its Stripe callouts first, then writes

each staging row's outcome separately so that one row's failure does not roll back the outcome already recorded for another. Both stay far inside the per-transaction DML limit.

Files: `StripePaymentSweep.cls` (5), `StagingReconciliationBatch.cls` (4)

Error logging — guarded insert — 47 paths (By design). `AppLogger.write()` inserts one `Log__c` row per call. The callers inside loops log from catch blocks, anomaly branches and per-row outcome notices. Before inserting, `write()` returns when the entry's level is below the org's configured log-level threshold (or logging is off), and when the transaction has no DML statements left (`Limits.getLimitDmlStatements() <= Limits.getDmlStatements()`), so logging cannot raise a limit exception that would mask the error being recorded. The insert itself is wrapped in try/catch.

Files: `AppLogger.cls` (47)

Single statement after the loop — 27 paths (By design). The DML statement is not inside the loop the scanner names. In each path the loop builds the list that one bulk statement then writes (`insert as system newStd, Database.insert(toCreate, false, AccessLevel.USER_MODE), Database.update(toUpdate, false, ...)`), generates a token character by character before a single insert, or joins the record-type mappings into one encoded string that a single upsert of the settings record then saves; in the remaining paths the loop is in a test method that calls the service more than once. The rule follows data from the loop into any method that contains a DML statement, including a call made once after the loop has ended, so a bulk call that receives the list the loop built is reported as DML inside the loop. The statement runs once per call whatever the number of records.

Files: `PricebookService.cls` (10), `CampaignPostService.cls` (7), `EventPurchaseService.cls` (4), `DonorPortalService.cls` (3), `AttendeeNamingHandler.cls` (1), `DonationService.cls` (1), `SettingsService.cls` (1)

Test fixture — 1 paths (By design). The loop and the DML are in test code (`TestDataFactory` and `_Test` classes) that builds a small, fixed set of records for a test. Test classes do not run in subscriber transactions.

Files: `AttendeeNamingHandler_Test.cls` (1)

Rule	Path	First node (scan)	Flagged statement (scan)	Group	Status
Multiple Trigger On same sObject	1	<code>triggers/ContactTrigger.trigger:2</code>	<code>triggers/ContactTrigger.trigger:2</code>	One trigger per object — scanner misfire	False positive
Multiple Trigger On same sObject	2	<code>triggers/DonationDesignationTrigger.trigger:2</code>	<code>triggers/DonationDesignationTrigger.trigger:2</code>	One trigger per object — scanner misfire	False positive
Multiple Trigger On same sObject	3	<code>triggers/EventTicketTypeTrigger.trigger:1</code>	<code>triggers/EventTicketTypeTrigger.trigger:1</code>	One trigger per object — scanner misfire	False positive
Multiple Trigger On same sObject	4	<code>triggers/PaymentAccountTrigger.trigger:1</code>	<code>triggers/PaymentAccountTrigger.trigger:1</code>	One trigger per object — scanner misfire	False positive
DML Statements Inside Loops	1	<code>classes/fflib_SObjectUnitOfWork.cls:1037</code>	<code>classes/SystemDML.cls:35</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	2	<code>classes/fflib_SObjectUnitOfWork.cls:1037</code>	<code>classes/fflib_SObjectUnitOfWork.cls:208</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	3	<code>classes/fflib_SObjectUnitOfWork.cls:1037</code>	<code>classes/fflib_SObjectUnitOfWork.cls:286</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	4	<code>classes/fflib_SObjectUnitOfWork.cls:1046</code>	<code>classes/SystemDML.cls:40</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	5	<code>classes/fflib_SObjectUnitOfWork.cls:1046</code>	<code>classes/fflib_SObjectUnitOfWork.cls:218</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	6	<code>classes/fflib_SObjectUnitOfWork.cls:1046</code>	<code>classes/fflib_SObjectUnitOfWork.cls:290</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	7	<code>classes/fflib_SObjectUnitOfWork.cls:1056</code>	<code>classes/SystemDML.cls:45</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	8	<code>classes/fflib_SObjectUnitOfWork.cls:1056</code>	<code>classes/fflib_SObjectUnitOfWork.cls:229</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	9	<code>classes/fflib_SObjectUnitOfWork.cls:1056</code>	<code>classes/fflib_SObjectUnitOfWork.cls:299</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	10	<code>classes/fflib_SObjectUnitOfWork.cls:1070</code>	<code>classes/SystemDML.cls:50</code>	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	11	<code>classes/fflib_SObjectUnitOfWork.cls:1070</code>	<code>classes/fflib_SObjectUnitOfWork.cls:240</code>	Unit of Work commit — one statement per object type	By design

Rule	Path	First node (scan)	Flagged statement (scan)	Group	Status
DML Statements Inside Loops	12	classes/fflib_SObjectUnitOfWork.cls:1070	classes/fflib_SObjectUnitOfWork.cls:294	Unit of Work commit — one statement per object type	By design
DML Statements Inside Loops	13	classes/StripePaymentSweep.cls:149	classes/StripePaymentSweep.cls:203	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	14	classes/StripePaymentSweep.cls:149	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	15	classes/StripePaymentSweep.cls:149	classes/EventPurchaseService.cls:590	Single statement after the loop	By design
DML Statements Inside Loops	16	classes/StagingReconciliationBatch.cls:92	classes/StagingReconciliationBatch.cls:234	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	17	classes/StagingReconciliationBatch.cls:92	classes/StagingReconciliationBatch.cls:240	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	18	classes/StagingReconciliationBatch.cls:92	classes/StagingReconciliationBatch.cls:275	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	19	classes/StagingReconciliationBatch.cls:92	classes/StagingReconciliationBatch.cls:281	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	20	classes/StagingReconciliationBatch.cls:92	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	21	classes/StagingReconciliationBatch.cls:92	classes/EventPurchaseService.cls:590	Single statement after the loop	By design
DML Statements Inside Loops	22	classes/GuestRequestService.cls:140	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	23	classes/RecurringRenewalBatch.cls:153	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	24	classes/StripePaymentSweep.cls:86	classes/StripePaymentSweep.cls:191	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	25	classes/StripePaymentSweep.cls:86	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	26	classes/NpsSyncService.cls:82	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	27	classes/NpsSyncService.cls:148	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	28	classes/CampaignMemberSyncService.cls:150	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	29	classes/CampaignMemberSyncService.cls:152	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	30	classes/CampaignDesignationService.cls:171	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	31	classes/AttendeeNamingHandler.cls:193	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	32	classes/RefundReconciliationBatch.cls:217	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	33	classes/ReceiptService.cls:313	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	34	classes/ReceiptService.cls:392	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	35	classes/FundraiserAdminController.cls:519	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	36	classes/CommunityService.cls:698	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	37	classes/EventPurchaseService.cls:911	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	38	classes/EventPurchaseService.cls:917	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	39	classes/RecurringRenewalBatch.cls:80	classes/AppLogger.cls:125	Error logging — guarded insert	By design

Rule	Path	First node (scan)	Flagged statement (scan)	Group	Status
DML Statements Inside Loops	40	classes/StripePaymentSweep_Test.cls:207	classes/StripePaymentSweep.cls:191	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	41	classes/StripePaymentSweep_Test.cls:207	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	42	classes/RecurringRenewalBatch.cls:66	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	43	classes/EventTicketAdminController.cls:258	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	44	classes/EventTicketAdminController.cls:258	classes/PricebookService.cls:125	Single statement after the loop	By design
DML Statements Inside Loops	45	classes/EventTicketAdminController.cls:258	classes/PricebookService.cls:135	Single statement after the loop	By design
DML Statements Inside Loops	46	classes/RefundReconciliationBatch.cls:283	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	47	classes/EventRegistrationController.cls:591	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	48	classes/EventPurchaseService.cls:1195	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	49	classes/NpsSyncService.cls:114	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	50	classes/GuestRequestService.cls:124	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	51	classes/AttendeeNamingHandler_Test.cls:237	classes/AttendeeNamingHandler_Test.cls:40	Test fixture	By design
DML Statements Inside Loops	52	classes/AttendeeNamingHandler_Test.cls:237	classes/AttendeeNamingHandler.cls:129	Single statement after the loop	By design
DML Statements Inside Loops	53	classes/SecureTokens.cls:30	classes/DonationService.cls:890	Single statement after the loop	By design
DML Statements Inside Loops	54	classes/CancelGoalReachedRecurringQueueable.cls:89	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	55	classes/RefundReconciliationBatch.cls:177	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	56	classes/ReceiptService.cls:514	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	57	classes/CampaignPostService.cls:679	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	58	classes/PostInstallHandler.cls:804	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	59	classes/AttendeeNamingHandler.cls:133	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	60	classes/CampaignPostService.cls:332	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	61	classes/CommunityService.cls:728	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	62	classes/CampaignMemberSyncService.cls:65	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	63	classes/StripePaymentSweep.cls:113	classes/StripePaymentSweep.cls:203	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	64	classes/StripePaymentSweep.cls:113	classes/EventPurchaseService.cls:590	Single statement after the loop	By design
DML Statements Inside Loops	65	classes/AttendeeNamingHandler.cls:185	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	66	classes/CompanyMatchService.cls:47	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	67	classes/EventPurchaseService.cls:419	classes/AppLogger.cls:125	Error logging — guarded insert	By design

Rule	Path	First node (scan)	Flagged statement (scan)	Group	Status
DML Statements Inside Loops	68	classes/DonorPortalService.cls:452	classes/DonorPortalService.cls:443	Single statement after the loop	By design
DML Statements Inside Loops	69	classes/CommunityService.cls:793	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	70	classes/PostInstallHandler.cls:1754	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	71	classes/CampaignPostService.cls:613	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	72	classes/EventPurchaseService.cls:1049	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	73	classes/CampaignPostService.cls:286	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	74	classes/CampaignPostService.cls:302	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	75	classes/EventPurchaseService.cls:832	classes/PricebookService.cls:125	Single statement after the loop	By design
DML Statements Inside Loops	76	classes/EventPurchaseService.cls:832	classes/PricebookService.cls:135	Single statement after the loop	By design
DML Statements Inside Loops	77	classes/RecurringRenewalBatch.cls:426	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	78	classes/NpsSyncService.cls:56	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	79	classes/RecordTypeMappingService.cls:112	classes/SettingsService.cls:345	Single statement after the loop	By design
DML Statements Inside Loops	80	classes/StripeGateway.cls:533	classes/StripePaymentSweep.cls:203	Batch job — per-row isolation by design	By design
DML Statements Inside Loops	81	classes/StripeGateway.cls:533	classes/EventPurchaseService.cls:590	Single statement after the loop	By design
DML Statements Inside Loops	82	classes/RecurringRenewalBatch_Test.cls:722	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	83	classes/PricebookService_Test.cls:182	classes/PricebookService.cls:125	Single statement after the loop	By design
DML Statements Inside Loops	84	classes/PricebookService_Test.cls:182	classes/PricebookService.cls:135	Single statement after the loop	By design
DML Statements Inside Loops	85	classes/CampaignPostService.cls:589	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	86	classes/RecurringDonationService_Test.cls:1399	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	87	classes/RefundReconciliationBatch.cls:628	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	88	classes/CampaignPostService.cls:605	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	89	classes/AttendeeNamingHandler.cls:92	classes/AppLogger.cls:125	Error logging — guarded insert	By design
DML Statements Inside Loops	90	classes/CampaignPostService.cls:256	classes/CampaignPostService.cls:678	Single statement after the loop	By design
DML Statements Inside Loops	91	classes/EventTicketAdminController.cls:210	classes/PricebookService.cls:125	Single statement after the loop	By design
DML Statements Inside Loops	92	classes/EventTicketAdminController.cls:210	classes/PricebookService.cls:135	Single statement after the loop	By design
DML Statements Inside Loops	93	classes/DonorPortalService_Test.cls:456	classes/DonorPortalService.cls:392	Single statement after the loop	By design
DML Statements Inside Loops	94	classes/DonorPortalService_Test.cls:456	classes/DonorPortalService.cls:383	Single statement after the loop	By design
DML Statements Inside Loops	95	classes/EventPurchaseService.cls:772	classes/PricebookService.cls:125	Single statement after the loop	By design

Rule	Path	First node (scan)	Flagged statement (scan)	Group	Status
DML Statements Inside Loops	96	classes/EventPurchaseService.cls:772	classes/PricebookService.cls:135	Single statement after the loop	By design